

# Contents

|          |                                           |           |
|----------|-------------------------------------------|-----------|
| <b>1</b> | <b>基本設計 index(運営者システム)</b>                | <b>6</b>  |
| 1.1      | 0. 文書情報                                   | 6         |
| 1.2      | 1. 目的・対象範囲                                | 6         |
| 1.3      | 2. 設計方針(全体像)                              | 6         |
| 1.4      | 3. システム構成(全体像)                            | 7         |
| 1.5      | 4. 機能一覧(FRxx_*.md と基本設計成果物の対応)            | 7         |
| 1.6      | 5. SCR × ドキュメント カバレッジ表                    | 8         |
| 1.7      | 6. 4-eyes 対象 10 操作カバレッジ表                  | 9         |
| 1.8      | 7. 連携 IF × ドキュメント カバレッジ                   | 10        |
| 1.9      | 8. 関連ドキュメント                               | 10        |
| 1.10     | 9. 未確定事項・確認事項                             | 10        |
| 1.11     | 10. 変更履歴                                  | 11        |
| <b>2</b> | <b>画面設計書 (運営者)</b>                        | <b>11</b> |
| 2.1      | 1. 文書概要                                   | 11        |
| 2.1.1    | 1.1 目的                                    | 11        |
| 2.1.2    | 1.2 対象範囲                                  | 11        |
| 2.1.3    | 1.3 版数                                    | 11        |
| 2.1.4    | 1.4 関連ドキュメント                              | 11        |
| 2.2      | 2. 画面一覧                                   | 11        |
| 2.3      | 3. 画面遷移                                   | 12        |
| 2.3.1    | 3.1 Mermaid 遷移図                           | 12        |
| 2.4      | 4. 共通 UI 部品 + サイドメニュー                     | 12        |
| 2.4.1    | 4.1 既存共通部品                                | 12        |
| 2.4.2    | 4.2 UI/UX 共通要件で追加する部品                     | 13        |
| 2.4.3    | 4.3 文言の共通基準                               | 13        |
| 2.4.4    | 4.4 サイドメニュー                               | 13        |
| 2.5      | 5. 画面詳細                                   | 14        |
| 2.5.1    | 5.1 SCR-AUTH 運営者ログイン                      | 14        |
| 2.5.2    | 5.2 SCR-AUTH-M1 MFA 初回セットアップ              | 15        |
| 2.5.3    | 5.3 SCR-HOME ホームダッシュボード                   | 16        |
| 2.5.4    | 5.4 SCR-090 削除データ参照                       | 16        |
| 2.5.5    | 5.5 SCR-091 削除データ復元                       | 17        |
| 2.5.6    | 5.6 SCR-092 AI 推論パラメータ設定(契約別上書き、ハードゲート)   | 18        |
| 2.5.7    | 5.7 SCR-093 契約別レート制限・予算上書き管理              | 18        |
| 2.5.8    | 5.8 SCR-094 お知らせ作成・配信                     | 19        |
| 2.5.9    | 5.9 SCR-096 運営者活動ダッシュボード(監査)              | 20        |
| 2.5.10   | 5.10 SCR-097 課金 Webhook リプレイ・DLQ 操作       | 21        |
| 2.5.11   | 5.11 SCR-098 PII 誤検出報告管理                  | 21        |
| 2.5.12   | 5.12 SCR-099 Webhook ペイロード差分検出一覧          | 22        |
| 2.5.13   | 5.13 SCR-APPROVALS 承認待ち一覧(4-eyes)         | 23        |
| 2.5.14   | 5.14 SCR-APPROVALS-M1 4-eyes 承認申請モジュール    | 24        |
| 2.5.15   | 5.15 SCR-APPROVALS-M2 4-eyes 承認 / 却下モジュール | 24        |
| 2.6      | 6. ユーザー種別別表示制御                            | 25        |
| 2.7      | 7. 未決事項                                   | 25        |
| 2.8      | 8. 変更履歴                                   | 25        |
| <b>3</b> | <b>API 設計書 (運営者)</b>                      | <b>25</b> |
| 3.1      | 1. 文書概要                                   | 25        |
| 3.1.1    | 1.1 目的                                    | 25        |
| 3.1.2    | 1.2 対象範囲                                  | 25        |
| 3.1.3    | 1.3 版数                                    | 25        |
| 3.1.4    | 1.4 関連ドキュメント                              | 26        |
| 3.2      | 2. API 一覧                                 | 26        |
| 3.2.1    | 2.1 機能ブロック別 API(§ 6.4)                    | 26        |
| 3.3      | 3. 共通仕様                                   | 26        |
| 3.3.1    | 3.1 認証ヘッダ / セッション                         | 26        |
| 3.3.2    | 3.2 ticket_id 入力規約                        | 27        |
| 3.3.3    | 3.3 再認証(5 分以内)                            | 27        |
| 3.3.4    | 3.4 4-eyes 承認チェック                         | 27        |

|       |                                       |    |
|-------|---------------------------------------|----|
| 3.3.5 | 3.5 Stripe Webhook 一次受信仕様             | 27 |
| 3.3.6 | 3.6 連携 IF 共通仕様 (mTLS + JWT)           | 27 |
| 3.4   | 4. レート制限・キャパシティ (運営者側 § 11.7、全 17 項目) | 27 |
| 3.5   | 5. API 詳細                             | 28 |
| 3.5.1 | 5.1 運営者認証 API                         | 28 |
| 3.5.2 | 5.2 4-eyes 承認 API (本書の中核)             | 29 |
| 3.5.3 | 5.3 削除データ参照・復元 API                    | 29 |
| 3.5.4 | 5.4 AI パラメータ・契約上書き API                | 30 |
| 3.5.5 | 5.5 お知らせ API                          | 31 |
| 3.5.6 | 5.6 監査・PII 報告 API                     | 31 |
| 3.5.7 | 5.7 Webhook 関連 API                    | 32 |
| 3.5.8 | 5.8 連携 IF (送信 / 受信)                   | 34 |
| 3.6   | 6. 4-eyes × API 対応表                   | 35 |
| 3.7   | 7. 未決事項                               | 35 |
| 3.8   | 8. 変更履歴                               | 35 |

|          |                                                                          |           |
|----------|--------------------------------------------------------------------------|-----------|
| <b>4</b> | <b>テーブル定義書 (運営者)</b>                                                     | <b>35</b> |
| 4.1      | 1. 文書概要                                                                  | 35        |
| 4.1.1    | 1.1 目的                                                                   | 35        |
| 4.1.2    | 1.2 対象範囲                                                                 | 35        |
| 4.1.3    | 1.3 版数                                                                   | 35        |
| 4.1.4    | 1.4 関連ドキュメント                                                             | 35        |
| 4.2      | 2. テーブル一覧                                                                | 36        |
| 4.2.1    | 2.1 <code>audit_logs.retention_class</code> 値の正本定義 (共有概念)                | 37        |
| 4.2.2    | 2.2 主要関係性 (§ 7.2 ER 図から派生)                                               | 37        |
| 4.2.3    | 2.3 BR ☒ FR / 設計章マッピング (§ 7.1.1)                                         | 37        |
| 4.3      | 3. テーブル詳細                                                                | 38        |
| 4.3.1    | 3.1 <code>service_operators</code> (運営者アカウント)                            | 38        |
| 4.3.2    | 3.2 <code>operator_sessions</code> (運営者セッション)                            | 38        |
| 4.3.3    | 3.3 <code>operator_mfa_secrets</code> (TOTP シークレット)                      | 39        |
| 4.3.4    | 3.4 <code>operator_mfa_recovery_codes</code> (MFA 回復コード)                 | 39        |
| 4.3.5    | 3.5 <code>operator_ip_allowlist</code> (IP 許可リスト、共有概念正本)                 | 39        |
| 4.3.6    | 3.6 <code>operator_approvals</code> (4-eyes 申請・承認、共有概念正本)                | 39        |
| 4.3.7    | 3.7 <code>audit_logs</code> (監査ログ、ハッシュチェーン構造の正本)                         | 40        |
| 4.3.8    | 3.8 <code>webhook_events</code> (Stripe Webhook 受信、共有概念正本)               | 41        |
| 4.3.9    | 3.9 <code>webhook_payload_diffs</code> (Webhook ペイロード差分検出)               | 41        |
| 4.3.10   | 3.10 <code>dlq_replay_log</code> (DLQ リプレイ履歴)                            | 42        |
| 4.3.11   | 3.11 <code>pii_false_positive_reports</code> (PII 誤検出報告)                 | 42        |
| 4.3.12   | 3.12 <code>announcement_drafts</code> (お知らせ下書き)                          | 43        |
| 4.3.13   | 3.13 <code>accounts_retired</code> (物理削除契約証跡、永久保持)                       | 43        |
| 4.3.14   | 3.14 <code>owner_registration_reviews</code> (契約登録審査)                    | 44        |
| 4.3.15   | 3.15 <code>rate_limit_overrides</code> (契約別レート上書き)                       | 44        |
| 4.3.16   | 3.16 <code>ai_parameter_overrides</code> (AI パラメータ 3 階層上書き)              | 44        |
| 4.3.17   | 3.17 <code>budget_limit_overrides</code> (契約別予算上限)                       | 44        |
| 4.3.18   | 3.18 <code>billing_invoices</code> (月次請求書、運営者側主管)                        | 45        |
| 4.3.19   | 3.19 <code>webhook_replay_requests</code> (リプレイ要求受付)                     | 45        |
| 4.4      | 4. ER 図 (運営者側、§ 7.2 から移管)                                                | 45        |
| 4.5      | 5. テーブル間関連 (§ 2.2 と同期)                                                   | 45        |
| 4.6      | 6. 命名規則・型方針 (§ 7.9 から移管)                                                 | 45        |
| 4.7      | 7. SaaS データ分離観点 (運営者側固有)                                                 | 46        |
| 4.7.1    | 7.1 運営者は全契約横断アクセス                                                        | 46        |
| 4.7.2    | 7.2 監査ログの完全性                                                             | 46        |
| 4.8      | 8. 状態コード値・状態遷移 (§ 4 + 付録 B から移管)                                         | 46        |
| 4.8.1    | 8.1 4-eyes 申請・承認状態 ( <code>operator_approvals.state</code> 、付録 B.3)      | 46        |
| 4.8.2    | 8.2 Webhook イベント状態遷移 ( <code>webhook_events.state</code> 、付録 B.2)        | 46        |
| 4.8.3    | 8.3 お知らせ下書き状態 ( <code>announcement_drafts.state</code> 、付録 B.4)          | 47        |
| 4.8.4    | 8.4 PII 誤検出報告状態 ( <code>pii_false_positive_reports.state</code> 、付録 B.5) | 47        |
| 4.8.5    | 8.5 Webhook 差分状態 ( <code>webhook_payload_diffs.state</code> 、付録 B.6)     | 47        |
| 4.8.6    | 8.6 契約状態 ( <code>accounts.contract_status</code> (オーナー行)、付録 B.7)         | 47        |
| 4.9      | 9. 監査ログ action コード × <code>retention_class</code> 割当表 (付録 F 全件、共有概念正本)   | 48        |
| 4.9.1    | 9.1 <b>1y</b> (業務監査)                                                     | 48        |
| 4.9.2    | 9.2 <b>5y</b> (運営者高権限)                                                   | 48        |

|          |                                           |           |
|----------|-------------------------------------------|-----------|
| 4.9.3    | 9.3 7y(課金・取引)                             | 48        |
| 4.10     | 10. インデックス方針 (§ 7.10 から移管)                | 48        |
| 4.11     | 11. データ削除モード (運営者側固有)                     | 48        |
| 4.12     | 12. 未決事項                                  | 48        |
| 4.13     | 13. 変更履歴                                  | 49        |
| <b>5</b> | <b>権限設計書 (運営者)</b>                        | <b>49</b> |
| 5.1      | 1. 文書概要                                   | 49        |
| 5.1.1    | 1.1 目的                                    | 49        |
| 5.1.2    | 1.2 対象範囲                                  | 49        |
| 5.1.3    | 1.3 版数                                    | 49        |
| 5.1.4    | 1.4 関連ドキュメント                              | 49        |
| 5.2      | 2. ロール一覧                                  | 49        |
| 5.2.1    | 2.1 単一ロール採用理由                             | 49        |
| 5.2.2    | 2.2 ロール識別子                                | 50        |
| 5.3      | 3. 画面別権限                                  | 50        |
| 5.4      | 4. 機能別権限                                  | 50        |
| 5.5      | 5. API 別権限                                | 51        |
| 5.6      | 6. 緊急時のみ可操作                               | 52        |
| 5.7      | 7. 4-eyes 対象 10 操作 (本書の中核、付録 E から移管)      | 52        |
| 5.7.1    | 7.1 ハードゲート 3 操作 (KV フラグが false なら API 拒否) | 52        |
| 5.7.2    | 7.2 承認ログ 7 操作                             | 52        |
| 5.7.3    | 7.3 ハードゲート KV フラグの管理                      | 52        |
| 5.7.4    | 7.4 自己承認禁止 / 自己却下禁止 / 取下げ規約               | 52        |
| 5.8      | 8. 4-eyes 未承認・権限不足時の動作                    | 53        |
| 5.9      | 9. 運営者アカウント・ライフサイクル                       | 53        |
| 5.10     | 10. 未決事項                                  | 53        |
| 5.11     | 11. 変更履歴                                  | 54        |
| <b>6</b> | <b>エラー設計書 (運営者)</b>                       | <b>54</b> |
| 6.1      | 1. 文書概要                                   | 54        |
| 6.1.1    | 1.1 目的                                    | 54        |
| 6.1.2    | 1.2 対象範囲                                  | 54        |
| 6.1.3    | 1.3 版数                                    | 54        |
| 6.1.4    | 1.4 関連ドキュメント                              | 54        |
| 6.2      | 2. エラー分類                                  | 54        |
| 6.3      | 3. エラー一覧                                  | 55        |
| 6.3.1    | 3.1 認証エラー (E-OP-AUTH-*)                   | 55        |
| 6.3.2    | 3.2 MFA エラー (E-OP-MFA-*)                  | 55        |
| 6.3.3    | 3.3 IP allowlist エラー (E-OP-IP-*)          | 55        |
| 6.3.4    | 3.4 再認証エラー (E-OP-REAUTH-*)                | 55        |
| 6.3.5    | 3.5 4-eyes エラー (E-OP-4EYES-*)—— 本書の中核     | 56        |
| 6.3.6    | 3.6 認可エラー (E-OP-AUTHZ-*)                  | 56        |
| 6.3.7    | 3.7 入力エラー (E-OP-INPUT-*)                  | 56        |
| 6.3.8    | 3.8 業務エラー (E-OP-BIZ-*)                    | 57        |
| 6.3.9    | 3.9 Webhook エラー (E-OP-WEBHOOK-*)          | 57        |
| 6.3.10   | 3.10 PII 報告エラー (E-OP-PII-*)               | 57        |
| 6.3.11   | 3.11 復元エラー (E-OP-RESTORE-*)               | 57        |
| 6.3.12   | 3.12 連携 IF エラー (E-OP-IF-*)                | 57        |
| 6.3.13   | 3.13 システムエラー (E-OP-SYS-*)                 | 58        |
| 6.4      | 4. 異常系共通方針                                | 58        |
| 6.4.1    | 4.1 IP allowlist 拒否                       | 58        |
| 6.4.2    | 4.2 MFA エラー                               | 58        |
| 6.4.3    | 4.3 再認証期限切れ                               | 58        |
| 6.4.4    | 4.4 4-eyes 未承認 (本書の中核)                    | 58        |
| 6.4.5    | 4.5 自己承認 / 自己却下                           | 58        |
| 6.4.6    | 4.6 承認 TTL 切れ                             | 58        |
| 6.4.7    | 4.7 payload_hash 改ざん検知                    | 58        |
| 6.4.8    | 4.8 Webhook 関連                            | 59        |
| 6.4.9    | 4.9 復元エラー                                 | 59        |
| 6.4.10   | 4.10 連携 IF エラー (送信側)                      | 59        |
| 6.5      | 5. ステータスコード対応表                            | 59        |

|          |                                              |           |
|----------|----------------------------------------------|-----------|
| 6.6      | 6. 運営者通知 <b>critical</b> レベルエラー              | 59        |
| 6.7      | 7. 未決事項                                      | 60        |
| 6.8      | 8. 変更履歴                                      | 60        |
| <b>7</b> | <b>メッセージ一覧 (運営者)</b>                         | <b>60</b> |
| 7.1      | 1. 文書概要                                      | 60        |
| 7.1.1    | 1.1 目的                                       | 60        |
| 7.1.2    | 1.2 対象範囲                                     | 60        |
| 7.1.3    | 1.3 版数                                       | 60        |
| 7.1.4    | 1.4 関連ドキュメント                                 | 60        |
| 7.2      | 2. 共通基準                                      | 60        |
| 7.2.1    | 2.1 運営者向け文言の特徴                               | 60        |
| 7.2.2    | 2.2 4-eyes 用語                                | 61        |
| 7.2.3    | 2.3 通知重要度ルール (共有概念、メイン側 § 2.4 参照)            | 61        |
| 7.3      | 3. メッセージ ID 体系                               | 61        |
| 7.4      | 4. 画面別メッセージ全件                                | 61        |
| 7.4.1    | 4.1 SCR-AUTH 運営者ログイン                         | 61        |
| 7.4.2    | 4.2 SCR-AUTH-M1 MFA 初回セットアップ                 | 62        |
| 7.4.3    | 4.3 SCR-HOME ホームダッシュボード                      | 62        |
| 7.4.4    | 4.4 SCR-090 削除データ参照                          | 62        |
| 7.4.5    | 4.5 SCR-091 削除データ復元                          | 63        |
| 7.4.6    | 4.6 SCR-092 AI 推論パラメータ (ハードゲート)              | 63        |
| 7.4.7    | 4.7 SCR-093 契約別レート / 予算上書き                   | 63        |
| 7.4.8    | 4.8 SCR-094 お知らせ作成・配信                        | 64        |
| 7.4.9    | 4.9 SCR-096 運営者活動ダッシュボード                     | 64        |
| 7.4.10   | 4.10 SCR-097 課金 Webhook リプレイ・DLQ             | 64        |
| 7.4.11   | 4.11 SCR-098 PII 誤検出報告                       | 65        |
| 7.4.12   | 4.12 SCR-099 Webhook ペイロード差分検出               | 65        |
| 7.4.13   | 4.13 SCR-APPROVALS 承認待ち一覧 (4-eyes)           | 65        |
| 7.4.14   | 4.14 SCR-APPROVALS-M1 4-eyes 承認申請モダル         | 65        |
| 7.4.15   | 4.15 SCR-APPROVALS-M2 4-eyes 承認 / 却下モダル      | 66        |
| 7.5      | 5. サイドメニュー (共通 UI)                           | 66        |
| 7.6      | 6. 4-eyes 関連メッセージ集約 (本書の中核)                  | 67        |
| 7.7      | 7. 認証・認可関連メッセージ (運営者固有)                      | 67        |
| 7.8      | 8. 通知契機 (運営者向け、§ 9.1 から移管)                   | 68        |
| 7.8.1    | 8.1 運営者宛通知 12 種                              | 68        |
| 7.8.2    | 8.2 IF #12 経由 利用者向け運営者操作通知 (FR-211、集約窓 10 分) | 68        |
| 7.8.3    | 8.3 通知テンプレート                                 | 69        |
| 7.8.4    | 8.4 運営者 inbox 設計                             | 69        |
| 7.9      | 9. エラー別メッセージ対応表                              | 69        |
| 7.10     | 10. 未決事項                                     | 70        |
| 7.11     | 11. 変更履歴                                     | 70        |
| <b>8</b> | <b>トレーサビリティマトリクス (運営者)</b>                   | <b>70</b> |
| 8.1      | 1. 文書概要                                      | 70        |
| 8.1.1    | 1.1 目的                                       | 70        |
| 8.1.2    | 1.2 対象範囲                                     | 70        |
| 8.1.3    | 1.3 版数                                       | 70        |
| 8.1.4    | 1.4 関連ドキュメント                                 | 71        |
| 8.2      | 2. 要件・設計対応表 (主要 FR / NFR)                    | 71        |
| 8.3      | 3. 機能・画面・API 対応表                             | 73        |
| 8.4      | 4. 画面・メッセージ対応表 (主要)                          | 74        |
| 8.5      | 5. API・エラー対応表                                | 75        |
| 8.6      | 6. 4-eyes × 画面 × API 対応表 (運営者側固有)            | 75        |
| 8.7      | 7. 連携 IF × ドキュメント対応表                         | 76        |
| 8.8      | 8. テスト観点との対応 (運営者側固有)                        | 76        |
| 8.8.1    | 8.1 運営者側テスト観点 6 列の定義                         | 76        |
| 8.8.2    | 8.2 主要要件のテスト観点表                              | 76        |
| 8.9      | 9. 不足・不整合一覧                                  | 77        |
| 8.10     | 10. 未決事項                                     | 77        |
| 8.11     | 11. 変更履歴                                     | 77        |

|                                                              |           |
|--------------------------------------------------------------|-----------|
| <b>9 認証・認可設計書 (運営者)</b>                                      | <b>78</b> |
| 9.1 1. 文書概要                                                  | 78        |
| 9.1.1 1.1 目的                                                 | 78        |
| 9.1.2 1.2 対象範囲                                               | 78        |
| 9.1.3 1.3 版数                                                 | 78        |
| 9.1.4 1.4 関連ドキュメント                                           | 78        |
| 9.2 2. 認証方式                                                  | 78        |
| 9.3 3. IP allowlist(共有概念正本)                                  | 78        |
| 9.4 4. MFA(TOTP)                                             | 79        |
| 9.5 5. セッション・トークン設計                                          | 79        |
| 9.5.1 5.1 重要操作の再認証 (FR-222) 対象                               | 79        |
| 9.6 6. 運営者アカウント・ライフサイクル (§ 3.5 から移管)                         | 79        |
| 9.7 6.1 操作チケット ID 入力規約 (§ 3.6 から移管)                          | 80        |
| 9.8 7. 認可モデル                                                 | 80        |
| 9.8.1 7.1 認可方式                                               | 80        |
| 9.8.2 7.2 オーナー境界                                             | 80        |
| 9.8.3 7.3 6 段階認可判定順序 (共有概念正本、§ 3.4 から移管)                     | 80        |
| 9.9 8. 4-eyes 承認フロー (本書の中核、共有概念正本)                           | 81        |
| 9.9.1 8.1 4-eyes 対象操作 (§ 3.3 から移管)                           | 81        |
| 9.9.2 8.2 ハードゲート KV フラグの管理                                   | 81        |
| 9.9.3 8.3 <b>operator_approvals</b> データモデル (論理設計、§ 6.5 から移管) | 81        |
| 9.9.4 8.4 4-eyes 申請・承認状態遷移 (§ 4.5 から移管)                      | 82        |
| 9.9.5 8.5 申請 → 承認 → 実行フロー                                    | 82        |
| 9.9.6 8.6 自己承認禁止 / 自己却下禁止 / 取下げ規約                            | 82        |
| 9.10 9. セキュリティ二段ガード (運営者専用、§ 10.0.3)                         | 82        |
| 9.11 10. アカウント状態                                             | 82        |
| 9.12 11. 認証・認可エラー                                            | 83        |
| 9.13 12. 未決事項                                                | 83        |
| 9.14 13. 変更履歴                                                | 83        |
| <b>10 セキュリティ設計書 (運営者)</b>                                    | <b>83</b> |
| 10.1 1. 文書概要                                                 | 83        |
| 10.1.1 1.1 目的                                                | 83        |
| 10.1.2 1.2 対象範囲                                              | 84        |
| 10.1.3 1.3 版数                                                | 84        |
| 10.1.4 1.4 関連ドキュメント                                          | 84        |
| 10.2 2. セキュリティ基本方針                                           | 84        |
| 10.2.1 2.1 保護対象 (運営者側固有)                                     | 84        |
| 10.2.2 2.2 想定脅威 (運営者側固有)                                     | 84        |
| 10.2.3 2.3 基本対策方針                                            | 84        |
| 10.3 3. データ保護 (運営者側固有)                                       | 84        |
| 10.4 4. 入力値検証                                                | 85        |
| 10.5 5. Web 脆弱性対策                                            | 85        |
| 10.5.1 5.1 CSP / Web セキュリティヘッダ (運営者側)                        | 85        |
| 10.5.2 5.2 4-eyes 承認画面の CSRF                                 | 85        |
| 10.6 6. アクセス制御                                               | 85        |
| 10.7 7. 監査・ログ (本書の中核、共有概念正本)                                 | 86        |
| 10.7.1 7.1 ハッシュチェーン構造 (§ 7.3 から移管)                           | 86        |
| 10.7.2 7.2 3 区分保持の物理実装 (§ 7.4 / D-08、共有概念正本)                 | 86        |
| 10.7.3 7.3 物理削除パッチ                                           | 87        |
| 10.7.4 7.4 tombstone 方式                                      | 87        |
| 10.7.5 7.5 監査対象操作の網羅範囲                                       | 87        |
| 10.7.6 7.6 監査ログエクスポート (§ 10.5)                               | 87        |
| 10.8 8. 秘密情報管理 (運営者側固有)                                      | 87        |
| 10.9 9. SaaS 特有のセキュリティ観点 (運営者側固有)                            | 88        |
| 10.10 10. 法令対応 (§ 1.5 から移管)                                  | 88        |
| 10.10.1 10.1 GDPR 越境移転規制への運用ガード (§ 1.5.1)                    | 88        |
| 10.11 11. 不正利用検知 (運営者側固有)                                    | 88        |
| 10.12 12. 監視 (運用統合)                                          | 88        |
| 10.13 13. 脆弱性対応 SLA・SCA・ペネトレーション (§ 10.10)                   | 89        |
| 10.14 14. ウィジェット保護 / PII マスキング / プロンプト注入対策                   | 89        |
| 10.15 15. Webhook 比較除外フィールド (付録 H、D-06)                      | 89        |

|                    |    |
|--------------------|----|
| 10.1616. バックアップ・復旧 | 90 |
| 10.1717. 未決事項      | 90 |
| 10.1818. 変更履歴      | 90 |

## 11 課金・請求設計書 (運営者) 90

|                                                |    |
|------------------------------------------------|----|
| 11.1 1. 文書概要                                   | 90 |
| 11.1.1 1.1 目的                                  | 90 |
| 11.1.2 1.2 対象範囲                                | 90 |
| 11.1.3 1.3 版数                                  | 90 |
| 11.1.4 1.4 関連ドキュメント                            | 90 |
| 11.2 2. 契約モデル(メイン側参照)                          | 91 |
| 11.3 3. 契約別利用上書き(運営者操作)                        | 91 |
| 11.4 4. 契約状態(メイン側参照)                           | 91 |
| 11.5 5. 契約ライフサイクル(運営者側責務)                      | 91 |
| 11.6 6. 契約とオーナーの関係                             | 91 |
| 11.7 7. プラン変更時の仕様                              | 92 |
| 11.8 8. 課金方式                                   | 92 |
| 11.9 9. 請求対象 / 請求状態                            | 92 |
| 11.10 10. 決済フロー                                | 92 |
| 11.11 11. 月次請求確定 cron(本書の中核)                   | 92 |
| 11.12 12. 外部決済サービス連携 (Stripe)                  | 92 |
| 11.13 13. Webhook 処理(本書の中核、共有概念正本)             | 92 |
| 11.13.1 13.1 Stripe Webhook 一次受信(運営者側 → メイン転送) | 92 |
| 11.13.2 13.2 Webhook ペイロード差分検出 (§ 6.7 から移管)    | 93 |
| 11.13.3 13.3 DLQ 30 日リプレイ                      | 93 |
| 11.13.4 13.4 監視・通知                             | 94 |
| 11.14 14. 請求書・領収書(7 年保持)                       | 94 |
| 11.15 15. 課金・契約エラー時の動作(運営者側責務)                 | 94 |
| 11.16 16. 未決事項                                 | 94 |
| 11.17 17. 変更履歴                                 | 94 |

## 1 基本設計 index(運営者システム)

### 1.1 0. 文書情報

| 項目      | 内容                                                 |
|---------|----------------------------------------------------|
| 文書名     | 基本設計 index(運営者システム)                                |
| 対象システム名 | FAQ AI ウィジェット SaaS / 運営者システム (SaaS 提供事業者向け管理コンソール) |
| 作成日     | 2026-05-17                                         |
| 作成者     | プロジェクト設計チーム                                        |
| 版数      | v1.0                                               |
| ステータス   | 承認済 (v1.0 初版)                                      |

### 1.2 1. 目的・対象範囲

| 項目   | 内容                                                                                        |
|------|-------------------------------------------------------------------------------------------|
| 目的   | 運営者システム (SaaS 提供者 = open-faq 運営) の全体方針 + 設計方針 + 個別設計書への索引。詳細仕様は本ディレクトリ配下の 10 個別設計書を正本とする。 |
| 対象範囲 | service_operator 単一ロール + 4-eyes 多段ガード + 監査ハッシュチェーン + Stripe Webhook 一次受信                  |
| 対象外  | 利用者向けメインシステム (../01_メインシステム/02_基本設計/)                                                     |
| 想定読者 | 設計レビュアー / 実装担当者 / 監査担当 / 運用担当                                                             |

### 1.3 2. 設計方針 (全体像)

| #  | 方針                    | 概要                                                                                                  | 詳細                   |
|----|-----------------------|-----------------------------------------------------------------------------------------------------|----------------------|
| 1  | 6 段認可判定方針             | IP allowlist → セッション → MFA → role → 再認証 → 4-eyes の順で全 API・全画面に適用                                    | 08_ 認証・認可設計.md       |
| 2  | 4-eyes 承認フロー方針        | 対象 10 操作のうち 3 操作はハードゲート (承認なし実行不可)、7 操作は承認ログ (実行と承認ログを別運営者で実施)                                      | 04_ 権限設計.md          |
| 3  | 監査ハッシュチェーン方針          | audit_logs 全行に前行ハッシュを連鎖し改竄不能化。日次完全性検証 cron。3 区分保持 (1y / 5y / 7y)。                                   | 09_ セキュリティ設計.md      |
| 4  | Stripe Webhook 一次受信方針 | 運営者側で一次受信し DLQ 30 日リプレイ。署名検証 + payload 差分検出 + メインへの転送                                               | 10_ 課金・請求設計.md       |
| 5  | 画面設計方針                | SCR-090~099 + SCR-AUTH / SCR-HOME / SCR-APPROVALS。承認待ち一覧 + モーダル承認/却下。                               | 01_ 画面設計.md          |
| 6  | API 設計方針              | /v1/operator/* 配下。連携 IF #1~#12 の主管責任 (送信 8 + 受信 2)。                                                 | 02_API 設計.md         |
| 7  | データ設計方針               | operator_* テーブル群 + audit_logs (ハッシュチェーン) + webhook_events + operator_approvals + ac-counts_retired。 | 03_ テーブル設計.md        |
| 8  | エラー設計方針               | E-OP-* プレフィックス。4-eyes 未承認 / IP allowlist 拒否 / 再認証期限切れの専用エラー。                                        | 05_ エラー設計.md         |
| 9  | メッセージ設計方針             | 運営者画面文言 + IF #12 経由通知 + お知らせテンプレート。重要度 critical メール強制送信。                                            | 06_ メッセージ一覧.md       |
| 10 | トレーサビリティ方針            | 要件 → 機能 → 画面 → API → DB → 権限 → エラー → メッセージ → テスト観点。4-eyes 操作 10 件のマッピング表を含む。                        | 07_ トレーサビリティマトリクス.md |

## 1.4 3. システム構成 (全体像)

| レイヤ        | 構成要素                                                  | 補足                       |
|------------|-------------------------------------------------------|--------------------------|
| フロントエンド    | 運営者専用 SPA(管理画面)                                       | admin.<domain> の独立サブドメイン |
| API バックエンド | Cloudflare Workers + REST API                         | /v1/operator/*           |
| データストア     | D1(SQLite 互換) + KV(セッション / IP allowlist) + R2(エクスポート) | RDB は運営者専用               |
| 外部連携       | Stripe(Webhook 一次受信) / メインシステム / SMTP / 監視 SaaS       | 連携 IF #1~#12 主管          |
| 認証基盤       | TOTP(MFA) + 再認証チャレンジ + IP allowlist + 4-eyes          | 6 段認可判定                  |

詳細構成図と Worker トポロジは [../03\\_詳細設計/index.md](#) §2 を参照。

## 1.5 4. 機能一覧 (FRxx\_\*.md と基本設計成果物の対応)

| FRxx ファイル                     | 概要                               | 主関連画面   | 主関連 API                          |
|-------------------------------|----------------------------------|---------|----------------------------------|
| ../01_要件定義/FR01_アカウント管理.md    | アカウント管理 (メイン側を正本として参照)           | -       | -                                |
| ../01_要件定義/FR02_ユーザー管理.md     | ユーザー管理 (メイン側を正本として参照)            | -       | -                                |
| ../01_要件定義/FR03_プロジェクト管理.md   | プロジェクト管理 (メイン側を正本として参照)          | -       | -                                |
| ../01_要件定義/FR04_FAQ 管理.md     | FAQ 管理 (メイン側を正本として参照)            | -       | -                                |
| ../01_要件定義/FR05_AI パラメータ設定.md | AI 推論パラメータの本番上書き (4-eyes ハードゲート) | SCR-092 | PATCH /v1/operator/ai-parameters |
| ../01_要件定義/FR06_未解決質問登録.md    | 未解決質問関連 (メイン側を正本として参照)           | -       | -                                |
| ../01_要件定義/FR07_個別チャット.md     | 個別チャット関連 (メイン側を正本として参照)          | -       | -                                |

| FRxx ファイル                         | 概要                                             | 主関連画面             | 主関連 API                                                       |
|-----------------------------------|------------------------------------------------|-------------------|---------------------------------------------------------------|
| ../01_要件定義/FR08_未解決質問から FAQ 登録.md | 未解決 → FAQ 関連(メイン側を正本として参照)                     | -                 | -                                                             |
| ../01_要件定義/FR09_処理エラー.md          | 処理エラー対応(運営者側エラーチケット連携)                         | -                 | -                                                             |
| ../01_要件定義/FR10_利用量・課金.md         | 利用量・課金(運営者主管: Stripe Webhook 一次受信 / 月次請求確定)    | SCR-097           | POST /v1/operator/webhook/replay                              |
| ../01_要件定義/FR11_管理ダッシュボード.md      | 運営者ホームダッシュボード                                  | SCR-HOME          | GET /v1/operator/home                                         |
| ../01_要件定義/FR12_通知.md             | 通知(IF #12 経由でメインへ転送)                           | -                 | -                                                             |
| ../01_要件定義/FR13_ウィジェット.md         | ウィジェット(メイン側を正本として参照)                           | -                 | -                                                             |
| ../01_要件定義/FR14_プライバシー・データ管理.md   | プライバシー / GDPR 越境移転ガード / accounts_retired 永久保持  | -                 | -                                                             |
| ../01_要件定義/FR15_セキュリティ.md         | セキュリティ(運営者主管: 監査ハッシュチェーン / IP allowlist / MFA) | -                 | -                                                             |
| ../01_要件定義/FR16_お知らせ.md           | お知らせ作成・配信                                      | SCR-094           | POST /v1/operator/announcements                               |
| ../01_要件定義/FR17_削除データ参照・復元.md     | 削除データ参照 / 復元(運営者専用 / 4-eyes 承認ログ)              | SCR-090 / SCR-091 | GET /v1/operator/deleted/:type/:id, POST /v1/operator/restore |
| ../01_要件定義/FR18_運営者の責務.md         | 運営者の責務(SLA / オンコール / 監査 / GDPR)                | -                 | -                                                             |
| ../01_要件定義/FR19_UI・UX 共通.md       | 運営者画面 UI/UX 共通要件                               | 全画面               | -                                                             |
| ../01_要件定義/FR20_ナビゲーション・情報構造.md   | ナビゲーション・情報構造要件                                 | 全画面               | -                                                             |
| ../01_要件定義/FR21_ローディング・フィードバック.md | ローディング・フィードバック要件                               | 全画面               | -                                                             |
| ../01_要件定義/FR22_アクセシビリティ強化.md     | アクセシビリティ強化要件                                   | 全画面               | -                                                             |
| ../01_要件定義/FR23_4-eyes 承認.md      | 4-eyes 承認(対象 10 操作)                            | SCR-APPROVALS     | POST /v1/operator/approvals                                   |
| ../01_要件定義/FR24_監査・SLA.md         | 監査ログ参照 / SLA 監視 / 運営者活動ダッシュボード                 | SCR-096           | GET /v1/operator/audit-logs                                   |

## 1.6 5. SCR × ドキュメント カバレッジ表

| SCR ID      | 画面名          | 画面              | API                                | テーブル                                 | 権限        | エラー         | メッセージ             | 認証認可               | セキュリティ     | 課金 |
|-------------|--------------|-----------------|------------------------------------|--------------------------------------|-----------|-------------|-------------------|--------------------|------------|----|
| SCR-AUTH    | 運営者ログイン      | § 5.SCR AUTH    | POST /v1/operator/session          | operator_sessions, service_operators | § 2 単一ロール | E-OP-AUTH-* | MSG-SCR-AUTH-*    | § 3 ログイン           | § 5 ロックアウト | -  |
| SCR-AUTH-M1 | MFA 初回セットアップ | § 5.SCR AUTH-M1 | POST /v1/operator/mfa/enroll       | operator_mfa_secrets                 |           | E-OP-MFA-*  | MSG-SCR-AUTH-M1-* | § 3 MFA / § 4 TOTP | -          | -  |
| SCR-HOME    | ホームダッシュボード   | § 5.SCR HOME    | GET /v1/operator/home              | (各種)                                 | 全運営者      | -           | MSG-SCR-HOME-*    | § 6 セッション検証        | -          | -  |
| SCR-090     | 削除データ参照      | § 5.SCR 090     | GET /v1/operator/deleted/:type/:id | accounts_retired, audit_logs         | 4-eyes 不要 | E-OP-AUTH-* | MSG-SCR-090-*     | § 6 再認証            | § 7 監査     | -  |



| SCR ID           | 画面名                 | 画面         | API                                        | テーブル                                        | 権限            | エラー             | メッセージ                  | 認証認可                  | セキュリティ         | 課金        |
|------------------|---------------------|------------|--------------------------------------------|---------------------------------------------|---------------|-----------------|------------------------|-----------------------|----------------|-----------|
| SCR-091          | 削除データ復元             | § 5.SCR091 | POST /v1/operator/restore                  | accounts_retired, audit_logs                | 4-eyes承認ログ    | E-OP-RESTORE-*  | MSG-SCR-091-*          | § 6 4-eyes承認          | § 7 監査         | -         |
| SCR-092          | AI 推論パラメータ設定        | § 5.SCR092 | PATCH /v1/operator/ai-parameters           | ai_parameter_override, audit_logs           | 4-eyesハードゲート  | E-OP-4EYES-*    | MSG-SCR-092-*          | § 6 ハードゲート            | § 7 監査         | -         |
| SCR-093          | レート制限・予算上書き         | § 5.SCR093 | PATCH /v1/operator/rate-limits ほか          | rate_limit_override, budget_limit_overrides | 4-eyes承認ログ    | E-OP-OVERRIDE-* | MSG-SCR-093-*          | § 6 4-eyes承認          | § 7 監査         | § 3 契約上書き |
| SCR-094          | お知らせ作成・配信           | § 5.SCR094 | POST /v1/operator/announcements ほか         | announcements, service_announcements        | 全運営者          | E-OP-INPUT-*    | MSG-SCR-094-*          | § 6 認可判定              | -              | -         |
| SCR-096          | 運営者活動ダッシュボード        | § 5.SCR096 | GET /v1/operator/audit-logs                | audit_logs                                  | 全運営者 (参照)     | -               | MSG-SCR-096-*          | § 6 認可判定              | § 7 監査参照       | -         |
| SCR-097          | Webhook リプレイ・DLQ 操作 | § 5.SCR097 | POST /v1/operator/webhook/replay ほか        | webhook_events, replay_log                  | 4-eyes承認ログ    | E-OP-WEBHOOK-*  | MSG-SCR-097-*          | § 6 4-eyes承認          | § 7 監査         | § 13 DLQ  |
| SCR-098          | PII 誤検出報告管理         | § 5.SCR098 | GET /v1/operator/pii-reports ほか            | pii_false_positive_reports                  | 全運営者          | E-OP-PII-*      | MSG-SCR-098-*          | § 6 認可判定              | § 13 PII マスキング | -         |
| SCR-099          | Webhook ペイロード差分検出   | § 5.SCR099 | GET /v1/operator/webhook/diffs             | webhook_payload_diffs                       | 全運営者          | -               | MSG-SCR-099-*          | § 6 認可判定              | § 7 監査         | § 13 差分検出 |
| SCR-APPROVALS    | 承認待ち一覧 (4-eyes)     | § 5.SCR091 | GET /v1/operator/approvals                 | operator_approvals                          | 4-eyes申請者/承認者 | E-OP-4EYES-*    | MSG-SCR-APPROVALS-*    | § 6 4-eyesフロー         | § 7 監査         | -         |
| SCR-APPROVALS-M1 | 4-eyes 承認申請モーダル     | § 5.SCR091 | POST /v1/operator/approvals                | operator_approvals                          | 4-eyes申請者     | E-OP-4EYES-*    | MSG-SCR-APPROVALS-M1-* | § 6 申請 / payload_hash | § 7 監査         | -         |
| SCR-APPROVALS-M2 | 4-eyes 承認待ち下モーダル    | § 5.SCR091 | POST /v1/operator/approvals/:id/approve ほか | operator_approvals                          | 4-eyes承認者     | E-OP-4EYES-*    | MSG-SCR-APPROVALS-M2-* | § 6 承認 / 自己承認禁        | § 7 監査         | -         |

## 1.7 6. 4-eyes 対象 10 操作カバレッジ表

| # | 操作                | 種別     | SCR        | action code                  | retention_cls | API                                     |
|---|-------------------|--------|------------|------------------------------|---------------|-----------------------------------------|
| 1 | 契約物理削除            | ハードゲート | SCR-091 派生 | owner.physical_delete        | 5y            | DELETE /v1/operator/owners/:id/physical |
| 2 | AI パラメータ変更 (本番)   | ハードゲート | SCR-092    | ai_parameter.update          | 5y            | PUT /v1/operator/ai-parameters          |
| 3 | マスター ローテーション      | ハードゲート | (運用 CLI)   | key.master_rotate            | 5y            | (CLI)                                   |
| 4 | 契約無効化 / サスペンション解除 | 承認ログ   | SCR-091 派生 | owner.suspend, owner.restore | 5y(billing)   | POST /v1/operator/owners/:id/suspend ほか |
| 5 | 契約別レート制限上書き       | 承認ログ   | SCR-093    | rate_limit.override          | 5y(general)   | PATCH /v1/operator/rate-limits          |

| #  | 操作              | 種別   | SCR        | action code        | retention_cls     | API                                        |
|----|-----------------|------|------------|--------------------|-------------------|--------------------------------------------|
| 6  | 契約別予算上限上書き      | 承認ログ | SCR-093    | budget.override    | 5y(billing)       | PATCH<br>/v1/operator/budgets              |
| 7  | 強制停止 (契約単位)     | 承認ログ | SCR-093 派生 | owner.force_stop   | 5y(operator_high) | POST<br>/v1/operator/owners/:id/force-stop |
| 8  | 削除データ復元         | 承認ログ | SCR-091    | owner.restore_data | 5y(operator_high) | POST<br>/v1/operator/restore               |
| 9  | 課金 Webhook リプレイ | 承認ログ | SCR-097    | webhook.replay     | 5y(billing)       | POST<br>/v1/operator/webhook/replay        |
| 10 | 法的レビュー結果記録      | 承認ログ | SCR-098 派生 | owner.legal_review | 7y(operator_high) | POST<br>/v1/operator/legal-review          |

## 1.8 7. 連携 IF × ドキュメント カバレッジ

| IF # | 方向           | 概要                       | API              | エラー           | セキュリティ      | 課金              |
|------|--------------|--------------------------|------------------|---------------|-------------|-----------------|
| #1   | 顧管 → メ       | 契約停止イベント送信               | § 5 IF #1(送信主管)  | E-OP-IF-001-* | § 7 監査      | § 5 サスペンション     |
| #2   | 顧管 → メ       | 強制ログアウト送信                | § 5 IF #2        | E-OP-IF-002-* | § 7 監査      | -               |
| #4   | 顧管 → メ       | 復元実行                     | § 5 IF #4        | E-OP-IF-004-* | § 7 監査      | -               |
| #5   | 顧管 → メ       | レート制限上書き                 | § 5 IF #5        | E-OP-IF-005-* | § 7 監査      | § 3 契約上書き       |
| #6   | 顧管 → メ       | AI パラメータ上書き              | § 5 IF #6        | E-OP-IF-006-* | § 7 監査      | -               |
| #7   | 顧管 → メ       | お知らせ生成                   | § 5 IF #7        | E-OP-IF-007-* | § 7 監査      | -               |
| #8   | メ → 顧管       | 監視メトリクス取得                | § 5 IF #8(受信主管)  | -             | § 10 監視     | -               |
| #9   | メ → 顧管       | 不正利用検知通知                 | § 5 IF #9(受信主管)  | -             | § 10 不正利用検知 | -               |
| #10  | 外 → 顧管 → メ   | 課金 Webhook 一次受信 (Stripe) | § 5 IF #10(送信主管) | E-OP-IF-010-* | § 7 監査      | § 13 Webhook 処理 |
| #12  | 顧管 → メ → 利用者 | 運営者操作通知                  | § 5 IF #12       | E-OP-IF-012-* | § 7 監査      | -               |

## 1.9 8. 関連ドキュメント

| ドキュメント     | 役割                                    | リンク                            |
|------------|---------------------------------------|--------------------------------|
| 要件定義       | WHAT(運営者要件)                           | ../01_要件定義/index.md            |
| 詳細設計       | 実装関連の詳細 (モジュール構成 / バッチ / マイグレーション)    | ../03_詳細設計/index.md            |
| 運用設計       | 監視 / バックアップ / ログ / 障害対応 / リリース / 運用手順 | ../04_運用設計/index.md            |
| 将来対応       | 運営者サブロール ほか                           | ../05_future/index.md          |
| ワイヤーフレーム   | 運営者画面表現                               | ../画面遷移図.html                  |
| メイン側ドキュメント | 利用者側設計書                               | ../01_メインシステム/02_基本設計/index.md |
| 共有概念対応表    | メイン / 運営者の正本所在                        | ../共有/共有概念.md                  |

## 1.10 9. 未確定事項・確認事項

| 確認事項 ID       | 確認内容                              | 関連箇所 | 優先度 | ステータス |
|---------------|-----------------------------------|------|-----|-------|
| Q-BASE-OP-001 | (現時点で未確定事項なし→v1.0 リリース時点で全項目確定済み) | -    | 低   | 確認済   |

## 1.11 10. 変更履歴

| 日付         | 版数  | 変更内容          | 変更者         |
|------------|-----|---------------|-------------|
| 2026-05-17 | 1.0 | 初版作成(新構成への再編) | プロジェクト設計チーム |

\newpage

## 2 画面設計書 (運営者)

### 2.1 1. 文書概要

#### 2.1.1 1.1 目的

運営者システム (open-faq 運営事業者向け管理画面) の画面仕様を一元化する。SCR-090～099 / SCR-AUTH / SCR-AUTH-M1 / SCR-HOME / SCR-APPROVALS / M1 / M2(計 15 画面) を対象とする。各画面に **4-eyes 対象 action code + ticket\_id 入力要否** を明示する。

#### 2.1.2 1.2 対象範囲

- 対象 15 画面: SCR-AUTH / SCR-AUTH-M1 / SCR-HOME / SCR-090～099(SCR-095 は MVP 範囲外、欠番) / SCR-APPROVALS / SCR-APPROVALS-M1 / SCR-APPROVALS-M2
- 対象外: 利用者側画面 (01\_メインシステム/個別設計書群/02\_画面設計書.md 参照)

#### 2.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

#### 2.1.4 1.4 関連ドキュメント

| ドキュメント名  | 役割                        | 参照先           |
|----------|---------------------------|---------------|
| 索引       | 11 ドキュメント体系の俯瞰            | 00_索引.md      |
| API 設計書  | 各画面の API 呼び出し             | 03_API 設計書.md |
| メッセージ一覧  | 画面ラベル / エラー文言 (正本)        | 07_メッセージ一覧.md |
| 権限設計書    | 4-eyes 対象 10 操作           | 05_権限設計書.md   |
| 認証・認可設計書 | 6 段階認可判定 / 4-eyes 承認フロー   | 09_認証認可設計書.md |
| エラー設計書   | 異常系挙動                     | 06_エラー設計書.md  |
| テーブル定義書  | operator_approvals 物理スキーマ | 04_テーブル定義書.md |
| ワイヤーフレーム | UI 表現                     | ../画面遷移図.html |

### 2.2 2. 画面一覧

| SCR         | 名称               | 主管 FR                   | 4-eyes 段階 | 再認証        | action code |
|-------------|------------------|-------------------------|-----------|------------|-------------|
| SCR-AUTH    | 運営者ログイン (URL 分離) | FR-220, FR-221, NFR-311 | なし        | -(認証前)     | -           |
| SCR-AUTH-M1 | MFA 初回セットアップ     | FR-220, RB-014, NFR-311 | なし        | -(限定セッション) | -           |

| SCR              | 名称                       | 主管 FR                         | 4-eyes 段階            | 再認証              | action code                           |
|------------------|--------------------------|-------------------------------|----------------------|------------------|---------------------------------------|
| SCR-HOME         | ホームダッシュボード               | (主要 KPI 集約)                   | なし                   | 不要               | -                                     |
| SCR-090          | 削除データ参照                  | FR-200, FR-223                | なし                   | 不要               | (操作なし、参照のみ)                           |
| SCR-091          | 削除データ復元                  | FR-201~FR-209, FR-211, FR-222 | MVP 承認ログのみ           | 必須 (5 分以内)       | owner.restore_data                    |
| SCR-092          | AI 推論パラメータ設定 (契約別上書き)    | FR-055, FR-061~FR-066, FR-222 | MVP ハードゲート           | 必須               | ai_parameter.update                   |
| SCR-093          | 契約別レート制限・予算上書き管理         | FR-121, FR-128, FR-224(b)     | MVP 承認ログのみ           | 必須               | rate_limit.override / budget.override |
| SCR-094          | お知らせ作成・配信 (運営者)          | FR-149, FR-188, FR-189        | なし (配信予約は 5 分前まで取消可) | 必須               | (即時配信のみ承認ログ)                          |
| SCR-096          | 運営者活動ダッシュボード (監査)        | FR-229, FR-230, FR-232        | なし                   | 不要 / エクスポートは記録対象 | -                                     |
| SCR-097          | 課金 Webhook リプレイ・DLQ 操作画面 | FR-302, NFR-808               | なし                   | 必須 (リプレイ実行時)     | webhook.replay                        |
| SCR-098          | PII 誤検出報告管理              | FR-060, FR-064, NFR-805       | なし                   | 必須 (ルール更新時)      | pii_rule.update                       |
| SCR-099          | Webhook ペイロード差分検出一覧      | FR-302 異常系, AC-041            | なし                   | 必須 (手動再処理選択時)    | -                                     |
| SCR-APPROVALS    | 承認待ち一覧 (4-eyes)          | FR-226, § 6.2.3               | 4-eyes 中核画面          | 承認 / 却下時に必須      | -                                     |
| SCR-APPROVALS-M1 | 4-eyes 承認申請モーダル          | FR-226, § 6.2.3, FR-231       | 申請発火点                | 必須               | (親画面から継承)                             |
| SCR-APPROVALS-M2 | 4-eyes 承認 / 却下モーダル       | FR-226, § 6.2.3               | 承認 / 却下発火点           | 必須               | approval.approved / approval.rejected |

## 2.3 3. 画面遷移

### 2.3.1 3.1 Mermaid 遷移図

flowchart TD

```

Login[SCR-AUTH<br/> 運営者ログイン <br/>+ MFA + IP 許可] --> Home[SCR-HOME<br/> ホームダッシュボード]
Login --> AuthM1[SCR-AUTH-M1<br/>MFA 初回セットアップ]
AuthM1 --> Home
Home --> SCR090[SCR-090<br/> 削除データ参照]
Home --> SCR097[SCR-097<br/>Webhook リプレイ]
Home --> SCR098[SCR-098<br/>PII 誤検出報告]
Home --> SCR099[SCR-099<br/> ペイロード差分]
Home --> SCR096[SCR-096<br/> 運営者活動]
Home --> SCR092[SCR-092<br/>AI パラメータ]
Home --> SCR093[SCR-093<br/> レート/予算]
Home --> SCR094[SCR-094<br/> お知らせ配信]
Home --> Approvals[SCR-APPROVALS<br/> 承認待ち一覧]
SCR090 -->| 復元実行 | SCR091[SCR-091<br/> 削除データ復元]
SCR099 -->| 手動再処理 | SCR097
SCR092 -->| 4-eyes 申請 | Approvals
SCR091 -->| 4-eyes 申請 | Approvals
Approvals --> ApprovalsM2[SCR-APPROVALS-M2<br/> 承認/却下モーダル]
SCR091 --> ApprovalsM1[SCR-APPROVALS-M1<br/> 承認申請モーダル]
SCR092 --> ApprovalsM1

```

## 2.4 4. 共通 UI 部品 + サイドメニュー

### 2.4.1 4.1 既存共通部品

| 部品            | 配置                                                      | 目的                                                                                                                    |
|---------------|---------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| グローバルヘッダ      | 全画面上部                                                   | サービス名、運営者表示名、MFA バッジ(緑/赤)、運営者 inbox バッジ(未読件数)、ログアウト                                                                   |
| サイドメニュー       | 全画面左                                                    | SCR-090~094, SCR-096~099 への遷移、未承認件数バッジ・DLQ 滞留バッジ・PII 未判定バッジ (FR-471)                                                  |
| チケット ID 入力モダル | SCR-091~094 / 097 / 098 / 099 の操作前                      | 対応チケット ID(任意文字列、最大 64 文字、必須)+ 操作種別の確認。placeholder で受付例 (JIRA-12345 / INC-001 / #1234) を提示、未入力時は Primary 非活性化 (FR-458) |
| 再認証モダル        | SCR-091~094 / 097 / 098 / 099 の操作前(過去 5 分以内に再認証していない場合) | パスワード再入力 (MVP)+ 操作 1 回限り。残時間 5 分カウントダウンを常時表示 (FR-457)                                                                 |
| 4-eyes 申請モダル  | SCR-092 / マスター ロータ / 契約物理削除                             | 申請理由・対象操作・payload 要約(変更前→変更後の対比)を主表示、生 JSON は折り畳み (FR-455)                                                            |
| 4-eyes 承認モダル  | 別運営者のホーム画面の「承認待ち」リスト経由                                  | 申請内容確認・承認/却下・コメント。payload_hash 不一致時は業務語で警告。自己承認は CTA 非活性化                                                             |
| 運営者 inbox バッジ | ヘッダ右上                                                   | 未読件数表示。critical 申請通知は赤強調                                                                                              |
| DLQ 滞留バッジ     | サイドメニュー SCR-097 横                                       | DLQ 滞留件数 (1 時間以上 / 24 時間以上)。24 時間以上は 赤強調 (FR-471)                                                                     |

## 2.4.2 4.2 UI/UX 共通要件で追加する部品

| 部品                 | 用途                    | 主な仕様                                                                               |
|--------------------|-----------------------|------------------------------------------------------------------------------------|
| Breadcrumb         | パンくず                  | 認証フローおよび全画面割込みモダルを除く全画面に表示。最大 3 階層                                                 |
| PageHeader         | 画面タイトル + 1 行説明文       | 全画面の最上部                                                                            |
| ReauthBadge        | 再認証必須操作の可視化           | Primary ボタン横に <input checked="" type="checkbox"/> アイコン + tooltip。FR-222 対象操作すべてに付与 |
| ReauthCountdown    | 再認証残時間表示              | 再認証モダル内およびモダル閉じた後のヘッダ右側に「再認証残 X:XX」を常時表示                                           |
| HardgateBadge      | 4-eyes ハードゲート可視化      | 紫枠 + <input checked="" type="checkbox"/> アイコン + tooltip 「別運営者の承認が必要な操作です」          |
| ApprovalStateBadge | 4-eyes 申請状態           | requested(青)/ approved(緑)/ rejected(赤)/ withdrawn(灰) を色 + アイコン + テキスト              |
| PayloadDiffViewer  | 4-eyes 申請内容の対比        | 主表示は「変更前 → 変更後」のキー別対比、生 JSON は折り畳み (FR-455)                                        |
| SelfApprovalGuard  | 自己承認禁止の UI ガード        | 自分の申請を開いたとき承認/却下 CTA を非活性化 + 補助文言「自分の申請は承認できません」                                   |
| TicketIdField      | 対応チケット ID 入力欄         | placeholder 「例: JIRA-12345 / INC-001 / #1234」、未入力時 Primary 非活性化                    |
| PrecheckResultList | 副作用プリチェック結果 (SCR-091) | 7 項目 (a-g) を OK/NG/不要バッジで一覧表示                                                      |
| AppliedFilterChip  | 適用済フィルタ表示 + クリア       | 「すべてクリア」を常設                                                                        |
| BulkActionBar      | 一括操作バー                | 複数選択時のみ画面下部固定                                                                      |
| SummaryCard        | KPI サマリーカード           | SCR-HOME / SCR-096 等で使用                                                            |
| LoadingSkeleton    | スケルトン UI              | スピナー単独表示を回避 (FR-480)                                                               |
| ProgressText       | 進捗テキスト (3 秒超操作)       | プリチェック実行、CSV エクスポート、Webhook リプレイ等                                                  |
| Toast              | 成功・警告・エラー通知           | 成功 4 秒 / 警告 6 秒 / エラーは手動閉じ                                                         |

## 2.4.3 4.3 文言の共通基準

詳細は [07\\_メッセージ一覧.md §2](#) を正本とする。

## 2.4.4 4.4 サイドメニュー

| メニュー項目                 | 表示順 | バッジ条件                     |
|------------------------|-----|---------------------------|
| ホーム                    | 1   | -                         |
| 削除データ参照 (SCR-090)      | 2   | -                         |
| 削除データ復元 (SCR-091)      | 3   | -                         |
| AI 推論パラメータ (SCR-092)   | 4   | ハードゲート申請中件数               |
| レート/予算上書き (SCR-093)    | 5   | -                         |
| お知らせ配信 (SCR-094)       | 6   | scheduled 件数              |
| Webhook リプレイ (SCR-097) | 7   | DLQ 滞留 1h 以上 / 24h 以上 (赤) |
| PII 誤検出報告 (SCR-098)    | 8   | 3 営業日経過件数                 |
| ペイロード差分 (SCR-099)      | 9   | detected 状態件数 (赤)         |
| 運営者活動 (SCR-096)        | 10  | -                         |
| 承認待ち一覧 (SCR-APPROVALS) | 11  | 承認待ち件数 (申請者・承認者問わず)       |
| 運営者 inbox              | 12  | 未読件数                      |
| ログアウト                  | 13  | -                         |

## 2.5 5. 画面詳細

文言は [07\\_メッセージ一覧.md §4](#) を正本とする。本書では UI 構造を網羅する。

### 2.5.1 5.1 SCR-AUTH 運営者ログイン

**2.5.1.1 画面概要** URL 分離した運営者専用ログイン画面 (<https://admin.open-faq.example.com/login>)。利用者側からのリンクは設けない(発見可能性を下げる)。

| 項目         | 内容                                             |
|------------|------------------------------------------------|
| ページタイトル    | open-faq Admin Console                         |
| 利用者        | service_operator                               |
| 認証         | メール+パスワード (Argon2id 運営者プロファイル)+ MFA(TOTP)      |
| IP 許可      | リクエスト到着前にエッジで適用、未許可 IP は 403(ログイン画面さえ表示しない)    |
| ロックアウト     | 5 回連続失敗で (IP × user_id) ペア単位 15 分ロック           |
| パスワードリセット  | 60 分有効リンク、自己リセット禁止 → 別運営者承認経由                  |
| MFA セットアップ | 初回 72h トークン経由で SCR-AUTH-M1 へ誘導。QR + 回復コード 10 個 |
| セッション TTL  | MVP 初期値 8 時間                                   |

#### 2.5.1.2 表示・入力・操作項目

| 区分 | 項目             | 入出力                     | バリデーション                                                  | エラー表示                                                     |
|----|----------------|-------------------------|----------------------------------------------------------|-----------------------------------------------------------|
| 入力 | メールアドレス        | 入力                      | 必須、254 文字以内、形式チェック                                       | 「メールアドレスを入力してください」 / 「メールアドレスの形式が正しくありません」                |
| 入力 | パスワード          | 入力                      | 必須、Argon2id 検証                                           | 「パスワードを入力してください」 / 認証失敗時の共通文言「メールアドレスまたはパスワードが正しくありません」   |
| 入力 | TOTP コード       | 入力 (6 桁分割入力 UI、各桁オートタブ) | 必須 (MFA 設定済み)、6 桁数字                                      | 「認証コードが一致しません。アプリで最新コードを確認してください」                         |
| 操作 | ログインする         | 操作 (Primary)            | (1) IP 許可リスト照合 (2) Argon2id 検証 (3) TOTP 検証 (4) 認可セッション発行 | IP 拒否 / 認証失敗 / ロックアウト                                     |
| 表示 | IP 拒否時の明示メッセージ | アラート帯 (画面上部固定)          | -                                                        | 「許可された IP アドレスからアクセスしてください (現在の IP: {ip})。管理者にお問い合わせください」 |

| 区分 | 項目                                                     | 入出力             | バリデーション                              | エラー表示                      |
|----|--------------------------------------------------------|-----------------|--------------------------------------|----------------------------|
| 表示 | ロックアウト残時間表示                                            | カウントダウン         | -                                    | 「[N] 分 [S] 秒後にもう一度お試しください」 |
| 操作 | パスワードを忘れた場合                                            | リンク (Secondary) | 60 分有効リンク、自己リセット禁止                   | -                          |
| 表示 | MFA 未設定者向け案内                                           | 出力              | 招待 72h トークンを受領した運営者は SCR-AUTH-M1 へ誘導 | -                          |
| 完了 | 監査ログ記録 (auth.login.success / auth.login.failure、5 年保持) | -               | -                                    | -                          |

## 2.5.2 5.2 SCR-AUTH-M1 MFA 初回セットアップ

**2.5.2.1 画面概要** 招待時に発行される 72h セットアップトークンを保持する運営者が、TOTP 秘密 と回復コードを初期登録する独立画面。**3 ステップウィザード:** (1) 認証アプリ登録、(2) 初回 TOTP 検証、(3) 回復コード保管。

### 2.5.2.2 表示・入力・操作項目

| 区分 | 項目                            | 入出力          | バリデーション                                                                   | エラー表示                                                                                               |
|----|-------------------------------|--------------|---------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| 表示 | ステッパー UI(3 段階)                | 出力           | 現在ステップを aria-current="step" で強調                                           | -                                                                                                   |
| 表示 | セットアップトークン                    | 出力           | サーバ側でトークン有効性を検証、72h 期限切れは UC-007 へ誘導                                      | 「セットアップリンクが期限切れです (72 時間)。管理者へ再発行を依頼してください」                                                         |
| 表示 | TOTP QR コード                   | 出力           | 一意に発行された TOTP 秘密 を QR で表示。QR/手動キーをトグル切替                                   | -                                                                                                   |
| 表示 | 手動キー (QR 切替)                  | 出力           | QR 読取不可時の代替                                                               | -                                                                                                   |
| 入力 | 初回 TOTP コード                   | 入力 (6 桁分割入力) | 必須、6 桁数字、サーバ側で初回検証                                                        | 「認証コードが一致しません」                                                                                      |
| 表示 | 回復コード保管警告帯                    | アラート (上部固定)  | -                                                                         | 「 <input checked="" type="checkbox"/> 回復コードは認証アプリを失った場合の唯一の復旧手段です。安全な場所に保管してください。この画面を閉じると再表示できません」 |
| 表示 | 回復コード (10 個)                  | 出力           | セットアップ確定時にのみ表示                                                            | -                                                                                                   |
| 操作 | 回復コードを印刷する                    | ボタン          | window.print() で印刷ダイアログ起動                                                 | -                                                                                                   |
| 操作 | 回復コードをコピーする                   | ボタン          | クリップボードにコピー                                                               | -                                                                                                   |
| 操作 | 回復コードを PDF でダウンロード            | ボタン          | PDF 生成 + ダウンロード                                                           | -                                                                                                   |
| 入力 | 「回復コードを安全な場所に保管しました」確認チェック    | 入力           | 必須 (セットアップ完了の前提)                                                          | 未チェック時は Primary 非活性化                                                                                |
| 操作 | セットアップを完了する                   | 操作 (Primary) | (1) 初回 TOTP 検証 (2) accounts.mfa_secret 暗号化保存 (3) 回復コード暗号化保存 (4) 認可セッション昇格 | 検証失敗                                                                                                |
| 完了 | 監査ログ記録 (auth.mfa.setup、5 年保持) | -            | -                                                                         | -                                                                                                   |

2.5.3 5.3 SCR-HOME ホームダッシュボード

2.5.3.1 画面概要 ログイン直後の遷移先。運営者の「いま何をすべきか」を 1 画面に集約。上部に 緊急アラート帯 (24h+ 滞留や承認期限切れ間近)、その下にカードグリッドで主要 KPI と各 SCR への入口を配置。

2.5.3.2 (1) 緊急アラート帯 (上部固定)

| 区分 | 項目                     | 種類                  | 概要                                                                                              |
|----|------------------------|---------------------|-------------------------------------------------------------------------------------------------|
| 表示 | 承認期限切れ間近 (残 24h 以内)    | アラート (赤、件数 > 0 時のみ) | 「 <input checked="" type="checkbox"/> 承認期限切れ間近の申請が {N} 件あります (残 24 時間以内)」 + 「承認待ち一覧へ」リンク        |
| 表示 | DLQ 24h+ 滞留            | アラート (赤)            | 「 <input checked="" type="checkbox"/> 24 時間以上滞留中の Webhook イベントが {N} 件あります」 + 「Webhook リブレイへ」リンク |
| 表示 | PII 誤検出 SLA 超過         | アラート (赤)            | 「 <input checked="" type="checkbox"/> 3 営業日を超過した PII 誤検出報告が {N} 件あります」 + 「PII 誤検出管理へ」リンク        |
| 表示 | ハッシュチェーン検証 NG (直近 24h) | アラート (赤、NG 時のみ)     | 「 <input checked="" type="checkbox"/> 監査ログのハッシュチェーン検証で不整合が検出されました。詳細を確認してください」                  |

2.5.3.3 (2) KPI サマリーカード

| 項目             | 概要                           |
|----------------|------------------------------|
| アクティブ契約数       | 現在値 + 前週比                    |
| 全契約 MAU        | 月次アクティブユーザー数                 |
| 全契約 質問数 (当月)   | 当月累計 + 前月比                   |
| 全契約 解決率 (当月)   | 解決数 / 質問数% + 前月比 (FR-230 連動) |
| AI 推論コスト (当月)  | 円換算合計 + 前月比                  |
| 通知失敗率 (直近 7 日) | バウンス + 苦情率。閾値超過時は警告色         |

2.5.3.4 (3) クイックアクセス (各 SCR への入口)

| 項目                | 表示                                                                         |
|-------------------|----------------------------------------------------------------------------|
| 承認待ち一覧            | カード + 件数バッジ「承認待ち {N} 件」                                                    |
| DLQ 滞留            | カード + 件数バッジ「DLQ 滞留 {N} 件 (うち 24h+ {M} 件)」                                  |
| PII 誤検出未判定        | カード + 件数バッジ「PII 誤検出未判定 {N} 件 (うち SLA 超過 {M} 件)」                            |
| ペイロード差分検出         | カード + 件数バッジ「差分検出 {N} 件 (未レビュー)」                                            |
| 削除データ参照           | カード (クリックで SCR-090 へ)                                                      |
| AI 推論パラメータ        | カード (クリックで SCR-092 へ、HardgateBadge <input checked="" type="checkbox"/> 付き) |
| 運営者活動ログ           | カード (クリックで SCR-096 へ)                                                      |
| 空状態 (緊急アラート 0 件時) | 「 <input checked="" type="checkbox"/> 緊急対応が必要な事案はありません」 + KPI カードのみ表示      |

2.5.4 5.4 SCR-090 削除データ参照

2.5.4.1 画面概要 論理削除済みリソースを検索・参照。本文は表示されず、復元判断に必要なメタデータのみ表示。左 60% に一覧、右 40% に詳細プレビューペイン。

2.5.4.2 表示・操作項目

| 区分   | 項目           | 入出力              | バリデーション                               |
|------|--------------|------------------|---------------------------------------|
| 表示   | パンくず         | Breadcrumb       | 「ホーム / 削除データ参照」                       |
| 表示   | クイックフィルタチップ  | QuickFilterChips | 「最近 1 週間」「最近 1 ヶ月」「物理削除予定 7 日以内」「すべて」 |
| 検索条件 | 契約検索 (ID/名前) | 入力 (部分一致)        | 最大 100 文字                             |



| 区分   | 項目                                 | 入出力                         | バリデーション                                        |
|------|------------------------------------|-----------------------------|------------------------------------------------|
| 検索条件 | リソース種別                             | 選択(複数可、チップ形式)               | owner / project / faq / account / announcement |
| 検索条件 | 削除種別                               | 選択(複数可、チップ形式)               | deleted / disabled / deleted_pending           |
| 検索条件 | 削除日範囲                              | 入力(日付範囲)                    | from <input type="checkbox"/> to、最大期間 1 年      |
| 表示   | 適用済フィルタチップ                         | AppliedFilterChips          | + 「すべてクリア」                                     |
| 表示   | 件数表示                               | テキスト                        | 「1-50 / 全 N 件」                                 |
| 一覧   | リソース ID / 契約 ID / 種別 / 削除日時 / 削除種別 | 出力 + バッジ                    | -                                              |
| 一覧   | 物理削除予定日 列                          | 出力<br>(deleted_pending 行のみ) | 残 7 日以内は赤、残 8-30 日は黄                           |
| 詳細   | リソース種別ヘッダ                          | 出力                          | アイコン + リソース名                                   |
| 詳細   | 直前主要属性プレビュー                        | 出力                          | 本文は非表示。表示: リソース ID、種別、契約名、削除日時、削除種別、削除操作者      |
| 詳細   | 物理削除予定日                            | 出力 + カウントダウン                | deleted_pending の場合のみ                          |
| 詳細   | 復元する                               | ボタン (Primary、SCR-091 遷移)    | 物理削除済は非活性 + tooltip 表示                         |
| 表示   | 空状態                                | EmptyState                  | 「該当する削除済みリソースはありません」                           |

## 2.5.5 5.5 SCR-091 削除データ復元

**2.5.5.1 画面概要** 論理削除済みのリソースを副作用プリチェック後に復元。上から (1) 復元対象情報、(2) 入力フィールド、(3) 副作用プリチェック結果セクション、(4) 実行 CTA(タブで「4-eyes 申請」と「即時実行(承認ログ)」を切り替え)。

### 2.5.5.2 表示・入力・操作項目

| 区分 | 項目                   | 入出力                         | バリデーション                                 |
|----|----------------------|-----------------------------|-----------------------------------------|
| 表示 | パンくず                 | Breadcrumb                  | 「ホーム / 削除データ参照 / 復元」                    |
| 表示 | 復元対象サマリ              | 出力                          | リソース ID / 種別 / 契約名 / 削除日時 / 直前主要属性プレビュー |
| 入力 | 復元対象 ID              | 入力 (SCR-090 から遷移)           | 必須                                      |
| 入力 | 復元理由                 | 入力(テキストエリア、最大 1000 文字、カウンタ) | 必須、最大 1000 文字                           |
| 入力 | 対応チケット ID            | TicketIdField               | 必須、最大 64 文字                             |
| 入力 | 再認証(過去 5 分以内に未実行の場合) | 入力(パスワード)                   | 必須                                      |

### 2.5.5.3 プリチェック (7 項目 a~g)

| 表示     | 項目                         | 内容                          |
|--------|----------------------------|-----------------------------|
| プリチェック | (a) Stripe サブスクリプション再開可否   | OK / NG / 不要、NG 時は赤バッジ + 理由 |
| プリチェック | (b) Webhook DLQ 滞留イベント数    | 件数表示 + 詳細リンク → SCR-097      |
| プリチェック | (c) お知らせ受信箱配信保留分           | 件数表示                        |
| プリチェック | (d) ウィジェット再有効化可否           | OK / NG / 不要                |
| プリチェック | (e) Stripe customer_id 整合性 | OK / NG                     |
| プリチェック | (f) 進行中登録完了・再入室トークン処置      | 件数表示                        |

| 表示     | 項目                   | 内容      |
|--------|----------------------|---------|
| プリチェック | (g) 監査・エラーログ参照ポイント整合 | OK / NG |

| 操作 | プリチェックを実行 | 操作 (Primary) | プリチェック未実行時、または入力変更後に活性化 |

**2.5.5.4 実行モード** | 表示 | 実行モードタブ | 出力 (タブ) | 「4-eyes 申請」「即時実行 (承認ログ)」の 2 タブ。MVP ハードゲート対象は「4-eyes 申請」のみ | | 操作 | **4-eyes 申請する** | 操作 (Primary + HardgateBadge) | プリチェック全 OK 必須、SCR-APPROVALS-M1 へ遷移 | | 操作 | **復元を実行する** | 操作 (Primary、Danger 寄り + 再認証) | プリチェック全 OK 必須、チケット ID 入力 + 再認証で実行 | | 表示 | 結果トースト | 出力 | 「復元しました。副作用 (a)~(g) の連動回復は監査ログを参照してください」 | | 完了 | 監査ログ記録 | 出力 | **owner.restore / faq.restore** 等、操作者・対象・理由・チケット ID・変更前後ステータス | | 完了 | 管理者ユーザー通知発火 (FR-211) | 出力 | 10 分集約窓 |

## 2.5.6 5.6 SCR-092 AI 推論パラメータ設定 (契約別上書き、ハードゲート)

**2.5.6.1 画面概要** 階層タブ「グローバル / 契約別 / プロジェクト別」、編集セクション、ロールアウト進行可視化セクション、変更履歴セクション。

### 2.5.6.2 表示・入力・操作項目

| 区分    | 項目                    | 入出力                           | バリデーション                                         |
|-------|-----------------------|-------------------------------|-------------------------------------------------|
| 階層タブ  | グローバル / 契約別 / プロジェクト別 | 選択                            | -                                               |
| 表示    | 優先順位の可視化バナー           | 出力 (情報パネル)                    | 「有効値 = min(プロジェクト, オーナー, グローバル)」                |
| 入力    | 信頼度しきい値               | スライダ + 数値入力                   | 0.00~1.00、0.01 刻み                               |
| 入力    | 関連度しきい値               | スライダ + 数値入力                   | 0.00~1.00、0.01 刻み                               |
| 入力    | 使用モデル                 | 選択 (プルダウン、検索付き)               | KV ai-models:available から                       |
| 入力    | 申請理由                  | 入力 (テキストエリア、最大 1000 文字)       | 必須                                              |
| 入力    | 対応チケット ID             | TicketIdField                 | 必須、最大 64 文字                                     |
| 入力    | 再認証 (5 分以内)           | 入力 (パスワード)                    | 必須                                              |
| 操作    | 4-eyes 申請する           | 操作 (Primary + Hardgate-Badge) | 別運営者承認必須 (MVP ハードゲート)                           |
| 表示    | ロールアウト進行ステッパ          | Timeline(段階表示)                | 「0% → 10% → 50% → 100%」で現在の段階を強調                |
| 操作    | 次のステージへ進める            | 操作 (Primary)                  | 各段階で監査ログ記録、4-eyes 再申請                           |
| プレビュー | 設定値の保存即時有効通知          | 出力 (トースト)                     | 「AI パラメータを更新しました。次回ハイドレーション (60 秒以内) から有効になります」 |
| 履歴タブ  | 過去の変更履歴               | 出力 (テーブル)                     | 直近 90 日。申請者・承認者・before/after・チケット ID・日時         |

## 2.5.7 5.7 SCR-093 契約別レート制限・予算上書き管理

**2.5.7.1 画面概要** 上に契約検索バー、その下に上書き中の契約カード一覧 (各カードでグローバル値との差が視覚化)。新規上書きは「+ 上書きを追加」ボタンから保存モダル経由で実行。

### 2.5.7.2 表示・操作項目

| 区分 | 項目   | 入出力        | バリデーション             |
|----|------|------------|---------------------|
| 表示 | パンくず | Breadcrumb | 「ホーム / レート制限・予算上書き」 |
| 検索 | 契約検索 | 入力         | 部分一致、最大 100 文字      |

| 区分 | 項目               | 入出力                        | バリデーション           |
|----|------------------|----------------------------|-------------------|
| 操作 | + 上書きを追加         | ボタン (Primary)              | クリックで保存モーダルを開く    |
| 一覧 | 契約名 + 契約 ID      | 出力 (カードヘッダ)                | -                 |
| 一覧 | レート制限 (差分表示)     | 出力                         | グローバル値 → 上書き値の対比  |
| 一覧 | チャット投稿レート (差分表示) | 出力                         | 同上                |
| 一覧 | 月次予算上書き (差分表示)   | 出力                         | 同上                |
| 一覧 | 上書き有効期限          | 出力 + カウントダウン               | 期限近接は黄、超過は赤       |
| 一覧 | 上書き理由            | 出力 + tooltip               | 全文は tooltip       |
| 一覧 | 上書き設定者・日時        | 出力                         | -                 |
| 操作 | 編集する             | ボタン (行アクション)               | 保存モーダルを「編集」モードで開く |
| 操作 | グローバル値に戻す        | ボタン (Danger、確認ダイアログ + 再認証) | 上書きを削除してグローバル値に復帰 |

### 2.5.7.3 保存モーダル

| 区分 | 項目                      | 入出力                  | バリデーション                     |
|----|-------------------------|----------------------|-----------------------------|
| 表示 | モーダル見出し                 | 出力                   | 「契約別上書きを {新規追加 / 編集}」 + 契約名 |
| 入力 | 契約選択 (新規時のみ)            | プルダウン (検索付き)         | 必須、契約 ID または名前で検索           |
| 入力 | レート制限上書き (/wid-get/ask) | 入力 + helper          | 1~10000 req/min             |
| 入力 | チャット投稿レート (EU 側)        | 入力 + helper          | 秒数 + 件数/分                   |
| 入力 | チャット投稿レート (admin 側)     | 入力 + helper          | 秒数 + 件数/分                   |
| 入力 | 月次予算上書き (円)             | 入力 + helper          | 1円刻み、KV 範囲内                 |
| 入力 | 上書き理由                   | テキストエリア (最大 1000 文字) | 必須                          |
| 入力 | 対応チケット ID               | TicketIdField        | 必須、最大 64 文字                 |
| 入力 | 再認証 (5 分以内)             | パスワード                | 必須                          |
| 表示 | 差分プレビュー                 | パネル                  | 変更前 → 変更後の対比                |
| 操作 | 保存する                    | ボタン (Primary + 再認証)  | MVP 単独実行 + 承認ログ             |
| 操作 | キャンセル                   | ボタン (Secondary)      | -                           |
| 完了 | 連携 IF #5 でメインへ即時反映      | 出力                   | KV TTL 30s でメイン側エッジに反映      |
| 完了 | 管理者ユーザー通知発火 (FR-211)    | 出力                   | 10 分集約窓                     |

## 2.5.8 5.8 SCR-094 お知らせ作成・配信

### 2.5.8.1 画面概要 4 段階ステッパー UI で配信フローを可視化:

1. 作成・下書き
2. テスト送信
3. 配信予約
4. 即時配信 (オプション、4-eyes 承認ログ対象)

### 2.5.8.2 表示・入力・操作項目

| 区分 | 項目          | 入出力      | バリデーション                            |
|----|-------------|----------|------------------------------------|
| 表示 | ステッパー UI    | 出力       | 現在ステップを強調                          |
| 入力 | 種別          | 選択       | announcement / system              |
| 入力 | 重要度         | 選択 (色付き) | low / normal / high / critical     |
| 入力 | 宛先範囲        | 選択       | 全契約 / 特定契約 (複数) / 特定ユーザー種別 (admin) |
| 表示 | 想定配信件数の即時表示 | 出力       | 「{recipientCount} 件に配信されます」        |

| 区分    | 項目                 | 入出力                                              | バリデーション                                               |
|-------|--------------------|--------------------------------------------------|-------------------------------------------------------|
| 入力    | 件名                 | 入力                                               | 必須、最大 200 文字、サニタイズ                                    |
| 入力    | 本文                 | 入力(リッチエディタ)                                      | 必須、最大 10000 文字、サニタイズ二段階                               |
| 入力    | オプトアウト可否           | 選択                                               | 規約改定・セキュリティ通知は強制送信                                    |
| 入力    | 送信予定日時             | 入力(日時)                                           | 現在時刻 <input checked="" type="checkbox"/> 入力値、最大 30 日先 |
| 入力    | 対応チケット ID          | TicketIdField                                    | 必須、最大 64 文字                                           |
| 入力    | 再認証                | 入力(パスワード)                                        | 必須                                                    |
| プレビュー | 件名・本文(サニタイズ後)      | 出力                                               | -                                                     |
| プレビュー | 宛先範囲・想定配信件数        | 出力                                               | -                                                     |
| 操作    | ステップ 1: 下書き保存      | 操作(Primary)                                      | 必須項目検証                                                |
| 操作    | ステップ 2: テスト送信      | 操作(Primary、本人宛)                                  | ステップ 1 完了後活性化                                         |
| 操作    | ステップ 3: 配信予約       | 操作(Primary <input checked="" type="checkbox"/> ) | ステップ 2 完了 + 日時必須                                      |
| 操作    | 配信予約取消             | 操作                                               | 配信開始 5 分前まで取消可                                        |
| 操作    | ステップ 4: 即時配信(緊急)   | 操作(Danger + Hardgate-Badge + 二段確認)               | 確認モジュール + 再認証 + 4-eyes 承認ログ                           |
| 操作    | 訂正告知発行(配信開始後)      | 操作                                               | 別 SERVICE_ANNOUNCEMENT として新規発行                        |
| 完了    | 連携 IF #7 でメインへ配信指示 | 出力                                               | メイン側で inbox_messages 生成 + メール送信                       |

## 2.5.9 5.9 SCR-096 運営者活動ダッシュボード (監査)

**2.5.9.1 画面概要** 運営者操作の監査ログを検索・閲覧・エクスポート(5 年保持)。上にハッシュチェーン検証バッジ + 異常検知バッジ、その下にフィルタ、一覧、詳細ペイン。

### 2.5.9.2 表示・操作項目

| 区分     | 項目                                                 | 入出力               | バリデーション                                           |
|--------|----------------------------------------------------|-------------------|---------------------------------------------------|
| 表示     | パンくず                                               | Breadcrumb        | 「ホーム / 運営者活動」                                     |
| 表示     | ハッシュチェーン検証バッジ                                      | バッジ + 詳細          | 直近 24h の検証結果(緑 OK / 赤 NG)                         |
| 表示     | 運営者操作頻度異常検知バッジ                                     | バッジ               | 短時間大量操作の検知件数。閾値超過時は赤                              |
| 検索     | クイックフィルタチップ                                        | QuickFilterChips  | 「直近 24h」「直近 7 日」「重要操作のみ」「異常検知あり」「すべて」             |
| 検索     | action                                             | 入力(部分一致)          | <resource>.<verb> 形式                              |
| 検索     | actor_id                                           | 入力(完全一致)          | -                                                 |
| 検索     | actor_type                                         | 選択                | service_operator / admin / end_user / system      |
| 検索     | target_id / target_type                            | 入力(完全一致)          | -                                                 |
| 検索     | occurred_at                                        | 入力(期間範囲)          | 最大検索期間 1 年                                        |
| 検索     | owner_account_id                                   | 入力                | 運営者は全契約横断可                                        |
| 検索     | ip_masked                                          | 入力(部分一致)          | IPv4/IPv6 マスク済                                    |
| 検索     | retention_class                                    | 選択                | 1y / 5y / 7y / 全部                                 |
| 検索     | ticket_id                                          | TicketIdField(任意) | -                                                 |
| 一覧     | 操作日時 / actor / action / target / IP / チケット / class | 出力                | カーソル方式 100 件/ページ                                  |
| 一覧     | 高権限操作 強調表示                                         | 行強調(背景)           | service_operator の restore / update / delete は紫背景 |
| 詳細     | before / after JSON 差分                             | PayloadDiffViewer | 要約モード優先、生 JSON は折り畳み                              |
| エクスポート | 形式                                                 | 選択                | CSV / JSON Lines                                  |
| エクスポート | 1 ファイル最大 10 万行                                     | 出力                | 超過は自動分割                                           |

| 区分     | 項目               | 入出力                                                      | バリデーション                     |
|--------|------------------|----------------------------------------------------------|-----------------------------|
| エクスポート | HMAC-SHA256 署名付き | 出力                                                       | ファイル末尾に signature 行         |
| 操作     | CSV をエクスポート      | ボタン (Primary + 再認証 <input checked="" type="checkbox"/> ) | 監査記録、5000 件以上で非同期化          |
| 表示     | エクスポート進行状況       | ProgressText                                             | 「エクスポート中…(N 件 / M 件)」       |
| 異常系    | KPI 表示           | 出力                                                       | 運営者操作頻度異常 / 全契約横断 MAU ・ 解決率 |

## 2.5.10 5.10 SCR-097 課金 Webhook リプレイ・DLQ 操作

**2.5.10.1 画面概要** 上から (1) 滞留サマリ アラート帯、(2) フィルタバー、(3) イベント一覧、(4) 詳細ペイン。

### 2.5.10.2 表示・操作項目

| 区分 | 項目                                              | 入出力                                                                   | バリデーション                                    |
|----|-------------------------------------------------|-----------------------------------------------------------------------|--------------------------------------------|
| 表示 | 滞留サマリ アラート帯                                     | アラート (固定)                                                             | 「24h+ 滞留: {N} 件 / 30 日近接 (残 3 日以内): {M} 件」 |
| 一覧 | 直近 30 日 Webhook イベント                            | 出力                                                                    | event_id / received_at / state / dlq_path  |
| 一覧 | 状態フィルタ                                          | QuickFilterChips                                                      | 「DLQ 滞留」「24h+ 滞留」「30 日近接」「全て」              |
| 一覧 | 詳細フィルタ (折り畳み)                                   | チェックボックス                                                              | 12 状態                                      |
| 一覧 | リプレイ枠残日数 列                                      | 出力 (行毎)                                                               | 残 3 日以内は黄、残 0 日は赤背景                        |
| 一覧 | 滞留時間バッジ                                         | 出力                                                                    | 1h+ は黄、24h+ は赤                             |
| 詳細 | Webhook ペイロード (R2 退避から呼び戻し)                     | 出力                                                                    | 機密フィールドはマスク。PayloadDiffViewer 要約モード優先      |
| 詳細 | 過去のリプレイ履歴                                       | 出力 (テーブル)                                                             | dlq_replay_log を時系列表示                      |
| 詳細 | ペイロード差分リンク                                      | リンク                                                                   | SCR-099 への直接ジャンプ (差分があるとき)                 |
| 操作 | リプレイする                                          | ボタン (Primary + 再認証 <input checked="" type="checkbox"/> + 確認)          | 1 時間自動 BO 完了後のみ活性化、受信から 30 日以内、チケット ID 必須  |
| 操作 | 破棄する                                            | ボタン (Danger + 4-eyes 承認ログ + 再認証 <input checked="" type="checkbox"/> ) | DLQ 確定イベントのみ。復元不可                          |
| 操作 | リプレイ実行時のチケット ID 入力                              | TicketIdField                                                         | 必須                                         |
| 完了 | 監査ログ記録 (webhook.replay / webhook.discard、5 年保持) | -                                                                     | -                                          |

## 2.5.11 5.11 SCR-098 PII 誤検出報告管理

**2.5.11.1 画面概要** PII 誤検出報告を 3 営業日以内に判定。上に SLA サマリ帯、中央に一覧、右に詳細プレビューペイン。

### 2.5.11.2 表示・操作項目

| 区分 | 項目   | 入出力        | バリデーション           |
|----|------|------------|-------------------|
| 表示 | パンくず | Breadcrumb | 「ホーム / PII 誤検出報告」 |

| 区分 | 項目                          | 入出力                                                                 | バリデーション                                                                              |
|----|-----------------------------|---------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| 表示 | SLA サマリ帯 (上部固定)             | アラート                                                                | 「期限内: {green} 件 / 期限間近 (残 1 日): {yellow} 件 / 期限切れ: {red} 件」                          |
| 表示 | クイックフィルタチップ                 | QuickFilterChips                                                    | 「期限切れ」「期限間近」「未判定」「すべて」                                                               |
| 一覧 | 報告一覧                        | 出力                                                                  | 状態 (reported / under_review / ruled_* / archived)                                    |
| 一覧 | 状態バッジ                       | 出力                                                                  | reported(青)/ under_review(黄)/ ruled_false_positive(緑)/ ruled_correct(灰)/ archived(灰) |
| 一覧 | 3 営業日判定タイマー                 | カウントダウン + アイコン                                                      | 残 2 営業日以上: 緑 / 残 1 営業日: 黄 / 超過: 赤                                                    |
| 詳細 | 報告内容 (マスキング前後)              | 出力                                                                  | 機密項目は表示制限                                                                            |
| 詳細 | 検出層 (第 1 層 / 第 2 層 / 第 3 層) | 出力                                                                  | -                                                                                    |
| 操作 | under_review 開始             | ボタン (Secondary)                                                     | 3 営業日タイマー起動                                                                          |
| 操作 | ruled_false_positive 判定     | ボタン (Primary)                                                       | ルール更新候補へ                                                                             |
| 操作 | ruled_correct_detection 判定  | ボタン (Secondary)                                                     | アーカイブへ                                                                               |
| 操作 | 報告を却下する                     | ボタン (Danger、4-eyes 承認ログ + 再認証 <input checked="" type="checkbox"/> ) | 報告者へ却下理由を通知                                                                          |

### 2.5.11.3 ルール更新モデル

| 区分 | 項目        | 入出力                                                                   | バリデーション                                                     |
|----|-----------|-----------------------------------------------------------------------|-------------------------------------------------------------|
| 入力 | 更新するルール   | 出力 (現在値 + 提案変更)                                                       | KV ルール (正規表現 / 分類器パラメータ)                                    |
| 表示 | 影響件数プレビュー | 出力                                                                    | 「過去 30 日の質問ログに対しドライラン: 検知数 {now} 件 → {after} 件 (差分 {diff})」 |
| 入力 | 段階ロールアウト  | ラジオ (0% / 10% / 50% / 100%)                                           | -                                                           |
| 入力 | 対応チケット ID | TicketIdField                                                         | 必須                                                          |
| 入力 | 申請理由      | テキストエリア (最大 1000 文字)                                                  | 必須                                                          |
| 操作 | ルールを更新する  | ボタン (Primary + 再認証 <input checked="" type="checkbox"/> + 4-eyes 承認ログ) | チケット ID 必須、過去データ修正なし (今後の検出のみ)                              |

## 2.5.12 5.12 SCR-099 Webhook ペイロード差分検出一覧

**2.5.12.1 画面概要** 同一イベント ID で payload\_hash が異なる Webhook 受信を検出・レビュー。上部に検出件数サマリ、左に一覧、右に diff ビューア (unified diff 形式優先)。

### 2.5.12.2 表示・操作項目

| 区分 | 項目                | 入出力        | バリデーション                                     |
|----|-------------------|------------|---------------------------------------------|
| 表示 | パンくず <sup>a</sup> | Breadcrumb | 「ホーム / ペイロード差分検出」                           |
| 表示 | サマリ帯 (上部)         | アラート       | 「未レビュー: {N} 件 / レビュー中: {M} 件 / 処理完了: {K} 件」 |

| 区分 | 項目                                             | 入出力                                                              | バリデーション                                                                        |
|----|------------------------------------------------|------------------------------------------------------------------|--------------------------------------------------------------------------------|
| 表示 | クイックフィルタチップ                                    | QuickFilterChips                                                 | 「未レビュー」「レビュー中」「処理完了」「すべて」                                                      |
| 一覧 | 同一 event_id + payload_hash<br>不一致イベント          | 出力                                                               | detected_at / event_id / owner_account_id                                      |
| 一覧 | 状態バッジ                                          | 出力                                                               | detected(青)/ reviewed(黄)/ repro-<br>cessed_manually(緑)/ dismissed_no_action(灰) |
| 詳細 | diff ビューア (unified 形式優先)                       | PayloadDiffViewer                                                | 単一カラムで unified diff。左右並列は折り畳み内。<br>除外フィールドはグレースアウト                             |
| 詳細 | 除外フィールド一覧 (D-06)                               | 出力 + tooltip                                                     | グレースアウトされたフィールドにマウスホバーで<br>「除外理由」表示                                            |
| 操作 | レビューを開始する                                      | ボタン (Secondary)                                                  | state=reviewed へ遷移                                                             |
| 操作 | 手動再処理 (SCR-097 へ遷移)                            | ボタン (Primary、右上固定 +<br>再認証 <input checked="" type="checkbox"/> ) | チケット ID 必須                                                                     |
| 操作 | 影響なしとして処理完了                                    | ボタン (Secondary + 理由モ<br>ーダル)                                     | dismissed_no_action へ遷移。理由必須 (最大 500<br>文字)                                    |
| 完了 | 監査ログ記録 (web-<br>hook.payload_diff.*、5 年保<br>持) | -                                                                | -                                                                              |

### 2.5.13 5.13 SCR-APPROVALS 承認待ち一覧 (4-eyes)

**2.5.13.1 画面概要** 4-eyes 原則対象操作の申請を、申請者・承認者の双方が一覧。新規申請の発火は各操作画面、承認 / 却下の発火は本画面の行アクション。

#### 2.5.13.2 表示・操作項目

| 区分 | 項目                      | 入出力                       | バリデーション                                                                                                                   |
|----|-------------------------|---------------------------|---------------------------------------------------------------------------------------------------------------------------|
| 表示 | クイックフィルタチップ             | チップグループ                   | 「承認待ち (別運営者)」「あなたの申請」「期限切れ間近」「すべて」                                                                                        |
| 一覧 | 申請一覧                    | 出力                        | 状態 / 操作種別 / 申請者 / 期限切れ間近のフィルタ                                                                                             |
| 一覧 | 「あなたの申請」バッジ             | 出力                        | 自分が申請者の行に表示 (自己承認禁止の可視化)                                                                                                  |
| 一覧 | 状態 (ApprovalStateBadge) | 出力                        | requested / reviewing / approved / rejected / withdrawn / exe-<br>cuted / expired の 7 状態                                  |
| 一覧 | 自己取下げと他者却下の区<br>別       | 出力                        | withdrawn(自己取下げ) と rejected(別運営者却下) を別表示                                                                                  |
| 一覧 | 残時間カウントダウン              | 出力                        | 72h タイマー、残 24h 以内は黄、残 6h 以内は赤強調                                                                                           |
| 操作 | 詳細表示                    | 操作                        | 自分が申請者 / 承認候補のいずれであっても閲覧可。申請者本<br>人は SCR-APPROVALS-M2 で「自己取下げ」のみ可                                                         |
| 操作 | 承認 / 却下                 | 操作 → SCR-<br>APPROVALS-M2 | 別運営者前提。自分の申請行では SelfApprovalGuard で非活性<br>化                                                                               |
| 操作 | 取り下げる (自分の申請の<br>み)     | 操作 → SCR-<br>APPROVALS-M2 | 申請者本人のみ表示                                                                                                                 |
| 表示 | 空状態                     | EmptyState                | 「承認待ちはありません」                                                                                                              |
| 完了 | 監査ログ記録                  | 出力                        | approval.requested / approval.approved / approval.rejected /<br>approval.withdrawn / approval.executed / approval.expired |

## 2.5.14 5.14 SCR-APPROVALS-M1 4-eyes 承認申請モジュール

**2.5.14.1 画面概要** 各操作画面で「4-eyes 申請」を起動すると開く独立画面。MVP ハードゲート 3 操作と承認ログ対象操作で共通利用。

### 2.5.14.2 表示・入力・操作項目

| 区分 | 項目                                | 入出力                                                     | バリデーション                                                                  |
|----|-----------------------------------|---------------------------------------------------------|--------------------------------------------------------------------------|
| 表示 | 操作種別                              | 出力                                                      | 親画面から自動連携 (action_code)                                                  |
| 表示 | 対象操作の概要                           | 出力                                                      | 親画面から自動連携 (target_type / target_id / payload_hash)                       |
| 表示 | 変更内容の要約 (主表示)                     | PayloadDiffViewer(要約モード)                                | 主要変更点を「変更前 → 変更後」のキー別対比で表示                                               |
| 表示 | 生 JSON(折り畳み)                      | PayloadDiffViewer(raw モード)                              | 詳細を必要とする運営者向けに展開可能                                                       |
| 入力 | 申請理由                              | 入力 (テキストエリア、最大 1000 文字、文字数カウンタ)                         | 必須                                                                       |
| 入力 | 対応チケット ID                         | TicketIdField                                           | 必須、最大 64 文字                                                              |
| 表示 | 通知先表示                             | 出力                                                      | 「申請後、運営者 N 名 (あなたを除く) に通知されます」                                           |
| 操作 | 申請する                              | 操作 (Primary + 再認証 <input checked="" type="checkbox"/> ) | 再 認 証 検 証 → operator_approvals(state='requested') INSERT → 全運営者 inbox 通知 |
| 操作 | キャンセル                             | 操作 (Secondary)                                          | フォームを破棄してモジュールを閉じる                                                       |
| 完了 | 監査ログ記録 (approval.requested、5 年保持) | -                                                       | -                                                                        |

## 2.5.15 5.15 SCR-APPROVALS-M2 4-eyes 承認 / 却下モジュール

**2.5.15.1 画面概要** SCR-APPROVALS 一覧の行アクションから開く独立画面。申請者本人は「自己取下げ」のみ、別運営者は「承認」または「却下」を実行可能。

### 2.5.15.2 表示・入力・操作項目

| 区分 | 項目                         | 入出力                      | バリデーション                                 |
|----|----------------------------|--------------------------|-----------------------------------------|
| 表示 | 申請者                        | 出力                       | requested_by + 申請日時 + 残時間 (72h カウントダウン) |
| 表示 | 対象操作 / 対象                  | 出力                       | action_code / target_type / target_id   |
| 表示 | 変更内容の要約 (主表示)              | PayloadDiffViewer(要約モード) | 「変更前 → 変更後」のキー別対比表示                     |
| 表示 | 申請理由                       | 出力                       | 申請モジュールで入力された自由記述                       |
| 表示 | 対応チケット ID                  | 出力                       | 申請モジュールで入力された値                          |
| 表示 | payload_hash 不一致警告 (該當時のみ) | アラート (モジュール上部固定)         | hash 不一致時に赤帯で警告 + 「最新を表示」「最新で再申請」リンク    |
| 表示 | 自己承認禁止ガード (申請者本人の場合)       | アラート + CTA 非活性化          | SelfApprovalGuard が表示 + 「承認」「却下」を非活性化   |
| 入力 | 承認コメント (任意)                | 入力                       | 最大 1000 文字                              |



| 区分 | 項目                                                                        | 入出力                                           | バリデーション                                             |
|----|---------------------------------------------------------------------------|-----------------------------------------------|-----------------------------------------------------|
| 入力 | 却下コメント (必須)                                                               | 入力                                            | 却下時は必須、最大 1000 文字                                   |
| 操作 | 承認する (右下、緑系 Primary、再認証 <input checked="" type="checkbox"/> )             | 操作                                            | 別運営者前提、approved_by 設定 → state='approved' 遷移 → 申請者通知 |
| 操作 | 却下する (左下、赤系 Danger、再認証 <input checked="" type="checkbox"/> )              | 操作                                            | 別運営者前提、却下コメント必須 → state='rejected'                  |
| 操作 | 取り下げる (自分の申請のみ)                                                           | 操作 (再認証 <input checked="" type="checkbox"/> ) | 申請者本人前提 (別運営者は非活性)、state='withdrawn'                |
| 操作 | キャンセル                                                                     | 操作 (Secondary)                                | 何も変更せずモーダルを閉じる                                      |
| 完了 | 監査ログ記録 (approval.approved / approval.rejected / approval.withdrawn、5 年保持) | -                                             | -                                                   |

## 2.6 6. ユーザー種別別表示制御

運営者は単一ロール (service\_operator)。表示制御は「全運営者表示」と「4-eyes 種別による操作可否」の 2 パターン。

## 2.7 7. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

## 2.8 8. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

# 3 API 設計書 (運営者)

## 3.1 1. 文書概要

### 3.1.1 1.1 目的

運営者システムのすべての API (管理 API / 4-eyes 承認 API / 連携 IF #1~#12 (運営者主管) / Stripe Webhook 一次受信) について、エンドポイント / 認証・認可 / 4-eyes 種別 / リクエスト / レスポンス / ステータスコード / エラー仕様を一元化する。

### 3.1.2 1.2 対象範囲

- 対象: 運営者向け管理 API (認証 / MFA / 4-eyes / 削除データ / AI パラメータ / 契約上書き / お知らせ / 監査 / Webhook / PII 報告)、運営者 → メインの連携 IF 送信 (#1 / #2 / #4 / #5 / #6 / #7 / #10 / #12)、メイン → 運営者の受信 (#8 / #9)、Stripe Webhook 一次受信
- 対象外: 利用者向け管理 API ([01\\_メインシステム/個別設計書群/03\\_API 設計書.md](#))

### 3.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

### 3.1.4 1.4 関連ドキュメント

| ドキュメント名      | 役割                             | 参照先                                 |
|--------------|--------------------------------|-------------------------------------|
| 索引           | 11 ドキュメント体系の俯瞰                 | 00_ 索引.md                           |
| 画面設計書        | API を呼び出す画面                    | 02_ 画面設計書.md                        |
| テーブル定義書      | API が操作するテーブル                  | 04_ テーブル定義書.md                      |
| 認証・認可設計書     | 6 段認可判定 / 4-eyes 承認            | 09_ 認証認可設計書.md                      |
| エラー設計書       | ステータスコード / エラー詳細               | 06_ エラー設計書.md                       |
| メッセージ一覧      | エラー文言                          | 07_ メッセージ一覧.md                      |
| 権限設計書        | 4-eyes 対象 10 操作                | 05_ 権限設計書.md                        |
| 課金・請求設計書     | Stripe Webhook 一次受信 / DLQ リプレイ | 11_ 課金請求設計書.md                      |
| メイン側 API 設計書 | 連携 IF 受信側                      | ../01_ メインシステム/個別設計書群/03_API 設計書.md |

## 3.2 2. API 一覧

### 3.2.1 2.1 機能ブロック別 API (§6.4)

| 機能ブロック            | 主要 API                                                    | 認証               | Idempotency           | 4-eyes           |
|-------------------|-----------------------------------------------------------|------------------|-----------------------|------------------|
| 運営者認証             | POST /admin/v1/auth/login, /auth/mfa/verify, /auth/reauth | Cookie + CSRF    | -                     | -                |
| 4-eyes 申請承認       | POST /admin/v1/approvals, '/approvals/{id}/approve        | reject           | withdraw'             | Cookie + Re-Auth |
| 削除データ参照           | GET /admin/v1/deleted-resources                           | Cookie           | -                     | -                |
| 削除データ復元           | POST /admin/v1/restorations                               | Cookie + Re-Auth | restoration_id        | 承認ログ             |
| AI パラメータ          | PUT /admin/v1/ai-parameters/{scope}/{id}                  | Cookie + Re-Auth | parameter_revision_id | 承認ログ             |
| レート/予算上書き         | PUT /admin/v1/overrides/rate-limit/{id}, /budget/{id}     | Cookie + Re-Auth | override_id           | 承認ログ             |
| お知らせ配信            | POST /admin/v1/announcements, '/{id}/schedule             | cancel'          | Cookie + Re-Auth      | announcement_id  |
| 監査ログ              | GET /admin/v1/audit-logs, POST /audit-logs/exports        | Cookie           | export_id             | -                |
| Webhook リプレイ      | POST /admin/v1/webhooks/replay                            | Cookie + Re-Auth | replay_id             | 承認ログ             |
| PII 報告            | POST /admin/v1/pii-rules/revisions                        | Cookie + Re-Auth | rule_revision         | 承認ログ             |
| Stripe Webhook 受信 | POST /webhooks/stripe                                     | Stripe 署名        | event_id              | -                |

## 3.3 3. 共通仕様

### 3.3.1 3.1 認証ヘッダ / セッション

| 項目           | 値                                                                                                  |
|--------------|----------------------------------------------------------------------------------------------------|
| Base URL     | https://admin.open-faq.example.com/admin/api/v1                                                    |
| Content-Type | Request: application/json / Response: application/json / Error: application/problem+json(RFC 7807) |
| 日時形式         | ISO 8601 UTC                                                                                       |
| ID 形式        | ULID(26 文字)、Stripe ID 例外 (evt_*, sub_*, inv_*, cn_*)                                               |
| ページング        | カーソル方式 (cursor, limit 50~200)                                                                      |
| Idempotency  | Idempotency-Key ヘッダ (ULID 推奨、24h 保管)                                                               |
| トレース         | X-Trace-Id: <ULID> レスポンスヘッダ                                                                        |
| パスワードハッシュ    | Argon2id m=128MB, t=4, p=4, salt=16B                                                               |

| 項目        | 値                                                                            |
|-----------|------------------------------------------------------------------------------|
| パスワード要件   | 12 文字以上、大文字 + 小文字 + 数字 + 記号各 1 文字以上                                          |
| セッション TTL | 8 時間絶対 / 30 分無操作                                                             |
| 再認証有効期間   | 5 分以内、1 回限り                                                                  |
| ロックアウト    | 5 連続失敗で (IP × user_id) 単位 15 分                                               |
| MFA       | TOTP + 回復コード (Argon2id ハッシュ保管)                                               |
| Cookie 属性 | Secure; HttpOnly; SameSite=Strict; Domain=admin.open-faq.example.com; Path=/ |
| CSRF      | 状態変更系で X-CSRF-Token ヘッダ必須                                                    |
| レート制限     | 600 req/min/運営者 (超過時 429)                                                    |

エラーレスポンス (RFC 7807):

```
{
  "type": "https://docs.open-faq.example.com/errors/FORBIDDEN_HARD_GATE",
  "title": "Hard gate requires approval",
  "status": 403,
  "code": "FORBIDDEN_HARD_GATE",
  "detail": "action=ai_parameter.update requires X-Approval-Id header",
  "trace_id": "01J9V0...",
  "instance": "/admin/api/v1/ai-parameters/owner/01J9..."
}
```

### 3.3.2 3.2 ticket\_id 入力規約

| ヘッダ            | 用途                    | 形式                                             |
|----------------|-----------------------|------------------------------------------------|
| X-Op-Ticket-Id | 対応チケット ID(クリティカル操作必須) | 任意文字列、最大 64 文字。例: JIRA-12345 / INC-001 / #1234 |

### 3.3.3 3.3 再認証 (5 分以内)

ヘッダ: X-Reauth-Id: <reauth\_id>(再認証から 5 分以内、1 回限り)

未保持時は 403 + 「再認証が必要です」 (MSG-OP-REAUTH-REQUIRED、E-OP-REAUTH-REQUIRED)

### 3.3.4 3.4 4-eyes 承認チェック

ヘッダ: X-Approval-Id: <approval\_id>(4-eyes ハードゲート操作時必須)

詳細フローは [09\\_ 認証認可設計書.md § 7](#) を正本とする。

### 3.3.5 3.5 Stripe Webhook 一次受信仕様

詳細は § 5.7 を参照。Stripe 署名検証 + 冪等性 + ペイロード差分検出。

### 3.3.6 3.6 連携 IF 共通仕様 (mTLS + JWT)

メイン側 [03\\_API 設計書.md § 3.4 / § 3.5](#) と整合。

## 3.4 4. レート制限・キャパシティ (運営者側 §11.7、全 17 項目)

| 機能              | リミット             | 関連      |
|-----------------|------------------|---------|
| 監査ログ検索期間        | 最大 1 年           | FR-232  |
| 監査ログ検索ヒット       | 最大 100 万件        | FR-232  |
| 監査ログエクスポート      | 最大 10 万行 (自動分割)  | FR-232  |
| ページング           | カーソル方式 100 件/ページ | FR-232  |
| DLQ 保持 (Queues) | 4 日              | NFR-809 |
| DLQ R2 退避       | 30 日             | NFR-809 |

| 機能                | リミット                | 関連      |
|-------------------|---------------------|---------|
| Webhook リプレイ範囲    | 直近 30 日             | FR-302  |
| 4-eyes 承認待 TTL    | 72 時間               | § 6.3.1 |
| お知らせ予約上限          | 最大 30 日先            | FR-149  |
| お知らせ取消窓           | 配信開始 5 分前           | FR-149  |
| 運営者セッション          | 8 時間絶対 / 30 分無操作    | D-18    |
| 再認証セッション          | 5 分以内 (1 回限り)       | FR-005  |
| DLQ 自動 BO 間隔      | 1m → 4m → 16m       | FR-302  |
| DLQ 自動 BO 最大回数    | 3 回 (超過で永久失敗)       | FR-302  |
| DLQ → 手動リプレイ移行    | 1 時間                | FR-302  |
| お知らせ失敗 BO         | 1m → 4m → 16m (3 回) | FR-149  |
| 4-eyes 承認後未実行 TTL | 72 時間               | § 6.3.1 |

## 3.5 5. API 詳細

### 3.5.1 5.1 運営者認証 API

**3.5.1.1 5.1.1 POST /admin/v1/auth/login** | 機能 ID | F-OP-001 | | 認証要否 | 不要 (IP 許可リスト適用) |  
| 関連画面 | SCR-AUTH |

リクエスト:

```
{
  "email": "ops@example.com",
  "password": "..."}
}
```

レスポンス (200): { "sessionId": "01J...", "csrfToken": "...", "mfaRequired": true, "mfaSetupRequired": false } + Cookie 設定

エラー: 401 **INVALID\_CREDENTIALS**(E-OP-AUTH-CREDENTIAL)、423 **LOCKED**(5 連続失敗、E-OP-AUTH-LOCKED)、400 **VALIDATION\_ERROR**、401(IP allowlist 拒否、E-OP-IP-DENIED)

監査: operator.login.attempt(1y)

**3.5.1.2 5.1.2 POST /admin/v1/auth/mfa/verify** | 関連画面 | SCR-AUTH | | 4-eyes 種別 | - |

リクエスト: { "code": "123456" } または { "recoveryCode": "ABCDEF-..." }

レスポンス (200): { "mfaVerifiedAt": "...", "expiresAt": "..." } エラー: 401 **MFA\_INVALID\_CODE**(E-OP-MFA-FAILED)、423 **LOCKED**(5 連続失敗)

監査: operator.mfa.verify(5y)

**3.5.1.3 5.1.3 POST /admin/v1/auth/mfa/setup / GET /admin/v1/auth/mfa/setup?token=...** | 認証 | 招待トークン (mfa-setup:<account\_id> KV、72h) | | 関連画面 | SCR-AUTH-M1 |

GET レスポンス (QR + 秘密 + 回復コード 10 個発行):

```
{
  "qrCodeDataUrl": "data:image/png;base64,...",
  "secret": "BASE32...",
  "recoveryCodes": ["...", "..."]
}
```

POST リクエスト: { "setupToken": "...", "totpCode": "...", "recoveryCodesStored": true }  
レスポンス (200): { "mfaSetupCompletedAt": "..." } エラー: 401 **TOKEN\_EXPIRED**(E-OP-MFA-SETUP-EXPIRED)、401 **TOTP\_INVALID**、401 **TOKEN\_ALREADY\_USED**

監査: operator.mfa.setup(5y)

#### 3.5.1.4 5.1.4 POST /admin/v1/me/reauth(再認証) | 機能 ID | F-OP-004 | | 認証 | セッション + MFA 完了 |

リクエスト: { "password": "...", "mfaToken": "..." } レスponse (200): { "reauthenticatedAt": "...", "expiresAt": "<now+5min>", "reauthId": "01J..." } エラー: 401 INVALID\_CREDENTIALS、423 LOCKED(15 分)

監査: operator.reauth(5y)

#### 3.5.2 5.2 4-eyes 承認 API(本書の中核)

##### 3.5.2.1 5.2.1 POST /admin/v1/approvals(申請) | 機能 ID | F-OP-005 | | 認証 要否 | 要 (service\_operator) | | 4-eyes 種別 | 申請フロー発火点 | | 関連画面 | SCR-APPROVALS-M1 | | 関連テーブル | operator\_approvals |

リクエスト:

```
{
  "actionCode": "ai_parameter.update",
  "targetType": "...",
  "targetId": "...",
  "payloadJson": { /* 操作ペイロード */ },
  "payloadHash": "<sha256hex>",
  "reason": " 申請理由",
  "ticketId": "TKT-1234"
}
```

レスponse (201): { "approvalId": "01J...", "expiresAt": "<now+72h>", "payloadHash": "<hex>" } エラー: 409 APPROVAL\_PENDING(同一操作 5 分以内二重)、409 PAYLOAD\_HASH\_MISMATCH、400 VALIDATION\_ERROR

監査: operator\_approval.request(5y)

##### 3.5.2.2 5.2.2 POST /admin/v1/approvals/{id}/approve(承認) | 機能 ID | F-OP-006 | | 認証 | 要 (service\_operator、申請者以外) | | 4-eyes 種別 | 承認ハードゲート | | 関連画面 | SCR-APPROVALS-M2 |

リクエスト: { "comment": "..." } + X-Approval-Id(承認者トークン) レスponse (200): { "state": "approved", "approvedAt": "..." } エラー: 403 FORBIDDEN\_SELF\_APPROVE(E-OP-4EYES-SELF)、410 APPROVAL\_EXPIRED(E-OP-4EYES-EXPIRED)、409 APPROVAL\_PAYLOAD\_MISMATCH(E-OP-4EYES-PAYLOAD-CHANGED)

監査: operator\_approval.approve(5y)

##### 3.5.2.3 5.2.3 POST /admin/v1/approvals/{id}/reject(却下) | 認可条件 | 申請者以外、再認証必須 | | 関連画面 | SCR-APPROVALS-M2 |

リクエスト: { "comment": "< 必須 >" } レスponse (200): { "state": "rejected", "rejectedAt": "..." } エラー: 403 FORBIDDEN\_SELF\_APPROVE

監査: operator\_approval.reject(5y)

##### 3.5.2.4 5.2.4 POST /admin/v1/approvals/{id}/withdraw(取下げ) | 認可条件 | 申請者本人のみ |

リクエスト: { "comment": "..." } レスponse (200): { "state": "withdrawn", "withdrawnAt": "..." } エラー: 403 FORBIDDEN(申請者以外)、409 CONFLICT(requested 以外)

監査: operator\_approval.withdraw(5y)

#### 3.5.3 5.3 削除データ参照・復元 API

##### 3.5.3.1 5.3.1 GET /admin/v1/deleted-resources | 機能 ID | F-OP-009 | | 関連画面 | SCR-090 |

クエリ: ownerSearch, resourceTypes[], deletionTypes[], from, to, cursor, limit

レスponse (200):

```
{
  "items": [
    {
      "resourceType": "owner",
      "resourceId": "...",
      "ownerAccountId": "...",
      "deletionType": "deleted_pending",
      "deletedAt": "...",
      "scheduledPhysicalDeleteAt": "...",
      "preview": { /* 直前主要属性プレビュー、本文非表示 */ }
    }
  ],
  "nextCursor": "..."
}
```

監査: (読取のみ)

**3.5.3.2 5.3.2 POST /admin/v1/restorations(削除データ復元)** | 機能 ID | F-OP-010 | | 4-eyes 種別 | 承認ログ (action: owner.restore\_data) | | 関連画面 | SCR-091 | | 関連テーブル | deleted\_resources, deletions, restorations, audit\_logs | | 連携 IF | #4(本書 → メイン復元実行)、 #12(管理者ユーザー通知) |

リクエスト:

```
{
  "resourceType": "owner",
  "resourceId": "...",
  "reason": " 顧客問合せ #ABC-123 対応"
}
```

ヘッダ: X-Op-Ticket-Id、 X-Approval-Id

レスポンス (200):

```
{
  "restorationId": "01J...",
  "restoredAt": "...",
  "rollback": {
    "stripeSubscriptionResumed": "sub_xxx",
    "dlqRequeued": 3,
    "inboxRequeued": 5
  }
}
```

エラー: 423 RESTORE\_LOCK\_FAILED(E-OP-RESTORE-LOCKED)、 500 RESTORE\_SIDE\_EFFECT\_FAILED

監査: owner.restore または <resource>.restore(5y)

### 3.5.4 5.4 AI パラメータ・契約上書き API

**3.5.4.1 5.4.1 PUT /admin/v1/ai-parameters/{scope}/{scopeId}** | 機能 ID | F-OP-011 | | 4-eyes 種別 | ハードゲート (action: ai\_parameter.update) | | 関連画面 | SCR-092 | | 連携 IF | #6(メイン同期) | | scope | global / owner / project | | scopeId | global は "global" 固定、それ以外は ID |

リクエスト:

```
{
  "confidenceThreshold": 0.62,
  "relevanceThreshold": 0.55,
  "modelId": "@cf/meta/llama-3.1-8b-instruct",
  "rolloutPercentage": 10,
  "reason": "test increase..."
}
```

ヘッダ: X-Op-Ticket-Id、 X-Approval-Id

レスポンス (200): { "scope": "owner", "scopeId": "01J...", "version": "...", "appliedAt": "...", "kvKey": "ai-params:owner:01J..." } エラー: 403 FORBIDDEN\_HARD\_GATE(E-OP-4EYES-HARDGATE)、400 VALIDATION\_ERROR

監査: ai\_parameter.update(5y)

**3.5.4.2 5.4.2 PUT /admin/v1/overrides/rate-limit/{owner\_account\_id}** | 機能 ID | F-OP-012 |  
| 4-eyes 種別 | 承認ログ (action: rate\_limit.override) | | 連携 IF | #5(メイン同期)|

リクエスト:

```
{
  "widgetAskPerMin": 200,
  "chatEndUserPerMin": 10,
  "chatStaffPerMin": 30,
  "reason": " 急増対応 #TKT-1234"
}
```

レスポンス (200): { "overrideId": "...", "kvKey": "rate-limit:01J..." }

監査: rate\_limit.override(5y)

**3.5.4.3 5.4.3 PUT /admin/v1/overrides/budget/{owner\_account\_id}** | 4-eyes 種別 | 承認ログ (action: budget.override)|

リクエスト: { "monthlyBudgetJpy": 100000, "reason": "..." }

### 3.5.5 5.5 お知らせ API

**3.5.5.1 5.5.1 POST /admin/v1/announcements(作成)** | 機能 ID | F-OP-013 | | 関連画面 | SCR-094 |

リクエスト:

```
{
  "kind": "announcement",
  "severity": "normal",
  "scope": { "type": "all" },
  "subject": " メンテナンス予告",
  "bodyHtml": "<p>...</p>",
  "optOut": "optional",
  "scheduledAt": "2026-05-15T10:00:00Z"
}
```

レスポンス (201): { "announcementId": "...", "state": "draft", "sanitizedBodyHtml": "..." }  
エラー: 422 XSS\_PATTERN\_DETECTED(タグ/属性フィルタ)

監査: announcement.create(5y)

**3.5.5.2 5.5.2 POST /admin/v1/announcements/{id}/schedule(配信予約)** | 認証 | 要(再認証 + チケット ID)|

バリデーション:  $\text{now} \leq \text{scheduledAt} \leq \text{now} + 30\text{d}$  監査: announcement.schedule(5y)

**3.5.5.3 5.5.3 POST /admin/v1/announcements/{id}/send(即時配信)** | 4-eyes 種別 | 承認ログ + 確認 (緊急用、HardgateBadge)|

連携 IF #7 経由でメインへ配信指示。

### 3.5.6 5.6 監査・PII 報告 API

**3.5.6.1 5.6.1 GET /admin/v1/audit-logs** | 機能 ID | F-OP-017 | | 関連画面 | SCR-096 |

クエリ: action, actorId, targetId, ownerAccountId, from, to, ipMasked, ticketId, cursor, limit  
バリデーション:  $\text{to} - \text{from} \leq 365 \text{ 日}$

レスポンス (200):

```
{
  "items": [
    {
      "id": "01J...",
      "occurredAt": "...",
      "actorId": "...",
      "action": "owner.restore",
      "targetId": "...",
      "ticketId": "TKT-1234",
      "beforeValue": { /* 差分 */ },
      "afterValue": { /* 差分 */ },
      "prevHash": "...",
      "recordHash": "..."
    }
  ],
  "nextCursor": "..."
}
```

監査: (読取のみ)

### 3.5.6.2 5.6.2 POST /admin/v1/audit-logs/exports | 機能 ID | F-OP-018 | | 認証 | 再認証 |

リクエスト: { "filter": { "action": "owner.\*", "from": "2026-04-01", "to": "2026-05-01" }, "format": "csv" }

レスポンス (202): { "exportId": "01J...", "status": "processing", "estimatedRows": 12345, "files": [] }

完了後: GET /admin/v1/audit-logs/exports/{exportId} で files: [{ url, sigUrl, rows }] エラー: 422 EXPORT\_TOO\_LARGE(>100 万行)

監査: audit.export(5y)

### 3.5.6.3 5.6.3 POST /admin/v1/pii-rules/revisions | 機能 ID | F-OP-016 | | 4-eyes 種別 | 承認ログ (action: pii\_rule.update) | | 関連画面 | SCR-098 |

リクエスト:

```
{
  "regexRules": [
    { "id": "phone_jp", "pattern": "0[789]0-\\d{4}-\\d{4}", "enabled": true }
  ],
  "classifierParams": { "threshold": 0.85 },
  "rolloutPercentage": 10,
  "reason": " 誤検出報告 #PFP-001 対応"
}
```

レスポンス (201): { "revisionId": "...", "kvKey": "pii-rules:regex" }

監査: pii\_rule.update(5y)

## 3.5.7 5.7 Webhook 関連 API

### 3.5.7.1 5.7.1 POST /admin/v1/webhooks/replay(DLQ リプレイ) | 機能 ID | F-OP-015 | | 4-eyes 種別 | 承認ログ (action: webhook.replay) | | 関連画面 | SCR-097 |

リクエスト: { "eventId": "evt\_xxx", "ticketId": "TKT-1234" } + X-Op-Ticket-Id バリデーション: state='dlq\_manual\_replay'、自動 BO 完了済み、受信から 30 日以内

レスポンス (200): { "state": "processing", "replayId": "..." } エラー: 409 WEBHOOK\_REPLAY\_AUTO\_BO\_IN\_PROGRESS、410 WEBHOOK\_REPLAY\_WINDOW\_EXPIRED(30 日超、E-OP-WEBHOOK-REPLAY-EXPIRED)

監査: webhook.replay(5y)



### 3.5.7.2 5.7.2 POST /webhooks/stripe(Stripe Webhook 一次受信) | 認証 | Stripe 署名 (HMAC-SHA256)| | 4-eyes 種別 | なし (自動処理)

ヘッダ:

- Stripe-Signature: t=<unix\_ts>,v1=<hmac\_sha256>,v1=<hmac\_sha256\_alternative>
- Content-Type: application/json

ボディ (Stripe 仕様):

```
{
  "id": "evt_xxxxx",
  "object": "event",
  "api_version": "2024-06-20",
  "created": 1718160000,
  "data": { /* ... */ },
  "livemode": true,
  "pending_webhooks": 1,
  "request": { "id": "req_xxxxx", "idempotency_key": "..."},
  "type": "invoice.paid"
}
```

#### 3.5.7.2.1 署名検証アルゴリズム

```
verifyStripeSignature(payload, header, secret, tolerance=300s):
  parts = parseHeader(header)
  timestamp = parts.t
  if |now - timestamp| > tolerance: return false // Replay 攻撃防止
  signedPayload = timestamp + "." + payload
  expectedSig = HMAC-SHA256(secret, signedPayload)
  for sig in parts.v1[]:
    if constantTimeEqual(sig, expectedSig): return true
  return false
```

失敗時: HTTP 401 即返却 + 運営者 inbox(system/high)+ audit.webhook.signature\_invalid(5y)

#### 3.5.7.2.2 冪等性・差分検出

| 項目                   | 仕様                                                                            |
|----------------------|-------------------------------------------------------------------------------|
| 冪等性キー                | Stripe event_id(evt_*) を webhook_events.event_id PK                           |
| 正規化 JSON             | キーソート + 空白除去 → SHA-256 ハッシュ                                                   |
| 同 event_id + ハッシュ一致  | 200 OK 「duplicate, skipped, hash_match」 + ログ                                  |
| 同 event_id + ハッシュ不一致 | 200 OK + webhook_payload_diffs INSERT + SCR-099 記録 + 運営者 high alert + 自動上書き禁止 |

#### 3.5.7.2.3 内部転送対象イベント (メイン側へ mTLS + JWT 同期)

| event_type                           | 処理                 |
|--------------------------------------|--------------------|
| invoice.paid                         | 支払成功確定 → サスペンション解除 |
| invoice.payment_failed               | 支払失敗 → 猶予突入        |
| invoice.finalized                    | 請求書確定              |
| customer.subscription.updated        | プラン変更反映            |
| customer.subscription.deleted        | 解約 → suspended 遷移  |
| customer.subscription.trial_will_end | トライアル終了予告          |
| charge.refunded                      | 返金 → 請求書更新         |

#### 3.5.7.2.4 DLQ・リブレイ設計

| 項目                   | 仕様  |
|----------------------|-----|
| Cloudflare Queues 保持 | 4 日 |

| 項目      | 仕様                                |
|---------|-----------------------------------|
| R2 退避パス | dlq-stripe-events/<event_id>.json |
| R2 保持期間 | 30 日 (dlq_archived で以降リプレイ不可)     |
| 自動 BO   | 1m → 4m → 16m(3 回、超過で永久失敗)        |
| 手動リプレイ  | SCR-097 から運営者の明示操作のみ              |
| タイムアウト  | 30 秒                              |

### 3.5.7.3 5.7.3 Stripe Webhook 除外フィールド (差分検出時、付録 H 全件) ルートレベル: created, request.id, request.idempotency\_key, idempotency\_key\_resent, livemode, api\_version, pending\_webhooks

data.object レベル: data.object.created, data.object.updated\_at, data.object.test\_clock, data.object.metadata.test\_\*, data.object.metadata.\_stripe\_internal\_\*, data.previous\_attributes

配列要素内(再帰): \*.created, \*.updated\_at

## 3.5.8 5.8 連携 IF(送信 / 受信)

### 3.5.8.1 5.8.1 連携 IF 主管責任 (運営者側)

| IF# | 連携先               | 方向     | 認証                     | 冪等性キー                                   | DLQ               | TO  | 関連 FR      |
|-----|-------------------|--------|------------------------|-----------------------------------------|-------------------|-----|------------|
| #1  | メイン               | 本書 →   | mTLS + JWT(aud=main)   | (operation_id, owner_id, target_status) | 100/30m           | 5s  | FR-124     |
| #2  | メイン               | 本書 →   | mTLS + JWT             | (operation_id, owner_id)                | 100/30m           | 3s  | FR-224     |
| #4  | メイン               | 本書 →   | mTLS + JWT             | (restore_operation_id)                  | 50/24h            | 10s | FR-200~209 |
| #5  | メイン               | 本書 →   | mTLS + JWT             | (owner_id, override_id)                 | 50/30m            | 3s  | FR-121     |
| #6  | メイン               | 本書 →   | mTLS + JWT             | (owner_id, scope, version)              | 50/30m            | 3s  | FR-055     |
| #7  | メイン               | 本書 →   | mTLS + JWT             | (announcement_id, owner_id)             | 1000/h            | 30s | FR-149     |
| #8  | メイン               | メ → 本書 | mTLS + JWT(aud=admin)  | (metric_window_id)                      | n/a               | 10s | NFR-804    |
| #9  | メイン               | メ → 本書 | mTLS + JWT(aud=admin)  | (detection_id)                          | 200/30m           | 5s  | FR-195     |
| #10 | Stripe → 本書 → メイン | 本書 →   | Stripe 署名 + mTLS + JWT | Stripe event_id                         | 1000/24h + R2 30d | 10s | FR-302     |
| #12 | メイン               | 本書 →   | mTLS + JWT             | (operation_id, owner_id)                | 200/30m           | 5s  | FR-211     |

**3.5.8.2 5.8.2 IF #1 契約停止イベント送信** POST 先: メイン側 /internal/admin-integration/v1/owner/suspend 詳細は [メイン側 §5.13.1](#) を参照。

**3.5.8.3 5.8.3 IF #8 監視メトリクス取得 (受信)** エンドポイント: GET /internal/main-integration/v1/metrics?window=5m 認証: mTLS + JWT(aud=admin)

詳細は [メイン側 §5.13.7](#) を参照。

**3.5.8.4 5.8.4 IF #9 不正利用検知通知 (受信)** エンドポイント: POST /internal/main-integration/v1/fraud/detected

**3.5.8.5 5.8.5 IF #10 Stripe Webhook → メイン転送** §5.7.2 参照。Stripe 一次受信後にメイン側へ転送。

**3.5.8.6 5.8.6 IF #12 運営者操作通知送信** POST 先: メイン側 /internal/admin-integration/v1/admin-operation/notify 詳細は [メイン側 §5.13.10](#) を参照。

3.6 6. 4-eyes × API 対応表

| 4-eyes action code            | 種別     | API                                                   | 関連画面       |
|-------------------------------|--------|-------------------------------------------------------|------------|
| owner.physical_delete         | ハードゲート | DELETE /admin/v1/owners/:id/physical(MVP 範囲)          | SCR-091 派生 |
| ai_parameter.update           | ハードゲート | PUT /admin/v1/ai-parameters/{scope}/{id}              | SCR-092    |
| key.master_rotate             | ハードゲート | (運用 CLI、API なし)                                       | -          |
| owner.suspend / owner.restore | 承認ログ   | POST /admin/v1/owners/:id/suspend, /restore(IF #1 経由) | SCR-091 派生 |
| rate_limit.override           | 承認ログ   | PUT /admin/v1/overrides/rate-limit/{owner_id}         | SCR-093    |
| budget.override               | 承認ログ   | PUT /admin/v1/overrides/budget/{owner_id}             | SCR-093    |
| owner.force_stop              | 承認ログ   | POST /admin/v1/owners/:id/force-stop                  | SCR-093 派生 |
| owner.restore_data            | 承認ログ   | POST /admin/v1/restorations                           | SCR-091    |
| webhook.replay                | 承認ログ   | POST /admin/v1/webhooks/replay                        | SCR-097    |
| owner.legal_review.record     | 承認ログ   | POST /admin/v1/legal-review                           | SCR-098 派生 |

3.7 7. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

3.8 8. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

4 テーブル定義書 (運営者)

4.1 1. 文書概要

4.1.1 1.1 目的

運営者システム専用テーブル(`operator_*` / `audit_logs`(ハッシュチェーン構造の正本) / `webhook_events` / `operator_approvals` / `accounts_retired` 等)について、カラム / 型 / 制約 / インデックス / 外部キー / コード値 / 保持期間 / 保持起点を一元化する。

4.1.2 1.2 対象範囲

- 対象: 運営者専用テーブル 19 個 (認証 / 4-eyes / 監査 / Webhook / DLQ / PII / お知らせ下書き / 物理削除証跡 / 契約上書き / 月次請求 等)
- 対象外: 利用者向けテーブル(`accounts` / `projects` / `faqs` 等)—— [01\\_メインシステム/個別設計書群/04\\_テーブル定義書.md](#) を参照 (再掲なし、共有概念正本)

4.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

4.1.4 1.4 関連ドキュメント

| ドキュメント名      | 役割                                 | 参照先                                |
|--------------|------------------------------------|------------------------------------|
| 索引           | 11ドキュメント体系の俯瞰                      | 00_索引.md                           |
| 共有概念対応表      | 共有概念の正本所在                          | ../共有/共有概念.md                      |
| メイン側 テーブル定義書 | accounts/projects等の正本              | ../01_メインシステム/個別設計書群/04_テーブル定義書.md |
| API 設計書      | テーブルを操作する API                      | 03_API 設計書.md                      |
| 認証・認可設計書     | 4-eyes 承認モデル / IP allowlist        | 09_ 認証認可設計書.md                     |
| 権限設計書        | 4-eyes 対象 10 操作                    | 05_ 権限設計書.md                       |
| セキュリティ設計書    | 監査ログハッシュチェーン構造 / 3 区分保持            | 10_ セキュリティ設計書.md                   |
| 課金・請求設計書     | 請求書 7 年保持 / Webhook                | 11_ 課金請求設計書.md                     |
| 詳細設計書        | 実装関連の詳細 (モジュール構成 / バッチ / マイグレーション) | ../03_ 詳細設計書.md                    |

## 4.2 2. テーブル一覧

| #  | テーブル名                       | 論理名                    | 概要                            | 主キー                         | 関連 FR                            | 保持期間        | retention_c        | 状態列         |
|----|-----------------------------|------------------------|-------------------------------|-----------------------------|----------------------------------|-------------|--------------------|-------------|
| 1  | service_operator            | 運営者アカウント               | 1 自然人 1 アカウント                 | id(ULID)                    | FR-220, NFR-311                  | 退職後 5 年     | 5y                 | status      |
| 2  | operator_session            | 運営者セッション               | 8 時間 TTL、MFA 必須               | id                          | NFR-311, D-18                    | 1 年         | 1y                 | -           |
| 3  | operator_mfa_secret         | MFA Secrets-クレット       | AES-256-GCM 暗号化               | operator_id                 | FR-221                           | アカウント連動     | 5y                 | -           |
| 4  | operator_mfa_recovery_codes | MFA回復コード               | 10 個、Argon2id ハッシュ            | id                          | FR-221                           | アカウント連動     | 5y                 | -           |
| 5  | operator_ip_allowlist       | IP許可リスト                | KV TTL 60s でミラー               | id                          | NFR-311                          | 永久          | 5y                 | -           |
| 6  | operator_approval           | 4-eyes申請・承認            | 自己承認禁止 + payload_hash         | id                          | FR-226, § 6.3.1                  | 5 年         | 5y                 | state(7 値)  |
| 7  | audit_logs                  | 監査ログ(ハッシュチェーン構造の正本)    | 3 区分保持 (1y/5y/7y)+ tomb-stone | id                          | NFR-306, NFR-602, FR-229, FR-232 | retention 別 | 1y/5y/7y           | -           |
| 8  | webhook_event               | Stripe Webhook 受信      | event_id 幕等                   | event_id(Stripe evt_* 直接利用) | FR-302, NFR-808                  | 7 年         | 7y                 | state(12 値) |
| 9  | webhook_payload_diff        | Webhookペイロード差分検出       | SHA-256 差分検出                  | id                          | FR-302 異常系, AC-041               | 5 年         | 5y                 | state(4 値)  |
| 10 | dlq_replay_log              | DLQ リプレイ履歴             | 最大 30 日                       | id                          | FR-302(c), NFR-809               | 30 日        | 1y                 | -           |
| 11 | pii_false_positive_checks   | PII誤検出報告               | 3 営業日タイマー                     | id                          | FR-064, NFR-805                  | 5 年         | 5y                 | state(6 値)  |
| 12 | announcement_draft          | お知らせ下書き                | 訂正告知の自己参照                     | id                          | FR-149, FR-188, FR-189           | 5 年         | 5y                 | state(8 値)  |
| 13 | accounts_removal            | 物理削除契約証跡               | 永久保持(slug 再利用防止)              | owner_account_id            | NFR-707                          | 永久          | 7y(物理削除 action のみ) | -           |
| 14 | owner_registration_logs     | 契約登録審査                 | EU/EEA/UK 4-eyes 承認、GDPR 越境移転 | id                          | NFR-402                          | 7 年         | 7y                 | (未決事項 No.1) |
| 15 | rate_limit_override         | 契約別レート上書き              | D1 永続化 + KV ミラー               | id                          | FR-121, FR-128, FR-224(b)        | 5 年         | 5y                 | -           |
| 16 | ai_parameters_override      | AI overrides タ 3 階層上書き | グローバル/オーナー/プロジェクト             | id                          | FR-055, FR-061                   | 5 年         | 5y                 | -           |
| 17 | budget_limit_override       | 運営者上書き予算上限             | 契約別予算                         | id                          | FR-121(c)                        | 5 年         | 5y                 | -           |

| #  | テーブル名                   | 論理名        | 概要                      | 主キー | 関連 FR              | 保持期間 | retention_c | 状態列    |
|----|-------------------------|------------|-------------------------|-----|--------------------|------|-------------|--------|
| 18 | billing_invoices        | 月次請求書      | cron 生成、7 年保持 (電子帳簿保存法) | id  | FR-303, NFR-602(c) | 7 年  | 7y          | status |
| 19 | webhook_replay_requests | プレイバック要求受付 | 4-eyes 承認経由             | id  | FR-302, NFR-809    | 5 年  | 5y          | -      |

**メイン側との重要な差異:** メイン側にも **billing\_invoices** が存在するが、メイン側は利用者の参照用ビューを提供。本書記載の **billing\_invoices** は運営者側で cron 生成・保持の主管テーブル。実装上は同一テーブル名で同一物理テーブルを参照する設計判断とし、正本の所在 (メインまたは運営者) は詳細設計で最終確定する。

#### 4.2.1 2.1 audit\_logs.retention\_class 値の正本定義 (共有概念)

**audit\_logs.retention\_class** の値は **クラス名表記** (**general / billing / operator\_high\_priv**) に統一する。期間表記 (**1y / 5y / 7y**) はクラス名から導出できる人間可読補助。

| 正本クラス名             | 期間補助表記 | 保持期間                   | 用途       |
|--------------------|--------|------------------------|----------|
| general            | 1y     | 1 年 (NFR-602a)         | 業務監査     |
| billing            | 7y     | 7 年 (NFR-602b、電子帳簿保存法) | 課金・取引    |
| operator_high_priv | 5y     | 5 年 (NFR-602d、SOX 類似)  | 運営者高権限操作 |

DDL CHECK 制約は両側で統一:

**CHECK** (retention\_class **IN** ('general', 'billing', 'operator\_high\_priv'))

**表記補足:** 本書および [10\\_セキュリティ設計書.md §7.2](#) 内で言及される '1y' / '5y' / '7y' 文字列は、クラス名 (**general / billing / operator\_high\_priv**) の **人間可読補助** として残す (運営者側のドキュメント表記習慣)。両表記とも同一値を指す。

#### 4.2.2 2.2 主要関係性 (§7.2 ER 図から派生)

| 関係                                        | 型                           | 説明                          |
|-------------------------------------------|-----------------------------|-----------------------------|
| service_operators ☒ operator_sessions     | 1:N                         | セッション複数 (複数デバイス)            |
| service_operators ☒ operator_mfa_*        | 1:1 / 1:N                   | MFA シークレット 1 個 + 回復コード 10 個 |
| service_operators ☒ operator_approvals    | 1:N (申請者・承認者・却下者・撤回者の 4 種類) | 4-eyes                      |
| service_operators ☒ audit_logs            | 1:N (actor_id 経由)           | 全運営者操作の証跡                   |
| webhook_events ☒ webhook_payload_diffs    | 1:N                         | 同 event_id の差分検出            |
| webhook_events ☒ dlq_replay_log           | 1:N                         | リプレイ履歴                      |
| announcement_drafts ☒ announcement_drafts | 0..1:N (自己参照、correction_of) | 訂正告知元                       |
| operator_approvals ☒ audit_logs           | 1:N (approval_id 経由)        | 4-eyes 承認の証跡参照              |

#### 4.2.3 2.3 BR ↔ FR / 設計章マッピング (§7.1.1)

| BR     | 業務要件                | 派生 FR                             | 主管 SCR  |
|--------|---------------------|-----------------------------------|---------|
| BR-017 | 不正利用検知・対処 (運営者)     | FR-121, FR-128, FR-211(e), FR-224 | SCR-093 |
| BR-018 | SaaS 全体利用状況把握 (運営者) | FR-303, FR-304, FR-232            | SCR-096 |

| BR     | 業務要件        | 派生 FR                                  | 主管 SCR               |
|--------|-------------|----------------------------------------|----------------------|
| BR-021 | 月次請求確定通知    | FR-303                                 | SCR-096              |
| BR-022 | 運営からのお知らせ配信 | FR-149, FR-188, FR-189                 | SCR-094              |
| BR-028 | 内部統制機能      | FR-204, FR-211, FR-220～232, FR-302～304 | SCR-090～094, 096～099 |

## 4.3 3. テーブル詳細

### 4.3.1 3.1 service\_operators(運営者アカウント)

#### 4.3.1.1 DDL(詳細設計書 行 3660-3682)

-- 運営者アカウント (1 自然人 1 アカウント、FR-220)

```
CREATE TABLE service_operators (
  id TEXT PRIMARY KEY, -- ULID
  email TEXT NOT NULL UNIQUE,
  password_hash TEXT NOT NULL, -- Argon2id m=128MB t=4 p=4(運営者強化プロファイ
  display_name TEXT NOT NULL,
  status TEXT NOT NULL DEFAULT 'invited', -- invited / active / disabled
  failed_login_count INTEGER NOT NULL DEFAULT 0,
  locked_until TEXT, -- ロックアウト解除時刻 (5 回失敗 → 15 分)
  last_login_at TEXT,
  invited_by TEXT, -- 招待した運営者 ID
  invited_at TEXT NOT NULL,
  activated_at TEXT,
  disabled_at TEXT,
  disabled_reason TEXT,
  created_at TEXT NOT NULL,
  updated_at TEXT NOT NULL,
  CHECK (status IN ('invited', 'active', 'disabled')),
  FOREIGN KEY (invited_by) REFERENCES service_operators(id)
);
CREATE INDEX idx_service_operators_status ON service_operators(status);
CREATE INDEX idx_service_operators_email ON service_operators(email);
```

#### 4.3.1.2 コード値: status

| 値        | 説明                            |
|----------|-------------------------------|
| invited  | 招待中(初回パスワード未設定 + MFA 未セットアップ) |
| active   | 有効                            |
| disabled | 無効化(退職等)                      |

### 4.3.2 3.2 operator\_sessions(運営者セッション)

#### 4.3.2.1 DDL(行 3688-3704)

-- 運営者セッション (D-18 TTL 8h、MFA 必須)

```
CREATE TABLE operator_sessions (
  id TEXT PRIMARY KEY, -- ULID
  operator_id TEXT NOT NULL,
  token_hash TEXT NOT NULL UNIQUE, -- セッショントークンの SHA-256
  csrf_token TEXT NOT NULL, -- CSRF 用ランダム
  ip_address TEXT, -- IP マスク前 (必要時のみ参照)
  user_agent TEXT,
  mfa_verified_at TEXT, -- MFA 完了時刻
  reauthenticated_at TEXT, -- 直近の再認証時刻 (5 分以内チェック用)
  expires_at TEXT NOT NULL, -- created_at + 8h
  revoked_at TEXT,
```

```

    created_at          TEXT NOT NULL,
    FOREIGN KEY (operator_id) REFERENCES service_operators(id)
);
CREATE INDEX idx_operator_sessions_operator ON operator_sessions(operator_id);
CREATE INDEX idx_operator_sessions_expires ON operator_sessions(expires_at);

```

### 4.3.3 3.3 operator\_mfa\_secrets(TOTP シークレット)

#### 4.3.3.1 DDL(行 3710-3720)

-- TOTP シークレット (AES-256-GCM 暗号化保存)

```

CREATE TABLE operator_mfa_secrets (
    operator_id          TEXT PRIMARY KEY,
    secret_encrypted     TEXT NOT NULL,           -- AES-256-GCM 暗号化済
    secret_iv            TEXT NOT NULL,          -- AES-GCM IV
    algorithm            TEXT NOT NULL DEFAULT 'totp-sha1-6-30',
    setup_completed_at   TEXT,
    created_at           TEXT NOT NULL,
    updated_at           TEXT NOT NULL,
    FOREIGN KEY (operator_id) REFERENCES service_operators(id)
);

```

### 4.3.4 3.4 operator\_mfa\_recovery\_codes(MFA 回復コード)

#### 4.3.4.1 DDL(行 3726-3735)

-- MFA 回復コード (10 個、1 回限り)

```

CREATE TABLE operator_mfa_recovery_codes (
    id                   TEXT PRIMARY KEY,
    operator_id          TEXT NOT NULL,
    code_hash            TEXT NOT NULL,          -- Argon2id ハッシュ
    used_at              TEXT,
    created_at           TEXT NOT NULL,
    FOREIGN KEY (operator_id) REFERENCES service_operators(id)
);
CREATE INDEX idx_recovery_codes_operator ON operator_mfa_recovery_codes(operator_id, used_at);

```

### 4.3.5 3.5 operator\_ip\_allowlist(IP 許可リスト、共有概念正本)

#### 4.3.5.1 DDL(行 3741-3753)

-- 運営者別 IP 許可リスト (エッジで参照、KV キャッシュ TTL 60s)

```

CREATE TABLE operator_ip_allowlist (
    id                   TEXT PRIMARY KEY,
    operator_id          TEXT NOT NULL,
    cidr                 TEXT NOT NULL,          -- IPv4/IPv6 CIDR
    description          TEXT,
    granted_at           TEXT NOT NULL,
    granted_by           TEXT NOT NULL,
    revoked_at           TEXT,
    FOREIGN KEY (operator_id) REFERENCES service_operators(id),
    FOREIGN KEY (granted_by) REFERENCES service_operators(id)
);
CREATE INDEX idx_ip_allowlist_operator ON operator_ip_allowlist(operator_id, revoked_at);

```

### 4.3.6 3.6 operator\_approvals(4-eyes 申請・承認、共有概念正本)

#### 4.3.6.1 DDL(行 3763-3800)

-- 4-eyes 申請・承認レコード

```

CREATE TABLE operator_approvals (
    id                   TEXT PRIMARY KEY,          -- ULID
    action_code          TEXT NOT NULL,             -- 'owner.physical_delete' 等

```

```

state                TEXT NOT NULL DEFAULT 'requested',
                                -- requested / reviewing / approved / rejected
requested_by         TEXT NOT NULL,
approved_by          TEXT,
rejected_by          TEXT,
withdrawn_by         TEXT,
payload_hash         TEXT NOT NULL,
payload_json         TEXT NOT NULL,
payload_preview      TEXT,
reason              TEXT NOT NULL,
comment             TEXT,
requested_at         TEXT NOT NULL,
reviewing_at        TEXT,
approved_at         TEXT,
rejected_at         TEXT,
withdrawn_at        TEXT,
executed_at         TEXT,
expired_at          TEXT,
expires_at          TEXT NOT NULL,
                                -- requested_at + 72h
CHECK (state IN ('requested','reviewing','approved','rejected','withdrawn','executed','expired',
-- 自己承認禁止
CHECK (requested_by IS NULL OR approved_by IS NULL OR requested_by != approved_by),
-- 自己却下禁止
CHECK (requested_by IS NULL OR rejected_by IS NULL OR requested_by != rejected_by),
-- 撤回者は申請者本人のみ
CHECK (withdrawn_by IS NULL OR withdrawn_by = requested_by),
FOREIGN KEY (requested_by) REFERENCES service_operators(id),
FOREIGN KEY (approved_by) REFERENCES service_operators(id),
FOREIGN KEY (withdrawn_by) REFERENCES service_operators(id),
FOREIGN KEY (rejected_by) REFERENCES service_operators(id)
);
CREATE INDEX idx_approvals_state_expires ON operator_approvals(state, expires_at);
CREATE INDEX idx_approvals_action ON operator_approvals(action_code, state);
CREATE INDEX idx_approvals_requested_by ON operator_approvals(requested_by, requested_at);

```

#### 4.3.6.2 設計判断 (共有概念正本)

- ・ 自己承認禁止: DB CHECK 制約 + アプリ層の二重チェック
- ・ payload\_hash 改ざん検知: 承認時 / 実行時に payload\_json を再 hash して検証
- ・ 承認 TTL 72h: expires\_at = requested\_at + 72h(承認後の実行も 72h 以内)
- ・ 訂正履歴: 同一 action\_code を 2 回申請する場合は別レコード (reject 後の再申請)

詳細フローは 09\_認証認可設計書.md §7 を正本とする。

#### 4.3.6.3 コード値: state(状態遷移は §8.1 参照)

#### 4.3.7 3.7 audit\_logs(監査ログ、ハッシュチェーン構造の正本)

##### 4.3.7.1 DDL(行 3806-3834)

-- 監査ログ (ハッシュチェーン、3 区分保持)

```

CREATE TABLE audit_logs (
    id                TEXT PRIMARY KEY,
                                -- ULID
    prev_hash         TEXT NOT NULL,
                                -- 前レコードの record_hash(初行は 0x00...32B)
    record_hash       TEXT NOT NULL,
                                -- SHA-256(prev_hash || canonical_json(other
    actor_id          TEXT,
                                -- service_operator / account / system / NULL
    actor_type        TEXT NOT NULL,
                                -- service_operator / admin / end_user / syst
    action            TEXT NOT NULL,
                                -- <resource>.<verb>(詳細設計 §15 参照)
    target_id         TEXT,
    target_type       TEXT,
    owner_account_id  TEXT,
                                -- 横断操作は NULL 可

```



```

before_value      TEXT,                                -- JSON 差分
after_value       TEXT,                                -- JSON 差分
ip_masked         TEXT,                                -- IPv4: 末オクテット 0 / IPv6: 末 80b 0
ticket_id         TEXT,                                -- 対応チケット (FR-231)
approval_id       TEXT,                                -- 4-eyes 承認 ID(該当時)
occurred_at       TEXT NOT NULL,
retention_class   TEXT NOT NULL,                        -- general / billing / operator_high_priv($2.
CHECK (actor_type IN ('service_operator', 'admin', 'end_user', 'system')),
CHECK (retention_class IN ('general', 'billing', 'operator_high_priv')),
FOREIGN KEY (approval_id) REFERENCES operator_approvals(id)
);
CREATE INDEX idx_audit_actor      ON audit_logs(actor_id, occurred_at);
CREATE INDEX idx_audit_target    ON audit_logs(target_id, occurred_at);
CREATE INDEX idx_audit_action    ON audit_logs(action, occurred_at);
CREATE INDEX idx_audit_owner     ON audit_logs(owner_account_id, occurred_at);
CREATE INDEX idx_audit_retention ON audit_logs(retention_class, occurred_at);
CREATE INDEX idx_audit_ticket    ON audit_logs(ticket_id);

```

#### 4.3.7.2 ハッシュチェーン設計 (D-04、共有概念正本 = 運営者側)

- ・ 計算式: record\_hash = SHA-256(prev\_hash || canonical\_json(他全フィールド))
- ・ 初行: prev\_hash = 0x00...(32 バイト)
- ・ 検証バッチ: AuditChainVerifierWorker(日次 02:00 JST、全件再計算)
- ・ 不一致検出時: 運営者 inbox(system/high)+メール+検証実行ログ記録 (retention\_class=5y)
- ・ 鍵管理: 単一 (Cloudflare Secret Store)、年次ローテーション、ローテーション中は 60 日 dual-decrypt

4.3.7.3 tombstone 方式 保持期間経過後、本文 (actor/target/IP/payload) を物理削除しつつ id / prev\_hash / record\_hash / deleted\_at を保持 (チェーン破断防止)。tombstone 自体は削除しない。

#### 4.3.8 3.8 webhook\_events(Stripe Webhook 受信、共有概念正本)

##### 4.3.8.1 DDL(行 3840-3864)

-- Stripe Webhook 受信ログ (event\_id 幕等、D-06, D-10)

```

CREATE TABLE webhook_events (
  event_id      TEXT PRIMARY KEY,                    -- Stripe evt_* をそのまま
  event_type    TEXT NOT NULL,                       -- 'invoice.paid' 等
  payload_hash  TEXT NOT NULL,                       -- sha256(canonical(payload))
  payload_size_bytes INTEGER NOT NULL,
  received_at   TEXT NOT NULL,
  state         TEXT NOT NULL DEFAULT 'received',    -- 12 状態 (下記 CHECK 制約参照)

  last_transition_at TEXT NOT NULL,
  attempt_count  INTEGER NOT NULL DEFAULT 0,
  next_retry_at  TEXT,
  dlq_path       TEXT,                                -- R2 退避パス
  owner_account_id TEXT,                              -- 関連契約 (イベント種別による)
  stripe_api_version TEXT,                            -- '2024-06-20' 等
  CHECK (state IN ('received', 'verifying_signature', 'rejected', 'checking_idempotency',
                  'processing', 'succeeded', 'failed', 'dlq_retrying', 'dlq_manual_replay',
                  'dlq_archived', 'duplicate_skipped_hash_match', 'duplicate_diff_detected_high_
);
CREATE INDEX idx_webhook_events_state_received ON webhook_events(state, received_at);
CREATE INDEX idx_webhook_events_owner         ON webhook_events(owner_account_id, received_at);
CREATE INDEX idx_webhook_events_next_retry    ON webhook_events(next_retry_at) WHERE next_retr

```

##### 4.3.8.2 コード値: state(状態遷移は §8.2 参照)

#### 4.3.9 3.9 webhook\_payload\_diffs(Webhook ペイロード差分検出)

##### 4.3.9.1 DDL(行 3870-3888)

-- ペイロード差分検出履歴 (同 `event_id + payload_hash` 不一致)

```
CREATE TABLE webhook_payload_diffs (
  id TEXT PRIMARY KEY,
  event_id TEXT NOT NULL,
  original_payload_hash TEXT NOT NULL,
  new_payload_hash TEXT NOT NULL,
  diff_summary TEXT NOT NULL,
  state TEXT NOT NULL DEFAULT 'detected',
  detected_at TEXT NOT NULL,
  reviewed_at TEXT,
  reviewed_by TEXT,
  decided_at TEXT,
  decision_reason TEXT,
  CHECK (state IN ('detected', 'reviewed', 'reprocessed_manually', 'dismissed_no_action')),
  FOREIGN KEY (event_id) REFERENCES webhook_events(event_id),
  FOREIGN KEY (reviewed_by) REFERENCES service_operators(id)
);
CREATE INDEX idx_diffs_state_detected ON webhook_payload_diffs(state, detected_at);
```

#### 4.3.10 3.10 dlq\_replay\_log(DLQ リプレイ履歴)

##### 4.3.10.1 DDL(行 3894-3907)

-- DLQ リプレイ履歴

```
CREATE TABLE dlq_replay_log (
  id TEXT PRIMARY KEY,
  event_id TEXT NOT NULL,
  replay_type TEXT NOT NULL,
  attempted_at TEXT NOT NULL,
  attempted_by TEXT,
  result TEXT NOT NULL,
  error_detail TEXT,
  ticket_id TEXT,
  FOREIGN KEY (event_id) REFERENCES webhook_events(event_id),
  FOREIGN KEY (attempted_by) REFERENCES service_operators(id)
);
CREATE INDEX idx_replay_event ON dlq_replay_log(event_id, attempted_at);
```

#### 4.3.11 3.11 pii\_false\_positive\_reports(PII 誤検出報告)

##### 4.3.11.1 DDL(行 3934-3959)

-- PII 誤検出報告

```
CREATE TABLE pii_false_positive_reports (
  id TEXT PRIMARY KEY,
  reporter_type TEXT NOT NULL,
  reporter_id TEXT,
  owner_account_id TEXT,
  detection_layer TEXT NOT NULL,
  detected_text_masked TEXT NOT NULL,
  context_excerpt TEXT,
  state TEXT NOT NULL DEFAULT 'reported',
  reported_at TEXT NOT NULL,
  review_started_at TEXT,
  review_due_at TEXT,
  reviewed_by TEXT,
  ruled_at TEXT,
  rule_revision_id TEXT,
  archived_at TEXT,
  CHECK (state IN ('reported', 'under_review', 'ruled_false_positive', 'ruled_correct_detection', 'rule_updated', 'rule_deleted')),
  FOREIGN KEY (reporter_id) REFERENCES service_operators(id),
  FOREIGN KEY (owner_account_id) REFERENCES users(id),
  FOREIGN KEY (reviewed_by) REFERENCES service_operators(id),
  FOREIGN KEY (rule_revision_id) REFERENCES rules(revision_id)
);
```

```

CHECK (detection_layer IN ('layer_1','layer_2','layer_3')),
FOREIGN KEY (reviewed_by) REFERENCES service_operators(id),
FOREIGN KEY (rule_revision_id) REFERENCES pii_rules_revisions(id)
);
CREATE INDEX idx_pii_state_reported ON pii_false_positive_reports(state, reported_at);
CREATE INDEX idx_pii_review_due ON pii_false_positive_reports(state, review_due_at) WHERE s

```

注: pii\_rules\_revisions テーブルは詳細設計内に別途定義(本書一覧外)。必要に応じて本書追加を検討。

#### 4.3.12 3.12 announcement\_drafts(お知らせ下書き)

##### 4.3.12.1 DDL(行 4015-4048)

-- お知らせ下書き・配信予約 (D-09)

```

CREATE TABLE announcement_drafts (
  id TEXT PRIMARY KEY,
  kind TEXT NOT NULL, -- 'announcement' / 'system'
  severity TEXT NOT NULL, -- 'low' / 'normal' / 'high'
  scope_type TEXT NOT NULL, -- 'all' / 'owners' / 'user_types'
  scope_targets_json TEXT, -- owners の場合 [owner_account_id, ...]
  subject TEXT NOT NULL,
  body_html_sanitized TEXT NOT NULL, -- 永続化前サニタイズ後
  opt_out TEXT NOT NULL DEFAULT 'optional', -- 'optional' / 'mandatory'
  scheduled_at TEXT,
  state TEXT NOT NULL DEFAULT 'draft', -- draft / preview / scheduled / sending / se

  attempt_count INTEGER NOT NULL DEFAULT 0,
  next_retry_at TEXT,
  created_by TEXT NOT NULL,
  created_at TEXT NOT NULL,
  updated_at TEXT NOT NULL,
  cancelled_at TEXT,
  sent_at TEXT,
  failed_at TEXT,
  failed_reason TEXT,
  dlq_at TEXT,
  correction_of TEXT, -- 訂正告知元 ID
  CHECK (state IN ('draft','preview','scheduled','sending','sent','failed','cancelled','dlq')),
  CHECK (kind IN ('announcement','system')),
  CHECK (severity IN ('low','normal','high')),
  CHECK (opt_out IN ('optional','mandatory')),
  FOREIGN KEY (created_by) REFERENCES service_operators(id),
  FOREIGN KEY (correction_of) REFERENCES announcement_drafts(id)
);
CREATE INDEX idx_ann_state_scheduled ON announcement_drafts(state, scheduled_at);
CREATE INDEX idx_ann_created_by ON announcement_drafts(created_by, created_at);

```

重要度の正本: 本テーブルの severity(low/normal/high) は内部運用用。利用者向けには [メイン側メッセージ一覧 §2.4](#) の通知重要度 4 値(low/normal/high/critical) と対応付ける(critical は別建ての緊急通知パスで管理)。

#### 4.3.13 3.13 accounts\_retired(物理削除契約証跡、永久保持)

##### 4.3.13.1 DDL(行 3988-3998)

-- 物理削除済契約識別子の永久保持 (NFR-707、slug 再利用防止)

```

CREATE TABLE accounts_retired (
  owner_account_id TEXT PRIMARY KEY, -- 旧 accounts.id
  slug TEXT NOT NULL UNIQUE, -- 旧 accounts.slug
  retired_at TEXT NOT NULL,
  reason TEXT NOT NULL, -- 物理削除理由 (運営者入力)
  operator_id TEXT NOT NULL,

```

```

    ticket_id          TEXT,
    FOREIGN KEY (operator_id) REFERENCES service_operators(id)
);
CREATE INDEX idx_retired_retired_at ON accounts_retired(retired_at);

```

#### 4.3.13.2 設計判断

- ・ 永久保持 (RetentionPurgeWorker 対象外)
- ・ slug 再利用防止が主目的: accounts.id および accounts.slug の UNIQUE 制約に WHERE 句を含めない (NFR-707)
- ・ 物理削除実行時に必ず本テーブルへ INSERT。audit\_logs.action = owner.physical\_delete(retention\_class=7y) と一対

#### 4.3.14 3.14 owner\_registration\_reviews(契約登録審査)

##### 4.3.14.1 詳細設計内 DDL は未収載 —— 基本設計のみ言及

| 項目        | 内容                                                                                                                                                                                 |
|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 用途        | EU / EEA / UK 契約の GDPR 越境移転規制対応、登録審査状態管理                                                                                                                                           |
| 主管 FR     | NFR-402                                                                                                                                                                            |
| 想定スキーマ    | id / owner_account_id / region(eu / eea / uk / jp 等) / state(pending / under_review / approved / rejected) / consent_document_url / reviewer_id(4-eyes) / reviewed_at / created_at |
| 4-eyes 種別 | 承認ログ (action: owner.legal_review.record、retention_class=7y)                                                                                                                        |

未決事項 No.1: 詳細設計に DDL がいないため、詳細設計で正式定義する。

#### 4.3.15 3.15 rate\_limit\_overrides(契約別レート上書き)

##### 4.3.15.1 詳細設計内 DDL は未収載 —— 基本設計のみ言及

| 項目     | 内容                                                                                                 |
|--------|----------------------------------------------------------------------------------------------------|
| 用途     | 契約別レート制限の運営者上書き (SCR-093 経由、4-eyes 承認ログ)                                                           |
| 主管 FR  | FR-121, FR-128, FR-224(b)                                                                          |
| 想定スキーマ | id / owner_account_id / endpoint_kind / rps / rpm / valid_until / reason / created_by / created_at |
| KV ミラー | TTL 60s。エッジで参照                                                                                     |

メイン側との関係: メイン側では owner\_quota\_overrides テーブルで rate\_limit / budget / quota を resource\_kind で区別して統一実装 (行 6337-6350)。運営者側基本設計では rate\_limit\_overrides / budget\_limit\_overrides を別テーブルとして言及するが、DDL 未収載のため、実装はメイン側統一テーブルに準拠を方針とする (詳細設計で最終確定)。

#### 4.3.16 3.16 ai\_parameter\_overrides(AI パラメータ 3 階層上書き)

##### 4.3.16.1 詳細設計内 DDL は未収載 —— 基本設計のみ言及

| 項目     | 内容                                                                                                                                                    |
|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| 用途     | AI 推論パラメータの 3 階層 (global / owner / project) 上書き (SCR-092、4-eyes ハードゲート)                                                                               |
| 主管 FR  | FR-055, FR-061                                                                                                                                        |
| 想定スキーマ | id / scope(global / owner / project) / owner_account_id / project_id / confidence_threshold / relevance_threshold / version / created_by / created_at |

メイン側との関係: メイン側 ai\_threshold\_persistent\_cache (行 6323-6335) が AI しきい値の永続キャッシュ。本テーブルは運営者上書きの原典で、IF #6 経由でメイン側へ反映される。

#### 4.3.17 3.17 budget\_limit\_overrides(契約別予算上限)

§ 3.15 と同様、詳細設計内 DDL 未収載。

| 項目    | 内容                                  |
|-------|-------------------------------------|
| 用途    | 月次予算上限の運営者上書き (SCR-093、4-eyes 承認ログ) |
| 主管 FR | FR-121(c)                           |

#### 4.3.18 3.18 billing\_invoices(月次請求書、運営者側主管)

メイン側 [billing\\_invoices](#) と同名・同物理テーブル。月次集計確定 cron(運営者側 § 11) で生成。

| 項目                 | 内容                 |
|--------------------|--------------------|
| 主管 FR              | FR-303, NFR-602(c) |
| 保持期間               | 7 年 (電子帳簿保存法対応)    |
| 関連 retention_class | 7y / billing       |

DDL はメイン側を参照。

#### 4.3.19 3.19 webhook\_replay\_requests(リプレイ要求受付)

##### 4.3.19.1 詳細設計内 DDL は未収載 —— 基本設計のみ言及

| 項目        | 内容                                                                                                    |
|-----------|-------------------------------------------------------------------------------------------------------|
| 用途        | SCR-097 からのリプレイ要求の受付 (dlq_replay_log と対になる申請レコード)                                                     |
| 主管 FR     | FR-302, NFR-809                                                                                       |
| 4-eyes 種別 | 承認ログ (action: webhook.replay、retention_class=5y)                                                      |
| 想定スキーマ    | id / event_id / requested_by / approval_id(operator_approvals.id) / executed_at / result / created_at |

### 4.4 4. ER 図 (運営者側、§7.2 から移管)

erDiagram

```

service_operators ||--o{ operator_sessions : has
service_operators ||--o{ operator_mfa_secrets : has
service_operators ||--o{ operator_mfa_recovery_codes : has
service_operators ||--o{ operator_ip_allowlist : grants
service_operators ||--o{ operator_approvals : "requests / approves / rejects / withdraws"
service_operators ||--o{ audit_logs : performs
operator_approvals ||--o{ audit_logs : audited
webhook_events ||--o{ webhook_payload_diffs : detects
webhook_events ||--o{ dlq_replay_log : replays
webhook_events ||--o{ webhook_replay_requests : requested
webhook_replay_requests }o--|| operator_approvals : approved_via
pii_false_positive_reports ||--|| service_operators : reviewed_by
announcement_drafts ||--|| service_operators : created_by
announcement_drafts ||--o| announcement_drafts : correction_of
rate_limit_overrides ||--|| service_operators : authored_by
ai_parameter_overrides ||--|| service_operators : authored_by
budget_limit_overrides ||--|| service_operators : authored_by
billing_invoices ||--o{ audit_logs : audited
accounts_retired ||--|| service_operators : retired_by
accounts_retired ||--o{ audit_logs : retains

```

### 4.5 5. テーブル間関連 (§2.2 と同期)

§ 2.2 「主要関係性」を参照。

### 4.6 6. 命名規則・型方針 (§7.9 から移管)

| 種別           | 規則                                            |
|--------------|-----------------------------------------------|
| テーブル名        | snake_case 複数形 (audit_logs、webhook_events)    |
| カラム名         | snake_case 単数形 (owner_account_id、occurred_at) |
| 状態列          | state、値は snake_case                           |
| 主キー          | UUID v4 / ULID / Stripe ID (evt_*, sub_*)     |
| タイムスタンプ      | UTC(TIMESTAMP)、表示時 JST 変換                     |
| KV キープレフィックス | <feature>:<scope>:<id>                        |
| KV キー命名      | コロン区切り、英小文字 + ハイフン                            |

## 4.7 7. SaaS データ分離観点 (運営者側固有)

### 4.7.1 7.1 運営者は全契約横断アクセス

運営者は **service\_operator** ロールで全契約のリソースを参照・操作可能 (オーナー境界判定を適用しない)。代わりに以下の多段ガードを適用:

1. IP allowlist (**operator\_ip\_allowlist**、§ 3.5)
2. MFA (**operator\_mfa\_\***、§ 3.3 / 3.4)
3. 再認証 (5 分以内、**operator\_sessions.reauthenticated\_at**、§ 3.2)
4. ロール検証 (**service\_operator**)
5. 4-eyes 承認 (10 操作、**operator\_approvals**、§ 3.6)
6. 監査ログ全件 (**audit\_logs**、§ 3.7)

### 4.7.2 7.2 監査ログの完全性

- ・全運営者操作 + 全 4-eyes 承認 + 全 API 呼び出しを **audit\_logs** に記録
- ・ハッシュチェーン構造 (D-04) + 日次完全性検証バッチ (**AuditChainVerifierWorker** 02:00 JST)
- ・監査ログの削除は禁止 (保持期間経過時のみ tombstone 処理、削除事実を残す)

詳細は [10\\_セキュリティ設計書.md §7](#) を正本とする。

## 4.8 8. 状態コード値・状態遷移 (§4 + 付録 B から移管)

### 4.8.1 8.1 4-eyes 申請・承認状態 (**operator\_approvals.state**、付録 B.3)

| From      | To        | トリガー        | 制約                                             |
|-----------|-----------|-------------|------------------------------------------------|
| (新規)      | requested | 運営者申請       | requested_at=now、expires_at=requested_at + 72h |
| requested | reviewing | 別運営者の確認開始   | -                                              |
| requested | expired   | 72h 経過      | 自動                                             |
| requested | withdrawn | 申請者自己取下げ    | withdrawn_by = requested_by                    |
| reviewing | approved  | 別運営者承認      | requested_by != approved_by                    |
| reviewing | rejected  | 別運営者却下      | requested_by != rejected_by                    |
| reviewing | withdrawn | 申請者自己取下げ    | 同上                                             |
| reviewing | expired   | 72h 経過      | 自動                                             |
| approved  | executed  | 申請者実行       | payload_hash 再検証一致必須                           |
| approved  | expired   | 承認後 72h 未実行 | 自動                                             |

### 4.8.2 8.2 Webhook イベント状態遷移 (**webhook\_events.state**、付録 B.2)

| From                 | To                           | トリガー           | 副作用            |
|----------------------|------------------------------|----------------|----------------|
| (新規)                 | received                     | Stripe POST 受信 | -              |
| received             | verifying_signature          | 署名検証開始         | -              |
| verifying_signature  | rejected                     | 署名 NG          | 401 + 運営者 high |
| verifying_signature  | checking_idempotency         | 署名 OK          | -              |
| checking_idempotency | processing                   | event_id 未処理   | INSERT         |
| checking_idempotency | duplicate_skipped_hash_match | 既処理 + ハッシュ一致   | 200 OK + ログ    |

| From                 | To                                 | トリガー              | 副作用                     |
|----------------------|------------------------------------|-------------------|-------------------------|
| checking_idempotency | duplicate_diff_detected_high_alert | 既処理 + ハッシュ不一致     | 200 OK + SCR-099 + high |
| processing           | succeeded                          | 内部転送成功            | -                       |
| processing           | failed                             | 5xx / Timeout 30s | DLQ 投入                  |
| failed               | dlq_retrying                       | 1時間自動指数 BO        | -                       |
| dlq_retrying         | succeeded                          | 再試行成功             | -                       |
| dlq_retrying         | dlq_manual_replay                  | 1時間経過             | SCR-097 待ち              |
| dlq_manual_replay    | succeeded                          | 運営者リプレイ成功         | -                       |
| dlq_manual_replay    | dlq_archived                       | 30 日経過            | R2 退避                   |

#### 4.8.3 8.3 お知らせ下書き状態 (announcement\_drafts.state、付録 B.4)

| From      | To        | トリガー                    |
|-----------|-----------|-------------------------|
| (新規)      | draft     | SCR-094 新規作成            |
| draft     | preview   | プレビュー表示                 |
| preview   | draft     | 編集に戻る                   |
| preview   | scheduled | 配信予約確定                  |
| preview   | sending   | 即時配信実行                  |
| scheduled | sending   | scheduled_at 到達         |
| scheduled | cancelled | scheduled_at - 5 分 まで取消 |
| sending   | sent      | IF #7 成功                |
| sending   | failed    | IF #7 失敗                |
| failed    | sending   | 自動 BO 再試(1m → 4m → 16m) |
| failed    | dlq       | 自動 BO 3 回失敗 → 永久失敗      |

#### 4.8.4 8.4 PII 誤検出報告状態 (pii\_false\_positive\_reports.state、付録 B.5)

| From                    | To                      | トリガー                |
|-------------------------|-------------------------|---------------------|
| (新規)                    | reported                | 報告元送信               |
| reported                | under_review            | 運営者確認開始 (3 営業日タイマー) |
| under_review            | ruled_false_positive    | 誤検出判定               |
| under_review            | ruled_correct_detection | 正検出判定               |
| ruled_false_positive    | rule_updated            | KV ルール更新完了          |
| rule_updated            | archived                | 終了                  |
| ruled_correct_detection | archived                | 終了                  |

#### 4.8.5 8.5 Webhook 差分状態 (webhook\_payload\_diffs.state、付録 B.6)

| From     | To                   | トリガー                    |
|----------|----------------------|-------------------------|
| (新規)     | detected             | BillingWebhookWorker 検出 |
| detected | reviewed             | 運営者 SCR-099 確認          |
| reviewed | reprocessed_manually | SCR-097 手動再処理           |
| reviewed | dismissed_no_action  | 無視可判断                   |

#### 4.8.6 8.6 契約状態 (accounts.contract\_status(オーナー行)、付録 B.7)

メイン側 [テーブル定義書 § 8.5](#) を参照。運営者側責務は IF #1 経由の遷移トリガーとサスペンション解除(4-eyes 承認)。



## 4.9 9. 監査ログ action コード × retention\_class 割当表 (付録 F 全件、共有概念正本)

### 4.9.1 9.1 1y(業務監査)

faq.create / faq.update / faq.publish / faq.delete / project.create / project.update / project.delete / chat.reply / chat.close / chat.reopen / unresolved.assign / unresolved.close / account.login / account.logout / account.password\_change / inbox.read / inbox.read.bulk / widget.config.update / apikey.rotate(利用者側)

### 4.9.2 9.2 5y(運営者高権限)

owner.suspend / owner.restore / owner.physical\_delete(※ 物理削除のみ 7y に格上げ) / ai\_parameter.update / ai\_model.switch / rate\_limit.override / budget\_limit.override / announcement.send / operator.invite / operator.disable / operator.mfa\_reset / operator.password\_reset / operator\_approval.request / operator\_approval.approve / operator\_approval.reject / operator\_approval.execute / webhook.replay / webhook.payload\_diff.\* / pii\_rule.update / audit.export / prod.direct\_change / master\_key.rotate

### 4.9.3 9.3 7y(課金・取引)

billing.invoice.issued / billing.credit\_note.issued / billing.cron.run / stripe.event.processed / stripe.event.replayed / owner.physical\_delete(契約物理削除は 5y ではなく 7y 扱い) / owner.legal\_review.record

## 4.10 10. インデックス方針 (§7.10 から移管)

| テーブル                       | インデックス                                                                                                                                               | 用途                   |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| webhook_events             | (state, received_at), (owner_account_id, received_at), next_retry_at(WHERE NOT NULL)                                                                 | DLQ 監視 / リプレイ検索      |
| audit_logs                 | (actor_id, occurred_at), (target_id, occurred_at), (action, occurred_at), (owner_account_id, occurred_at), (retention_class, occurred_at), ticket_id | SCR-096 検索 / 保持区分別削除 |
| pii_false_positive_reports | (state, reported_at), (state, review_due_at) WHERE state='under_review'                                                                              | 3 営業日判定              |
| operator_approvals         | (state, expires_at), (action_code, state), (requested_by, requested_at)                                                                              | 承認待ち TTL 監視          |
| announcement_drafts        | (state, scheduled_at), (created_by, created_at)                                                                                                      | 1 分ポーリング             |
| billing_invoices           | (owner_account_id, billing_year_month) UNIQUE                                                                                                        | 冪等性                  |

## 4.11 11. データ削除モード (運営者側固有)

- **accounts\_retired** は **永久保持** (GDPR 越境移転対応 / 契約物理削除の証跡)
- **audit\_logs** は保持期間経過後 **tombstone 処理** (削除事実を残す)
- **operator\_\*** は退職処理時に物理削除 (MFA は即時削除)
- **webhook\_events** は 7 年保持後に物理削除 (R2 archive 経由)

## 4.12 12. 未決事項

| No | 内容                                                                               | 確認先                    | ステータス                                 |
|----|----------------------------------------------------------------------------------|------------------------|---------------------------------------|
| 1  | owner_registration_reviews の DDL 未収載 (基本設計のみ言及)                                  | 02_運営者システム/03_詳細設計書.md | 補正待ち                                  |
| 2  | rate_limit_overrides / budget_limit_overrides / ai_parameter_overrides の DDL 未収載 | 02_運営者システム/03_詳細設計書.md | メイン側 owner_quota_overrides 統一実装に準拠の方針 |
| 3  | webhook_replay_requests の DDL 未収載 (基本設計のみ言及)                                     | 02_運営者システム/03_詳細設計書.md | 補正待ち                                  |
| 4  | pii_rules_revisions テーブル (pii_false_positive_reports.rule_revision_id FK 先)      | 02_運営者システム/03_詳細設計書.md | 別途定義の有無を確認                            |
| 5  | announcement_drafts.severity(low / normal / high) と通知重要度 4 値 (critical 含む) の対応   | メッセージ一覧 07 § 2.4       | critical 通知は別建てパスで対応済                 |



### 4.13 13. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

## 5 権限設計書 (運営者)

### 5.1 1. 文書概要

#### 5.1.1 1.1 目的

運営者システムの権限モデルを一元化する。単一ロール **service\_operator** + **4-eyes 対象 10 操作** (ハードゲート 3 + 承認ログ 7) を中心に、画面別・API 別の操作可否を定義する。

#### 5.1.2 1.2 対象範囲

- 対象: 運営者ロール (**service\_operator**)、4-eyes 対象 10 操作、画面別・API 別権限
- 対象外: 認可判定フロー ([09\\_ 認証認可設計書.md](#) が正本)、利用者ロール ([01\\_ メインシステム/個別設計書群/05\\_ 権限設計書.md](#) 参照)

#### 5.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

#### 5.1.4 1.4 関連ドキュメント

| ドキュメント名    | 役割                          | 参照先                                |
|------------|-----------------------------|------------------------------------|
| 索引         | 11 ドキュメント体系の俯瞰              | 00_ 索引.md                          |
| 認証・認可設計書   | 6 段認可判定 / 4-eyes 承認フロー (正本) | 09_ 認証認可設計書.md                     |
| 画面設計書      | 画面別表示制御 / 4-eyes UI         | 02_ 画面設計書.md                       |
| API 設計書    | API 別権限 / X-Approval-Id ヘッダ | 03_ API 設計書.md                     |
| エラー設計書     | 権限不足 / 4-eyes 未承認時のエラー      | 06_ エラー設計書.md                      |
| テーブル定義書    | operator_approvals 物理スキーマ   | 04_ テーブル定義書.md                     |
| メイン側 権限設計書 | 利用者ロール / 契約上書き              | ../01_ メインシステム/個別設計書群/05_ 権限設計書.md |

### 5.2 2. ロール一覧

(§3.1 から移管)

| ロール ID           | ロール名 | 概要                        | 利用者   | 範囲              |
|------------------|------|---------------------------|-------|-----------------|
| service_operator | 運営者  | 単一ロール、open-faq 運営事業者のメンバー | 運営事業者 | 全契約横断 (各種ガード適用) |

#### 5.2.1 2.1 単一ロール採用理由

MVP は単一 **service\_operator** ロールで運用。運営者は SCR-090~099 の運用機能を扱い、操作ごとの安全性は以下で担保:

1. IP allowlist (認証・認可設計書 09 §3)
2. MFA (09 §4)
3. 再認証 (5 分以内、09 §5)
4. 4-eyes 承認 (10 操作のみ、本書 §7)
5. 監査ログ全件 (セキュリティ設計書 10 §7)

## 5.2.2 2.2 ロール識別子

| 項目     | 内容                                     |
|--------|----------------------------------------|
| ロール識別子 | accounts.user_type='service_operator'  |
| 適用数    | 本 SaaS 提供者の自然人 1 名につき 1 アカウント (FR-220) |
| 認証要件   | MFA(TOTP) 必須、未設定時は全画面ログイン不可            |
| パスワード  | Argon2id 採用、運営者強化プロファイル (FR-221)       |
| セッション  | 初期値 8 時間 (D-18)                        |
| 自己リセット | 禁止。MFA / パスワード再設定は別運営者 + 組織内承認         |
| 発行・無効化 | 既存運営者またはブートストラップ管理者のみ                  |

## 5.3 3. 画面別権限

| 画面 ID                   | 画面名                | 全運営者            | 4-eyes 申請者 | 4-eyes 承認者 | 備考            |
|-------------------------|--------------------|-----------------|------------|------------|---------------|
| SCR-AUTH / SCR-AUTH-M1  | ログイン / MFA         | ○               | -          | -          | 認証フロー         |
| SCR-HOME                | ホーム                | ○               | -          | -          | KPI + 緊急アラート  |
| SCR-090                 | 削除データ参照            | ○(再認証必須)        | -          | -          | 参照のみ          |
| SCR-091                 | 削除データ復元            | -               | ○(申請)      | ○(承認)      | 4-eyes 承認ログ   |
| SCR-092                 | AI パラメータ設定 (本番)    | -               | ○(申請)      | ○(承認)      | 4-eyes ハードゲート |
| SCR-093                 | 契約別レート / 予算上書き     | -               | ○(申請)      | ○(承認)      | 4-eyes 承認ログ   |
| SCR-094                 | お知らせ作成・配信          | ○               | -          | -          | 即時配信のみ承認ログ    |
| SCR-096                 | 監査ダッシュボード          | ○(参照のみ)         | -          | -          | エクスポートは再認証    |
| SCR-097                 | Webhook リプレイ / DLQ | -               | ○(申請)      | ○(承認)      | 4-eyes 承認ログ   |
| SCR-098                 | PII 誤検出報告          | ○               | ○(ルール更新時)  | ○(ルール更新時)  | ルール更新は承認ログ    |
| SCR-099                 | Webhook 差分検出       | ○               | -          | -          | 手動再処理は再認証     |
| SCR-APPROVALS / M1 / M2 | 4-eyes 承認画面        | ○(申請者 / 承認者として) | ○          | ○          | 4-eyes 中核画面   |

## 5.4 4. 機能別権限

| 機能 ID             | 機能名              | 必要権限                                   | 4-eyes 種別 | 関連 SCR             |
|-------------------|------------------|----------------------------------------|-----------|--------------------|
| F-OP-AUTH-*       | 認証 / MFA / セッション | service_operator                       | -         | SCR-AUTH / AUTH-M1 |
| F-OP-DELETE-001   | 削除データ参照          | service_operator + 再認証                 | -         | SCR-090            |
| F-OP-DELETE-002   | 削除データ復元          | service_operator + 再認証 + 4-eyes 承認ログ   | 承認ログ      | SCR-091            |
| F-OP-AI-001       | AI パラメータ設定       | service_operator + 再認証 + 4-eyes ハードゲート | ハードゲート    | SCR-092            |
| F-OP-OVERRIDE-001 | 契約別上書き           | service_operator + 再認証 + 4-eyes 承認ログ   | 承認ログ      | SCR-093            |

| 機能 ID            | 機能名                           | 必要権限                                             | 4-eyes 種別   | 関連 SCR                  |
|------------------|-------------------------------|--------------------------------------------------|-------------|-------------------------|
| F-OP-NOTIF-001   | お知らせ作成・配信                     | service_operator + 再認証                           | 即時配信のみ承認ログ  | SCR-094                 |
| F-OP-AUDIT-001   | 監査ログ閲覧 / エクスポート               | service_operator(参照は不要、エクスポートは再認証)               | -           | SCR-096                 |
| F-OP-WEBHOOK-001 | Webhook リプレイ                  | service_operator + 再認証 + 4-eyes 承認ログ             | 承認ログ        | SCR-097                 |
| F-OP-PII-001     | PII 報告管理 / ルール更新              | service_operator + 再認証(更新時)+ 4-eyes 承認ログ(ルール更新時) | 承認ログ(ルール更新) | SCR-098                 |
| F-OP-WEBHOOK-002 | ペイロード差分検出                     | service_operator(手動再処理は再認証)                      | -           | SCR-099                 |
| F-OP-4EYES-*     | 4-eyes 承認(申請 / 承認 / 却下 / 取下げ) | service_operator(自己承認禁止)                         | -           | SCR-APPROVALS / M1 / M2 |

## 5.5 5. API 別権限

03\_API 設計書.md を正本とする。主要 API:

| API                                           | メソッド | 必要権限                                   | 4-eyes 種別 | 関連エラー ID                    |
|-----------------------------------------------|------|----------------------------------------|-----------|-----------------------------|
| POST /admin/v1/auth/login                     | POST | (IP allowlist のみ)                      | -         | E-OP-AUTH-*                 |
| POST /admin/v1/auth/mfa/verify                | POST | セッション                                  | -         | E-OP-MFA-*                  |
| POST /admin/v1/me/reauth                      | POST | セッション + MFA                            | -         | -                           |
| POST /admin/v1/approvals                      | POST | service_operator                       | 申請フロー     | E-OP-4EYES-*                |
| POST /admin/v1/approvals/{id}/approve         | POST | 別運営者(自己承認禁止)                           | 承認ハードゲート  | E-OP-4EYES-SELF             |
| POST /admin/v1/approvals/{id}/reject          | POST | 別運営者 + 再認証                             | -         | E-OP-4EYES-SELF             |
| POST /admin/v1/approvals/{id}/withdraw        | POST | 申請者本人のみ                                | -         | -                           |
| GET /admin/v1/deleted-resources               | GET  | service_operator                       | -         | -                           |
| POST /admin/v1/restorations                   | POST | service_operator + 再認証                 | 承認ログ      | E-OP-RESTORE-LOCKED         |
| PUT /admin/v1/ai-parameters/{scope}/{id}      | PUT  | service_operator + 再認証 + X-Approval-Id | ハードゲート    | E-OP-4EYES-HARDGATE         |
| PUT /admin/v1/overrides/rate-limit/{owner_id} | PUT  | service_operator + 再認証 + X-Approval-Id | 承認ログ      | -                           |
| PUT /admin/v1/overrides/budget/{owner_id}     | PUT  | service_operator + 再認証 + X-Approval-Id | 承認ログ      | -                           |
| POST /admin/v1/announcements                  | POST | service_operator + 再認証                 | -         | -                           |
| POST /admin/v1/announcements/{id}/schedule    | POST | service_operator + 再認証                 | -         | -                           |
| POST /admin/v1/announcements/{id}/send(即時)    | POST | service_operator + 再認証 + X-Approval-Id | 承認ログ      | -                           |
| GET /admin/v1/audit-logs                      | GET  | service_operator                       | -         | -                           |
| POST /admin/v1/audit-logs/exports             | POST | service_operator + 再認証                 | -         | -                           |
| POST /admin/v1/webhooks/replay                | POST | service_operator + 再認証 + X-Approval-Id | 承認ログ      | E-OP-WEBHOOK-REPLAY-EXPIRED |
| POST /admin/v1/pii-rules/revisions            | POST | service_operator + 再認証 + X-Approval-Id | 承認ログ      | -                           |

## 5.6 6. 緊急時のみ可操作

運営者は通常時に全契約横断アクセス可能だが、利用者側 Δ 緊急時のみ可 操作についてはメイン側 [権限設計書 §9](#) を参照。

## 5.7 7. 4-eyes 対象 10 操作 (本書の中核、付録 E から移管)

詳細フロー・承認モデルは [09\\_認証認可設計書.md §8](#) を正本とする。本書では一覧と画面・API・retention の対応を保持する。

### 5.7.1 7.1 ハードゲート 3 操作 (KV フラグが false なら API 拒否)

| # | 操作              | action code           | 対象 SCR     | API                                      | retention_class        | ticket_id 必須 |
|---|-----------------|-----------------------|------------|------------------------------------------|------------------------|--------------|
| 1 | 契約物理削除          | owner.physical_delete | SCR-091 派生 | DELETE /admin/v1/owners/{id}/physical    | 7y(billing)            | ○            |
| 2 | AI パラメータ変更 (本番) | ai_parameter.update   | SCR-092    | PUT /admin/v1/ai-parameters/{scope}/{id} | 5y(operator_high_priv) | ○            |
| 3 | マスター ローテーション    | master_key.rotate     | (運用 CLI)   | (CLI)                                    | 5y                     | ○            |

### 5.7.2 7.2 承認ログ 7 操作

| #  | 操作                         | action code                           | 対象 SCR     | API                                           | retention_class | ticket_id 必須 |
|----|----------------------------|---------------------------------------|------------|-----------------------------------------------|-----------------|--------------|
| 4  | 契約無効化 (active → suspended) | owner.suspend                         | SCR-091 派生 | POST /admin/v1/owners/{id}/suspend (IF #1 経由) | 5y              | ○            |
| 5  | 契約復元 (削除猶予中 → active)      | owner.restore                         | SCR-091 派生 | POST /admin/v1/owners/{id}/restore            | 5y              | ○            |
| 6  | 従量単価表・無料枠改定                | pricing.update                        | (運用 CLI)   | (CLI)                                         | 5y              | ○            |
| 7  | 契約別レート制限・予算上限の上書き          | rate_limit.override / budget.override | SCR-093    | PUT /admin/v1/overrides/*                     | 5y              | ○            |
| 8  | 緊急ウィジェット強制停止               | widget.force_stop                     | SCR-093 派生 | POST /admin/v1/widgets/{id}/force-stop        | 5y              | ○            |
| 9  | 削除データ復元 (FR-204)           | owner.restore_data                    | SCR-091    | POST /admin/v1/restorations                   | 5y              | ○            |
| 10 | ハードゲート KV フラグ切替            | feature.hard_gate.toggle              | (運用 CLI)   | (CLI)                                         | 5y              | ○            |

### 5.7.3 7.3 ハードゲート KV フラグの管理

KV キー: `feature:hard-gate:<action_code>`

- 対象 action コードは **実装定数 (コード内 const)** で管理
- 許可操作: **緊急一時無効化のみ** (true → false 一時切替)
- 発動条件: セキュリティインシデント + メイン要件 §6.2.2 の条件成立時
- フラグ変更操作は 4-eyes 承認ログ対象 (`feature.hard_gate.toggle`、`retention_class='5y'`)
- 誤操作で MVP 重大操作 (`owner.physical_delete`) が単独実行可能になるリスクを排除

### 5.7.4 7.4 自己承認禁止 / 自己却下禁止 / 取下げ規約

| ルール    | 内容                                               |
|--------|--------------------------------------------------|
| 自己承認禁止 | DB CHECK: requested_by != approved_by + アプリ層チェック |
| 自己却下禁止 | DB CHECK: requested_by != rejected_by + アプリ層チェック |

| ルール   | 内容                                   |
|-------|--------------------------------------|
| 取下げ規約 | 申請者本人 (requested_by) のみ可。別運営者の取下げは不可 |

詳細は 09\_ 認証認可設計書.md § 8 を正本とする。

## 5.8 8. 4-eyes 未承認・権限不足時の動作

| ケース                    | システム動作        | 画面表示                                        | メッセージ ID                     | 関連エラー ID                   |
|------------------------|---------------|---------------------------------------------|------------------------------|----------------------------|
| 4-eyes 未承認で操作実行        | 403 + 専用コード   | 「承認が必要な操作です。SCR-APPROVALS から申請してください」       | MSG-OP-4EYES-NOT-APPROVED    | E-OP-4EYES-REQUIRED        |
| 4-eyes ハードゲート KV false | 403 + 即時拒否    | 「現在この操作は無効化されています (運営側で有効化が必要)」             | MSG-OP-4EYES-HARDGATE-OFF    | E-OP-4EYES-HARDGATE        |
| 自己承認試行                 | 422 + 専用コード   | 「自分が申請した操作は承認できません」                         | MSG-OP-4EYES-SELF            | E-OP-4EYES-SELF            |
| 自己却下試行                 | 422 + 専用コード   | 「自分が申請した操作は却下できません」                         | MSG-OP-4EYES-SELF-REJECT     | E-OP-4EYES-SELF            |
| 承認 TTL 切れ (72h)        | 410 + 専用コード   | 「承認の有効期限が切れました。再申請してください」                   | MSG-OP-4EYES-EXPIRED         | E-OP-4EYES-EXPIRED         |
| 再認証期限切れ (5分以内)         | 403 + 再認証画面誘導 | 「再認証が必要です」                                  | MSG-OP-REAUTH-REQUIRED       | E-OP-REAUTH-REQUIRED       |
| IP allowlist 拒否        | 401(即時)       | (拒否画面なし、HTTP のみ)                            | -                            | E-OP-IP-DENIED             |
| payload_hash 改ざん検知     | 409 + 専用コード   | 「申請内容が変更されている可能性があります。最新の内容を確認してから承認してください」 | MSG-OP-4EYES-PAYLOAD-CHANGED | E-OP-4EYES-PAYLOAD-CHANGED |
| ticket_id 必須項目欠落       | 400 + 入力欄エラー  | 「操作チケット ID を入力してください」                       | MSG-OP-4EYES-TICKET-REQUIRED | E-OP-INPUT-TICKET-REQUIRED |

## 5.9 9. 運営者アカウント・ライフサイクル

| イベント                  | 実行可能者                        | 監査記録                                                  |
|-----------------------|------------------------------|-------------------------------------------------------|
| 発行 (account.invite)   | 既存運営者 (MVP は全員)/ ブートストラップ管理者 | audit_logs(retention_class=5y)、action=operator.invite |
| MFA 初回設定              | 本人 (初回 72h セットアップトークン経由)     | action=operator.mfa.setup                             |
| MFA リセット              | 別運営者 + 組織内承認                 | action=operator.mfa.reset                             |
| パスワード再設定              | 別運営者 + 組織内承認                 | action=operator.password.reset                        |
| 無効化 (account.disable) | 既存運営者                        | action=operator.disable                               |
| 再有効化 (account.enable) | 既存運営者                        | action=operator.enable                                |

## 5.10 10. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

## 5.11 11. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

## 6 エラー設計書 (運営者)

### 6.1 1. 文書概要

#### 6.1.1 1.1 目的

運営者システムで発生するすべてのエラーについて、分類 / 発生条件 / システム動作 / ユーザー表示 / 復旧方法 / ログレベルを一元化する。プレフィックスは **E-OP-\*** で、メイン側 **E-\*** と識別する。

#### 6.1.2 1.2 対象範囲

- 対象: 運営者向けエラー (認証 / MFA / 認可 / 4-eyes / IP allowlist / 再認証 / Webhook / 業務 / 連携 IF)
- 対象外: 利用者エラー (01\_メインシステム/個別設計書群/06\_エラー設計書.md 参照、プレフィックス E-\*)

#### 6.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

#### 6.1.4 1.4 関連ドキュメント

| ドキュメント名     | 役割                    | 参照先                               |
|-------------|-----------------------|-----------------------------------|
| 索引          | 11 ドキュメント体系の俯瞰        | 00_索引.md                          |
| API 設計書     | ステータスコードとの対応          | 03_API 設計書.md                     |
| メッセージ一覧     | エラー文言                 | 07_メッセージ一覧.md                     |
| 認証・認可設計書    | 6 段認可 / 4-eyes エラーの根拠 | 09_認証認可設計書.md                     |
| 権限設計書       | 4-eyes 対象 10 操作       | 05_権限設計書.md                       |
| セキュリティ設計書   | 監査・ログ                 | 10_セキュリティ設計書.md                   |
| メイン側 エラー設計書 | 利用者エラー                | ../01_メインシステム/個別設計書群/06_エラー設計書.md |

### 6.2 2. エラー分類

| エラー分類            | 概要         | プレフィックス       | 代表例                                                      |
|------------------|------------|---------------|----------------------------------------------------------|
| 認証エラー            | 認証失敗・期限切れ  | E-OP-AUTH-*   | パスワード不一致 / セッション期限切れ                                     |
| MFA エラー          | MFA 関連     | E-OP-MFA-*    | TOTP 失敗 / セットアップ期限切れ / 回復コード使用済み                         |
| IP allowlist エラー | IP 許可リスト拒否 | E-OP-IP-*     | 未許可 IP からのアクセス                                           |
| 再認証エラー           | 5 分以内再認証   | E-OP-REAUTH-* | 再認証期限切れ                                                  |
| 4-eyes エラー       | 4-eyes 関連  | E-OP-4EYES-*  | 未承認 / 自己承認 / ハードゲート KV false / TTL 切れ / payload_hash 改ざん |
| 認可エラー            | 権限不足       | E-OP-AUTHZ-*  | (運営者では稀、主に 4-eyes 未承認)                                   |
| 入力エラー            | バリデーション失敗  | E-OP-INPUT-*  | ticket_id 形式不正 / 必須項目欠落                                  |

| エラー分類       | 概要         | プレフィックス        | 代表例                             |
|-------------|------------|----------------|---------------------------------|
| 業務エラー       | ビジネスルール違反  | E-OP-BIZ-*     | 削除済み契約の操作 / 既復元データの再復元          |
| Webhook エラー | Webhook 関連 | E-OP-WEBHOOK-* | 署名検証失敗 / 幂等性違反 / 差分検出 / リプレイ枠超過 |
| PII 報告エラー   | PII 誤検出    | E-OP-PII-*     | 報告ステータス不正                       |
| 復元エラー       | 削除データ復元    | E-OP-RESTORE-* | 復元期限切れ / 423 Locked / 既復元       |
| 連携 IF エラー   | 連携 IF 関連   | E-OP-IF-NNN-*  | 送信失敗 / 認証失敗                     |
| システムエラー     | サーバー内部エラー  | E-OP-SYS-*     | DB エラー / 内部例外                   |

## 6.3 3. エラー一覧

### 6.3.1 3.1 認証エラー (E-OP-AUTH-\*)

| エラー ID                    | 発生条件                       | メッセージ ID               | ステータスコード | システム動作           | ログレベル |
|---------------------------|----------------------------|------------------------|----------|------------------|-------|
| E-OP-AUTH-CREDENTIAL      | パスワード不一致                   | MSG-SCR-AUTH-ERROR-004 | 401      | 失敗カウント +1        | WARN  |
| E-OP-AUTH-LOCKED          | 5 回失敗 (IP × operator_id)   | MSG-SCR-AUTH-ERROR-002 | 423      | 15 分ロック          | WARN  |
| E-OP-AUTH-SESSION-EXPIRED | セッション期限切れ (8 時間 / 30 分無操作) | -                      | 401      | SCR-AUTH ヘリダイレクト | INFO  |

### 6.3.2 3.2 MFA エラー (E-OP-MFA-\*)

| エラー ID                 | 発生条件                 | メッセージ ID                  | ステータスコード | システム動作        |
|------------------------|----------------------|---------------------------|----------|---------------|
| E-OP-MFA-FAILED        | TOTP 失敗              | MSG-SCR-AUTH-ERROR-003    | 401      | 失敗カウント +1     |
| E-OP-MFA-LOCKED        | TOTP 5 回失敗           | MSG-OP-MFA-LOCKED         | 423      | 15 分ロック       |
| E-OP-MFA-SETUP-EXPIRED | セットアップトークン期限切れ (72h) | MSG-SCR-AUTH-M1-ERROR-001 | 401      | 管理者へ再発行依頼     |
| E-OP-MFA-RECOVERY-USED | 回復コード再利用             | MSG-SCR-AUTH-M1-ERROR-002 | 401      | -             |
| E-OP-MFA-REQUIRED      | MFA 未検証              | -                         | 403      | SCR-AUTH-M1 へ |

### 6.3.3 3.3 IP allowlist エラー (E-OP-IP-\*)

| エラー ID         | 発生条件             | メッセージ ID | ステータスコード | システム動作        |
|----------------|------------------|----------|----------|---------------|
| E-OP-IP-DENIED | IP allowlist 不一致 | (画面表示なし) | 401 即時   | ログイン画面さえ表示しない |

### 6.3.4 3.4 再認証エラー (E-OP-REAUTH-\*)

| エラー ID               | 発生条件           | メッセージ ID               | ステータスコード | システム動作    |
|----------------------|----------------|------------------------|----------|-----------|
| E-OP-REAUTH-REQUIRED | 再認証期限切れ (5 分超) | MSG-OP-REAUTH-REQUIRED | 403      | 再認証モーダル表示 |
| E-OP-REAUTH-FAILED   | 再認証パスワード不一致    | -                      | 401      | 失敗カウント +1 |

### 6.3.5 3.5 4-eyes エラー (E-OP-4EYES-\*) —— 本書の中核

| エラー ID                        | 発生条件                                    | メッセージ ID                     | ステータスコード | システム動作                 | ログレベル |
|-------------------------------|-----------------------------------------|------------------------------|----------|------------------------|-------|
| E-OP-4EYES-REQUIRED           | 4-eyes 未承認で操作実行                         | MSG-OP-4EYES-NOT-APPROVED    | 403      | SCR-APPROVALS へ申請誘導    | WARN  |
| E-OP-4EYES-HARDGATE           | KV ハードゲート false                         | MSG-OP-4EYES-HARDGATE-OFF    | 403      | 即時拒否                   | WARN  |
| E-OP-4EYES-SELF               | 自己承認 / 自己却下試行                           | MSG-OP-4EYES-SELF            | 422      | DB CHECK 制約 + アプリ層チェック | WARN  |
| E-OP-4EYES-EXPIRED            | TTL 72h 経過                              | MSG-OP-4EYES-EXPIRED         | 410      | 再申請が必要                 | INFO  |
| E-OP-4EYES-PAYLOAD-CHANGED    | payload_hash 不一致                        | MSG-OP-4EYES-PAYLOAD-CHANGED | 409      | 最新の内容を確認してから承認         | WARN  |
| E-OP-4EYES-WITHDRAW-FORBIDDEN | 別運営者が取下げ試行                              | -                            | 403      | 申請者本人のみ取下げ可            | INFO  |
| E-OP-4EYES-INVALID-STATE      | 不正な state 遷移 (approved 以外から executed 等) | -                            | 422      | -                      | WARN  |

### 6.3.6 3.6 認可エラー (E-OP-AUTHZ-\*)

| エラー ID               | 発生条件               | ステータスコード | システム動作 |
|----------------------|--------------------|----------|--------|
| E-OP-AUTHZ-FORBIDDEN | 一般的な認可エラー (運営者では稀) | 403      | -      |

### 6.3.7 3.7 入力エラー (E-OP-INPUT-\*)

| エラー ID                     | 発生条件                   | メッセージ ID                     | ステータスコード | システム動作                 |
|----------------------------|------------------------|------------------------------|----------|------------------------|
| E-OP-INPUT-TICKET-REQUIRED | ticket_id 必須項目欠落       | MSG-OP-4EYES-TICKET-REQUIRED | 400      | 入力欄エラー表示               |
| E-OP-INPUT-VALIDATION      | 一般的なバリデーション失敗          | (フィールド別)                     | 400      | -                      |
| E-OP-INPUT-CIDR-FORMAT     | IP allowlist CIDR 形式不正 | -                            | 400      | -                      |
| E-OP-INPUT-DATE-RANGE      | 監査ログ検索期間が 1 年超過        | -                            | 400      | 「検索期間は 1 年以内で指定してください」 |
| E-OP-INPUT-XSS-DETECTED    | お知らせ本文に危険な HTML 要素     | -                            | 422      | サニタイズ不可と判定             |



### 6.3.8 3.8 業務エラー (E-OP-BIZ-\*)

| エラー ID                              | 発生条件                     | ステータスコード | システム動作     |
|-------------------------------------|--------------------------|----------|------------|
| E-OP-BIZ-NOT-FOUND                  | リソース不在                   | 404      | -          |
| E-OP-BIZ-DELETED-OWNER              | 削除済み契約の操作                | 410      | -          |
| E-OP-BIZ-ALREADY-RESTORED           | 既復元データの再復元               | 422      | 「既に復元済みです」 |
| E-OP-BIZ-ANNOUNCEMENT-CANCEL-WINDOW | お知らせ取消窓 (配信開始 5 分前) を過ぎた | 422      | -          |

### 6.3.9 3.9 Webhook エラー (E-OP-WEBHOOK-\*)

| エラー ID                             | 発生条件                 | システム動作                                                                     | ログレベル |
|------------------------------------|----------------------|----------------------------------------------------------------------------|-------|
| E-OP-WEBHOOK-SIGNATURE-INVALID     | Stripe 署名 HMAC 不正    | 401 + 監査記録 (webhook.signature.failed) + 運営者 high alert                     | WARN  |
| E-OP-WEBHOOK-IDEMPOTENCY-VIOLATION | event_id 重複          | 200 「duplicate, skipped, hash_match」 + ログ                                  | INFO  |
| E-OP-WEBHOOK-PAYLOAD-DIFF          | 同 event_id + ハッシュ不一致 | 200 + webhook_payload_diffs INSERT + SCR-099 記録 + 運営者 high alert + 自動上書き禁止 | WARN  |
| E-OP-WEBHOOK-DLQ-FAILED            | DLQ 自動 BO 3 回失敗      | 永久失敗 → 運営者手動リプレイ待ち                                                         | WARN  |
| E-OP-WEBHOOK-REPLAY-AUTO-BO        | 自動 BO 完了前のリプレイ試行     | 409 + 「自動 BO 中はリプレイできません ([N] 分後)」                                         | INFO  |
| E-OP-WEBHOOK-REPLAY-EXPIRED        | 受信から 30 日超過          | 410 + 「受信から 30 日を超えたためリプレイできません (R2 退避済み)」                                 | INFO  |

### 6.3.10 3.10 PII 報告エラー (E-OP-PII-\*)

| エラー ID                 | 発生条件         | システム動作       |
|------------------------|--------------|--------------|
| E-OP-PII-INVALID-STATE | 不正な state 遷移 | 422          |
| E-OP-PII-SLA-EXPIRED   | 3 営業日 SLA 超過 | 警告のみ (運営者通知) |

### 6.3.11 3.11 復元エラー (E-OP-RESTORE-\*)

| エラー ID                          | 発生条件                          | メッセージ ID              | ステータスコード   | システム動作                |
|---------------------------------|-------------------------------|-----------------------|------------|-----------------------|
| E-OP-RESTORE-LOCKED             | 他の運営者が処理中 (deletion-queue 競合) | MSG-SCR-091-ERROR-001 | 423 Locked | 「他の運営者が処理中のため復元できません」 |
| E-OP-RESTORE-PRECHECK-FAILED    | プリチェック NG 項目あり                | -                     | 422        | 詳細を画面で確認              |
| E-OP-RESTORE-WINDOW-EXPIRED     | 復元期限切れ (物理削除済み)               | -                     | 410        | 「復元期限が過ぎました」          |
| E-OP-RESTORE-SIDE-EFFECT-FAILED | 副作用ロールバック失敗                   | -                     | 500        | 運営者 high alert        |

### 6.3.12 3.12 連携 IF エラー (E-OP-IF-\*)

メイン側 [06\\_エラー設計書.md §4.9](#) と整合。運営者側は **送信主管側のエラー** (送信失敗 → DLQ 投入 → 自動 BO 3 回 → 失敗で運営者通知)。

| エラー ID                  | 発生条件                        | システム動作                    |
|-------------------------|-----------------------------|---------------------------|
| E-OP-IF-001-SEND-FAILED | IF #1 送信失敗                  | DLQ 投入 + 自動 BO 3 回        |
| E-OP-IF-010-SIG-FAILED  | IF #10(Stripe Webhook) 署名失敗 | 401 + 監査 + 運営者 high alert |
| E-OP-IF-012-SEND-FAILED | IF #12 送信失敗                 | DLQ 投入 + 自動 BO 3 回        |

### 6.3.13 3.13 システムエラー (E-OP-SYS-\*)

| エラー ID                     | 発生条件                 | ステータスコード | システム動作                   |
|----------------------------|----------------------|----------|--------------------------|
| E-OP-SYS-INTERNAL          | サーバー内部エラー            | 500      | エラー ID を運営者に提示           |
| E-OP-SYS-DB                | DB エラー               | 500      | 同上                       |
| E-OP-SYS-HASH-CHAIN-BROKEN | 監査ログ SHA-256 チェーン不整合 | (バッチ検出)  | 運営者 high alert(critical) |

## 6.4 4. 異常系共通方針

### 6.4.1 4.1 IP allowlist 拒否

- **401 即時応答** (画面遷移なし、HTTP のみ)
- レスポンスボディには詳細を含めない (IP 範囲列挙攻撃対策)
- ログには発信元 IP を記録 (セキュリティ設計書 10 §7、`audit_logs.action='auth.ip_blocked'`)

### 6.4.2 4.2 MFA エラー

- TOTP 失敗 5 回で (IP × operator\_id) を 15 分ロックアウト
- 回復コードは 1 回限り使用、使用済みは無効化
- **MFA リセットは自己リセット禁止** (他運営者承認必須)

### 6.4.3 4.3 再認証期限切れ

- **403 + 再認証画面誘導** (再認証モーダル表示)
- 再認証成功後、元の操作を再実行可能
- 残時間 5 分カウントダウンを `ReauthCountdown` で常時表示

### 6.4.4 4.4 4-eyes 未承認 (本書の中核)

- 4-eyes 対象 10 操作の API 直接呼び出しは **403 統一**
- 「承認が必要な操作です。SCR-APPROVALS から申請してください」を返却
- 4-eyes ハードゲート KV false の場合は別エラーコード (**E-OP-4EYES-HARDGATE**)
- 監査: `audit_logs.action='4eyes.approval.required'`

### 6.4.5 4.5 自己承認 / 自己却下

- **422 + 専用コード**
- 申請者と承認者が同一 operator\_id の場合、`operator_approvals.CHECK` 制約 + アプリ層の二重チェック
- 監査: `audit_logs.action='4eyes.self_approval_rejected'`

### 6.4.6 4.6 承認 TTL 切れ

- **410 + 専用コード** (承認可能時間 72h 経過後)
- 再申請を促す
- 自動状態遷移 `expired`

### 6.4.7 4.7 payload\_hash 改ざん検知

- **409 + 専用コード** (承認時の payload と実行時の payload が異なる)
- 監査: `audit_logs.action='4eyes.payload_mismatch'`
- 「申請内容が変更されている可能性があります」を表示し、最新で再申請

#### 6.4.8 4.8 Webhook 関連

- ・署名検証失敗: 401 + 監査ログ記録(全件)
- ・冪等性違反: 200 + 既存処理結果(リトライ安全性)
- ・ペイロード差分検出: 200 受信 + SCR-099 で表示 + 運営者通知 **high** + 自動上書き禁止

#### 6.4.9 4.9 復元エラー

- ・accounts\_retired 未存在: 404 + 「復元可能なデータが見つかりません」
- ・deletion-queue 競合: **423 Locked** + 「他の運営者が処理中のため復元できません」
- ・既復元データ: 422 + 「既に復元済みです」
- ・プリチェック NG: 422 + 詳細表示

#### 6.4.10 4.10 連携 IF エラー (送信側)

- ・送信側(運営者 → メイン)失敗: DLQ 投入、自動リトライ(指数バックオフ 1m → 4m → 16m)
- ・3 回失敗で運営者通知 (**high**)
- ・受信側(メイン → 運営者)エラー: 200 + エラーログ記録(リトライさせない)

### 6.5 5. ステータスコード対応表

| ステータスコード   | 用途                             | 主なエラー ID                                                                                                       |
|------------|--------------------------------|----------------------------------------------------------------------------------------------------------------|
| 200        | Webhook 受信 / 冪等性違反 / 差分検出      | E-OP-WEBHOOK-IDEMPOTENCY-VIOLATION / E-OP-WEBHOOK-PAYLOAD-DIFF                                                 |
| 400        | 入力エラー                          | E-OP-INPUT-*                                                                                                   |
| 401        | 認証エラー / IP allowlist 拒否 / 署名失敗 | E-OP-AUTH-*/E-OP-IP-*/E-OP-MFA-*/E-OP-WEBHOOK-SIGNATURE-INVALID                                                |
| 403        | 4-eyes 未承認 / 再認証期限切れ / 認可エラー   | E-OP-4EYES-REQUIRED / E-OP-4EYES-HARDGATE / E-OP-REAUTH-REQUIRED / E-OP-AUTHZ-FORBIDDEN                        |
| 404        | リソース不在                         | E-OP-BIZ-NOT-FOUND                                                                                             |
| 409        | payload_hash 不一致 / 自動 BO 中リプレイ | E-OP-4EYES-PAYLOAD-CHANGED / E-OP-WEBHOOK-REPLAY-AUTO-BO                                                       |
| 410        | TTL 切れ / 復元期限切れ / リプレイ枠超過      | E-OP-4EYES-EXPIRED / E-OP-RESTORE-WINDOW-EXPIRED / E-OP-WEBHOOK-REPLAY-EXPIRED                                 |
| 422        | 業務エラー / 自己承認                   | E-OP-BIZ-*/E-OP-4EYES-SELF / E-OP-4EYES-INVALID-STATE / E-OP-RESTORE-PRECHECK-FAILED / E-OP-INPUT-XSS-DETECTED |
| 423 Locked | ロックアウト / 復元時競合                 | E-OP-AUTH-LOCKED / E-OP-MFA-LOCKED / E-OP-RESTORE-LOCKED                                                       |
| 429        | レート制限(運営者は通常到達しない、600 req/min) | -                                                                                                              |
| 500        | システムエラー                        | E-OP-SYS-*/E-OP-RESTORE-SIDE-EFFECT-FAILED                                                                     |

### 6.6 6. 運営者通知 **critical** レベルエラー

以下のエラーは運営者 inbox + メール強制送信 (**critical**):

| エラー ID                         | 発火条件                    | 通知契機 ID                 |
|--------------------------------|-------------------------|-------------------------|
| E-OP-WEBHOOK-SIGNATURE-INVALID | Stripe 署名検証失敗           | NOTIF-OP-SIG-FAIL       |
| E-OP-SYS-HASH-CHAIN-BROKEN     | 監査ログハッシュチェーン不整合(直近 24h) | NOTIF-OP-HASH-CHAIN-NG  |
| (運営者頻度異常検知)                    | 短時間大量操作                 | NOTIF-OP-FREQ-ANOMALY   |
| (不正利用検知通知 IF #9)               | FR-195 検知パターン           | NOTIF-OP-FRAUD-DETECTED |

6.7 7. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

6.8 8. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

7 メッセージ一覧 (運営者)

7.1 1. 文書概要

7.1.1 1.1 目的

運営者システムで運営者および IF #12 経由で利用者に表示するすべての文言 (画面ラベル / プレースホルダー / ボタン / 説明文 / エラー / 成功 / 警告 / 確認 / 空状態 / トースト / お知らせ・運営者操作通知テンプレート) を一元管理する。

7.1.2 1.2 対象範囲

- 対象: SCR-090~099 / SCR-AUTH / SCR-AUTH-M1 / SCR-HOME / SCR-APPROVALS / M1 / M2 の全面文言、運営者向け通知 (4-eyes / Webhook / 監査 / PII / DLQ)、IF #12 経由で利用者へ送られる運営者操作通知テンプレート、4-eyes 関連メッセージ
- 対象外: 利用者向けメッセージ (01\_メインシステム/個別設計書群/07\_メッセージ一覧.md 参照)

7.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

7.1.4 1.4 関連ドキュメント

| ドキュメント名     | 役割                                | 参照先                                |
|-------------|-----------------------------------|------------------------------------|
| 索引          | 11 ドキュメント体系の俯瞰                    | 00_索引.md                           |
| 画面設計書       | 画面別メッセージ参照                        | 02_画面設計書.md                        |
| エラー設計書      | エラー ID とメッセージ ID の対応              | 06_エラー設計書.md                       |
| 認証・認可設計書    | 4-eyes / 再認証 / IP allowlist フロー   | 09_認証認可設計書.md                      |
| 権限設計書       | 4-eyes 対象 10 操作                   | 05_権限設計書.md                        |
| メイン側メッセージ一覧 | 通知重要度 / critical メール強制送信 (共有概念正本) | ../01_メインシステム/個別設計書群/07_メッセージ一覧.md |

7.2 2. 共通基準

メイン側 [メッセージ一覧 §2](#) の共通基準を踏襲する。運営者固有の補足:

7.2.1 2.1 運営者向け文言の特徴

- 専門用語 (4-eyes, retention\_class, payload\_hash, ticket\_id, DLQ, hardgate 等) を許容
- 4-eyes 関連は「申請」「承認」「却下」「実行」「取消」を統一語彙
- 操作対象を明示 ({ContractName} / {operator\_id} / {action\_code} 等プレースホルダー多用)
- セキュリティ理由から具体情報を伏せる場合あり (IP allowlist 拒否時の許可範囲非表示等)

### 7.2.2 2.2 4-eyes 用語

| 用語                       | 説明                      |
|--------------------------|-------------------------|
| 申請 (request)             | 4-eyes 対象操作の最初の起票       |
| 承認 (approve)             | 別運営者による承認               |
| 却下 (reject)              | 別運営者による却下               |
| 取消 (withdraw)            | 申請者本人による取下げ             |
| 実行 (execute)             | 承認後の運用実行                |
| ハードゲート (hardgate)        | KV フラグによる動的拒否           |
| 操作チケット ID(ticket_id)     | 4-eyes 申請時に必須入力する内部チケット |
| ペイロードハッシュ (payload_hash) | 申請内容の改ざん検知用 SHA-256     |

### 7.2.3 2.3 通知重要度ルール (共有概念、メイン側 §2.4 参照)

`announcement_drafts.severity` の 3 値 (`low` / `normal` / `high`) は内部運用用。利用者向けには通知重要度 4 値 (`low` / `normal` / `high` / `critical`) と対応付ける。`critical` 通知は別建ての緊急通知パス (基本設計書 § 9.2 / メイン側 [10\\_セキュリティ設計書.md § 11](#)) で管理。

## 7.3 3. メッセージ ID 体系

メイン側 § 3 を踏襲。SCR ID 部分は運営者画面 ID (`SCR-090` / `SCR-AUTH` / `SCR-APPROVALS-M1` 等) を使用。運営者向け接頭辞は `MSG-` をそのまま使う (プレフィックス分離はなし)。エラー側は `E-OP-*` プレフィックスでメインと識別。

## 7.4 4. 画面別メッセージ全件

(基本設計書 § 5.3.1~5.3.15 から移管)

### 7.4.1 4.1 SCR-AUTH 運営者ログイン

| メッセージ ID               | 種別    | 表示文言                                                    | 表示条件                    | 関連エラー ID         |
|------------------------|-------|---------------------------------------------------------|-------------------------|------------------|
| MSG-SCR-AUTH-TITLE-001 | TITLE | 運営者ログイン                                                 | 画面ヘッダ                   | -                |
| MSG-SCR-AUTH-LBL-001   | LBL   | メールアドレス                                                 | 入力欄ラベル                  | -                |
| MSG-SCR-AUTH-LBL-002   | LBL   | パスワード                                                   | 入力欄ラベル                  | -                |
| MSG-SCR-AUTH-LBL-003   | LBL   | TOTP 認証コード (6 桁)                                        | 入力欄ラベル (MFA セットアップ済の場合) | -                |
| MSG-SCR-AUTH-BTN-001   | BTN   | ログイン                                                    | 送信ボタン                   | -                |
| MSG-SCR-AUTH-ERROR-001 | ERROR | 許可された IP アドレスからアクセスしてください (現在の IP: {ip})。管理者にお問い合わせください | IP allowlist 拒否         | E-OP-IP-DENIED   |
| MSG-SCR-AUTH-ERROR-002 | ERROR | ログイン試行回数の上限に達しました。{N} 分 {S} 秒後にもう一度お試しください              | ロックアウト中                 | E-OP-AUTH-LOCKED |
| MSG-SCR-AUTH-ERROR-003 | ERROR | 認証コードが一致しません。アプリで最新コードを確認してください                         | TOTP 失敗                 | E-OP-MFA-FAILED  |

| メッセージ ID               | 種別    | 表示文言                     | 表示条件 | 関連エラー ID             |
|------------------------|-------|--------------------------|------|----------------------|
| MSG-SCR-AUTH-ERROR-004 | ERROR | メールアドレスまたはパスワードが正しくありません | 認証失敗 | E-OP-AUTH-CREDENTIAL |

#### 7.4.2 4.2 SCR-AUTH-M1 MFA 初回セットアップ

| メッセージ ID                    | 種別      | 表示文言                                                                                             | 表示条件      | 関連エラー ID               |
|-----------------------------|---------|--------------------------------------------------------------------------------------------------|-----------|------------------------|
| MSG-SCR-AUTH-M1-TITLE-001   | TITLE   | MFA セットアップ                                                                                       | 画面ヘッダ     | -                      |
| MSG-SCR-AUTH-M1-STEP-001    | STEP    | ① 認証アプリでこの QR コードを読み取ってください                                                                      | ステップ 1    | -                      |
| MSG-SCR-AUTH-M1-STEP-002    | STEP    | ② 認証アプリに表示される 6 桁のコードを入力                                                                         | ステップ 2    | -                      |
| MSG-SCR-AUTH-M1-STEP-003    | STEP    | ③ 回復コード 10 個を保管してください                                                                            | ステップ 3    | -                      |
| MSG-SCR-AUTH-M1-WARN-001    | WARN    | <input checked="" type="checkbox"/> 回復コードは認証アプリを失った場合の唯一の復旧手段です。安全な場所に保管してください。この画面を閉じると再表示できません | ステップ 3 警告 | -                      |
| MSG-SCR-AUTH-M1-ERROR-001   | ERROR   | セットアップリンクが期限切れです (72 時間)。管理者へ再発行を依頼してください                                                        | トークン期限切れ  | E-OP-MFA-SETUP-EXPIRED |
| MSG-SCR-AUTH-M1-ERROR-002   | ERROR   | この回復コードは使用済みです                                                                                   | 回復コード再利用  | E-OP-MFA-RECOVERY-USED |
| MSG-SCR-AUTH-M1-SUCCESS-001 | SUCCESS | MFA セットアップが完了しました。次回ログインから認証アプリのコードが必要です                                                         | 完了        | -                      |

#### 7.4.3 4.3 SCR-HOME ホームダッシュボード

| メッセージ ID               | 種別    | 表示文言                                                                    | 表示条件        |
|------------------------|-------|-------------------------------------------------------------------------|-------------|
| MSG-SCR-HOME-TITLE-001 | TITLE | ホーム                                                                     | 画面ヘッダ       |
| MSG-SCR-HOME-DESC-001  | DESC  | 緊急対応の状況と各種カウンタを一覧します                                                    | 画面説明        |
| MSG-SCR-HOME-EMPTY-001 | EMPTY | <input checked="" type="checkbox"/> 緊急対応が必要な事案はありません                    | 緊急アラート空状態   |
| MSG-SCR-HOME-WARN-001  | WARN  | <input checked="" type="checkbox"/> 24 時間以上滞留中の Webhook イベントが {N} 件あります | DLQ 24h+    |
| MSG-SCR-HOME-WARN-002  | WARN  | <input checked="" type="checkbox"/> 承認期限切れ間近の申請が {N} 件あります (残 24 時間以内)  | 4-eyes 期限間近 |

#### 7.4.4 4.4 SCR-090 削除データ参照

| メッセージ ID              | 種別    | 表示文言    | 表示条件  |
|-----------------------|-------|---------|-------|
| MSG-SCR-090-TITLE-001 | TITLE | 削除データ参照 | 画面ヘッダ |

| メッセージ ID                | 種別      | 表示文言                                   | 表示条件     |
|-------------------------|---------|----------------------------------------|----------|
| MSG-SCR-090-DESC-001    | DESC    | 論理削除済みのリソースを検索・参照します                   | 画面説明     |
| MSG-SCR-090-CHIP-001    | CHIP    | 最近 1 週間 / 最近 1 ヶ月 / 物理削除予定 7 日以内 / すべて | クイックフィルタ |
| MSG-SCR-090-MSG-001     | MSG     | 物理削除予定: 残 {N} 日 ({deletionDate})       | 残日数表示    |
| MSG-SCR-090-TOOLTIP-001 | TOOLTIP | 物理削除済のため復元できません                        | tooltip  |
| MSG-SCR-090-EMPTY-001   | EMPTY   | 該当する削除済みリソースはありません                     | 空状態      |

#### 7.4.5 4.5 SCR-091 削除データ復元

| メッセージ ID                | 種別      | 表示文言                                                               | 表示条件                                                   |
|-------------------------|---------|--------------------------------------------------------------------|--------------------------------------------------------|
| MSG-SCR-091-TITLE-001   | TITLE   | 削除データ復元                                                            | 画面ヘッダ                                                  |
| MSG-SCR-091-DESC-001    | DESC    | 削除済みリソースの復元を 4-eyes 承認経由で実行します                                     | 画面説明                                                   |
| MSG-SCR-091-LBL-001     | LBL     | 操作チケット ID                                                          | 必須                                                     |
| MSG-SCR-091-LBL-002     | LBL     | 復元理由                                                               | 必須                                                     |
| MSG-SCR-091-PH-001      | PH      | 対応チケットの内容と復元判断の根拠を簡潔にご記入ください(申請履歴に残ります)                            | 復元理由プレースホルダ                                            |
| MSG-SCR-091-SUCCESS-001 | SUCCESS | <input checked="" type="checkbox"/> プリチェック全項目 OK。復元できます            | プリチェック OK                                              |
| MSG-SCR-091-WARN-001    | WARN    | <input checked="" type="checkbox"/> プリチェックで NG 項目があります。詳細を確認してください | プリチェック NG                                              |
| MSG-SCR-091-BTN-001     | BTN     | 4-eyes 申請する                                                        | 4-eyes 申請 Primary(HardgateBadge 付き)                    |
| MSG-SCR-091-BTN-002     | BTN     | 復元を実行する                                                            | 即時実行 Primary(再認証 <input checked="" type="checkbox"/> ) |
| MSG-SCR-091-TOAST-001   | TOAST   | 復元しました。副作用 (a)~(g) の連動回復は監査ログを参照してください                             | 完了                                                     |
| MSG-SCR-091-ERROR-001   | ERROR   | 他の運営者が処理中のため復元できません。少し時間を置いて再度お試しください                              | 競合エラー (423 Locked)                                     |

#### 7.4.6 4.6 SCR-092 AI 推論パラメータ (ハードゲート)

| メッセージ ID               | 種別     | 表示文言                                          | 表示条件        |
|------------------------|--------|-----------------------------------------------|-------------|
| MSG-SCR-092-TITLE-001  | TITLE  | EAI 推論パラメータ                                   | 画面ヘッダ       |
| MSG-SCR-092-BANNER-001 | BANNER | 有効値 = min(プロジェクト, オーナー, グローバル)                | 優先順位バナー     |
| MSG-SCR-092-MSG-001    | MSG    | 現在 {currentPercent}% → 次回 {nextPercent}%      | ロールアウト進行ラベル |
| MSG-SCR-092-TOAST-001  | TOAST  | AI パラメータを更新しました。次回ハイドレーション (60 秒以内) から有効になります | 完了          |
| MSG-SCR-092-ERROR-001  | ERROR  | 自分の申請は承認できません (他の運営者の承認が必要です)                 | 自己承認エラー     |

#### 7.4.7 4.7 SCR-093 契約別レート / 予算上書き

| メッセージ ID                    | 種別      | 表示文言                                                          | 表示条件               |
|-----------------------------|---------|---------------------------------------------------------------|--------------------|
| MSG-SCR-093-TITLE-001       | TITLE   | 契約別レート・予算上書き                                                  | 画面ヘッダ              |
| MSG-SCR-093-BTN-001         | BTN     | グローバル値に戻す                                                     | 戻すボタン (tooltip 付き) |
| MSG-SCR-093-TOOLTIP-001     | TOOLTIP | 上書きを削除し、グローバル既定値に復帰します                                        | 戻すボタン tooltip      |
| MSG-SCR-093-CONFIRM_MSG-001 | CONFIRM | {msgName} の上書き設定を削除し、グローバル既定値 ({globalValues}) に戻します。即時反映されます | 戻す確認本文             |
| MSG-SCR-093-TOAST-001       | TOAST   | 上書きを保存しました。次回ハイドレーション (30 秒以内) から有効になります                      | 保存完了               |
| MSG-SCR-093-TOAST-002       | TOAST   | 上書きを削除しました。グローバル既定値に復帰しました                                    | 削除完了               |

#### 7.4.8 4.8 SCR-094 お知らせ作成・配信

| メッセージ ID              | 種別    | 表示文言                          | 表示条件                                             |
|-----------------------|-------|-------------------------------|--------------------------------------------------|
| MSG-SCR-094-TITLE-001 | TITLE | お知らせ作成・配信                     | 画面ヘッダ                                            |
| MSG-SCR-094-BTN-001   | BTN   | 下書きを保存                        | ステップ 1                                           |
| MSG-SCR-094-BTN-002   | BTN   | テスト送信 (自分宛に送る)                | ステップ 2                                           |
| MSG-SCR-094-BTN-003   | BTN   | 配信を予約する                       | ステップ 3(再認証 <input checked="" type="checkbox"/> ) |
| MSG-SCR-094-BTN-004   | BTN   | 即時配信する                        | ステップ 4(HardgateBadge + Danger)                   |
| MSG-SCR-094-MSG-001   | MSG   | {recipientCount} 件に配信されます     | 想定配信件数表示                                         |
| MSG-SCR-094-TOAST-001 | TOAST | 下書きを保存しました                    | 下書き完了                                            |
| MSG-SCR-094-TOAST-002 | TOAST | 配信を予約しました (開始 5 分前まで取消可能)     | 予約完了                                             |
| MSG-SCR-094-TOAST-003 | TOAST | 即時配信を実行しました。配信状況はホーム画面で確認できます | 即時配信完了                                           |

#### 7.4.9 4.9 SCR-096 運営者活動ダッシュボード

| メッセージ ID              | 種別    | 表示文言                                                                      | 表示条件     |
|-----------------------|-------|---------------------------------------------------------------------------|----------|
| MSG-SCR-096-TITLE-001 | TITLE | 運営者活動ダッシュボード                                                              | 画面ヘッダ    |
| MSG-SCR-096-BADGE-001 | BADGE | <input checked="" type="checkbox"/> ハッシュチェーン検証 OK(直近 24 時間)               | 検証 OK    |
| MSG-SCR-096-BADGE-002 | BADGE | <input checked="" type="checkbox"/> ハッシュチェーン検証 NG(直近 24 時間) — 詳細を確認してください | 検証 NG    |
| MSG-SCR-096-WARN-001  | WARN  | <input checked="" type="checkbox"/> 短時間大量操作を検知: {N} 件                     | 運営者頻度異常  |
| MSG-SCR-096-TOAST-001 | TOAST | CSV のエクスポートが完了しました。署名検証用の手順は付録 H を参照                                      | エクスポート完了 |

#### 7.4.10 4.10 SCR-097 課金 Webhook リプレイ・DLQ



| メッセージ ID                    | 種別      | 表示文言                                                                        | 表示条件     |
|-----------------------------|---------|-----------------------------------------------------------------------------|----------|
| MSG-SCR-097-TITLE-001       | TITLE   | 課金 Webhook リプレイ・DLQ                                                         | 画面ヘッダ    |
| MSG-SCR-097-WARN-001        | WARN    | <input checked="" type="checkbox"/> 24 時間以上滞留中のイベントが {N} 件あります。早急に確認してください  | 24h+ 滞留  |
| MSG-SCR-097-WARN-002        | WARN    | <input checked="" type="checkbox"/> リプレイ枠 30 日に近づくイベントが {M} 件あります (残 3 日以内) | 30 日近接   |
| MSG-SCR-097-CONFIRM_MSG-001 | CONFIRM | イベント {eventId} を再処理キューに投入します。冪等性キーで二重課金は防止されます                              | リプレイ確認本文 |
| MSG-SCR-097-ERROR-001       | ERROR   | 受信から 30 日を超えたためリプレイできません (R2 退避済み)                                          | 枠超過      |

#### 7.4.11 4.11 SCR-098 PII 誤検出報告

| メッセージ ID               | 種別     | 表示文言                                                                                                                                           | 表示条件      |
|------------------------|--------|------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| MSG-SCR-098-TITLE-001  | TITLE  | PII 誤検出報告管理                                                                                                                                    | 画面ヘッダ     |
| MSG-SCR-098-BANNER-001 | BANNER | <input checked="" type="checkbox"/> SLA 超過: {N} 件 / 期限間近: {M} 件 / 期限内: {K} 件                                                                   | SLA サマリ   |
| MSG-SCR-098-BADGE-001  | BADGE  | <input checked="" type="checkbox"/> 残 {N} 営業日 / <input checked="" type="checkbox"/> 残 1 営業日 / <input checked="" type="checkbox"/> SLA 超過 {N} 日 | 3 営業日タイマー |
| MSG-SCR-098-WARN-001   | WARN   | <input checked="" type="checkbox"/> 検知数 {now} 件 → {after} 件 (差分 {diff})                                                                        | ルール更新影響件数 |
| MSG-SCR-098-TOAST-001  | TOAST  | PII ルールを更新しました。次回ハイドレーション (60 秒以内) から有効になります                                                                                                   | ルール更新完了   |

#### 7.4.12 4.12 SCR-099 Webhook ペイロード差分検出

| メッセージ ID                    | 種別      | 表示文言                                                      | 表示条件            |
|-----------------------------|---------|-----------------------------------------------------------|-----------------|
| MSG-SCR-099-TITLE-001       | TITLE   | Webhook ペイロード差分検出                                         | 画面ヘッダ           |
| MSG-SCR-099-BTN-001         | BTN     | 手動再処理する → SCR-097 へ                                       | 手動再処理           |
| MSG-SCR-099-CONFIRM_MSG-001 | CONFIRM | イベント {eventId} は差分があるものの、業務上の影響はないと判定します。判定理由は監査ログに記録されます | 「影響なしとして処理」確認本文 |

#### 7.4.13 4.13 SCR-APPROVALS 承認待ち一覧 (4-eyes)

| メッセージ ID                    | 種別    | 表示文言                                | 表示条件     |
|-----------------------------|-------|-------------------------------------|----------|
| MSG-SCR-APPROVALS-TITLE-001 | TITLE | 承認待ち一覧                              | 画面ヘッダ    |
| MSG-SCR-APPROVALS-CHIP-001  | CHIP  | 承認待ち (別運営者) / あなたの申請 / 期限切れ間近 / すべて | クイックフィルタ |
| MSG-SCR-APPROVALS-MSG-001   | MSG   | 自分の申請は承認できません (他の運営者の承認が必要です)       | 自己承認禁止   |
| MSG-SCR-APPROVALS-EMPTY-001 | EMPTY | 承認待ちの申請はありません                       | 空状態      |

#### 7.4.14 4.14 SCR-APPROVALS-M1 4-eyes 承認申請モーダル

| メッセージ ID                       | 種別    | 表示文言                                    | 表示条件         |
|--------------------------------|-------|-----------------------------------------|--------------|
| MSG-SCR-APPROVALS-M1-TITLE-001 | TITLE | 4-eyes 承認を申請する                          | モーダルヘッダ      |
| MSG-SCR-APPROVALS-M1-DESC-001  | DESC  | この操作には別の運営者の承認が必要です。申請後、他の運営者に通知が送信されます | 上部説明         |
| MSG-SCR-APPROVALS-M1-LBL-001   | LBL   | 操作チケット ID                               | 必須           |
| MSG-SCR-APPROVALS-M1-LBL-002   | LBL   | 申請理由                                    | 必須           |
| MSG-SCR-APPROVALS-M1-MSG-001   | MSG   | 申請後、運営者 [N] 名 (あなたを除く) に通知されます          | 通知先表示        |
| MSG-SCR-APPROVALS-M1-BTN-001   | BTN   | 申請する                                    | Primary      |
| MSG-SCR-APPROVALS-M1-TOAST-001 | TOAST | 申請を送信しました。承認待ち一覧から状況を確認できます             | 完了           |
| MSG-SCR-APPROVALS-M1-ERROR-001 | ERROR | 操作チケット ID を入力してください                     | ticket_id 欠落 |

#### 7.4.15 4.15 SCR-APPROVALS-M2 4-eyes 承認 / 却下モーダル

| メッセージ ID                       | 種別    | 表示文言                                                         | 表示条件             |
|--------------------------------|-------|--------------------------------------------------------------|------------------|
| MSG-SCR-APPROVALS-M2-TITLE-001 | TITLE | 申請内容を確認する                                                    | モーダルヘッダ          |
| MSG-SCR-APPROVALS-M2-WARN-001  | WARN  | 申請内容が変更されている可能性があります (payload_hash 不一致)。最新の内容を確認してから承認してください | payload_hash 不一致 |
| MSG-SCR-APPROVALS-M2-ERROR-001 | ERROR | 自分の申請は承認できません (他の運営者の承認が必要です)                                | 自己承認禁止           |
| MSG-SCR-APPROVALS-M2-ERROR-002 | ERROR | 承認の有効期限が切れました。再申請してください                                      | TTL 切れ           |
| MSG-SCR-APPROVALS-M2-TOAST-001 | TOAST | 承認しました。申請者と監査ログに記録されます                                       | 承認完了             |
| MSG-SCR-APPROVALS-M2-TOAST-002 | TOAST | 却下しました。申請者に通知されます                                            | 却下完了             |

### 7.5 5. サイドメニュー (共通 UI)

| メッセージ ID       | 種別  | 表示文言    | 表示先        |
|----------------|-----|---------|------------|
| MSG-NAV-OP-001 | LBL | ホーム     | → SCR-HOME |
| MSG-NAV-OP-002 | LBL | 削除データ参照 | → SCR-090  |
| MSG-NAV-OP-003 | LBL | 削除データ復元 | → SCR-091  |

| メッセージ ID       | 種別  | 表示文言         | 表示先                                 |
|----------------|-----|--------------|-------------------------------------|
| MSG-NAV-OP-004 | LBL | AI 推論パラメータ   | → SCR-092(バッジ: ハードゲート申請中件数)         |
| MSG-NAV-OP-005 | LBL | レート/予算上書き    | → SCR-093                           |
| MSG-NAV-OP-006 | LBL | お知らせ配信       | → SCR-094(バッジ: scheduled 件数)        |
| MSG-NAV-OP-007 | LBL | Webhook リプレイ | → SCR-097(バッジ: DLQ 滞留 1h+ / 24h+ 赤) |
| MSG-NAV-OP-008 | LBL | PII 誤検出報告    | → SCR-098(バッジ: 3 営業日経過件数)           |
| MSG-NAV-OP-009 | LBL | ペイロード差分      | → SCR-099(バッジ: detected 件数、赤)       |
| MSG-NAV-OP-010 | LBL | 運営者活動        | → SCR-096                           |
| MSG-NAV-OP-011 | LBL | 承認待ち一覧       | → SCR-APPROVALS(バッジ: 承認待ち件数)        |
| MSG-NAV-OP-012 | LBL | 運営者 inbox    | → 別画面 (未読件数バッジ)                     |
| MSG-NAV-OP-013 | LBL | ログアウト        | → SCR-AUTH                          |

## 7.6 6. 4-eyes 関連メッセージ集約 (本書の中核)

| メッセージ ID                     | 利用箇所                     | 表示文言                                                                   | 表示条件               | 関連エラー ID                   |
|------------------------------|--------------------------|------------------------------------------------------------------------|--------------------|----------------------------|
| MSG-OP-4EYES-NOT-APPROVED    | API 拒否時                  | 承認が必要な操作です。SCR-APPROVALS から申請してください                                    | 4-eyes 未承認で API 実行 | E-OP-4EYES-REQUIRED        |
| MSG-OP-4EYES-HARDGATE-OFF    | API 拒否時                  | 現在この操作は無効化されています (運営側で有効化が必要)                                          | KV ハードゲートフラグ false | E-OP-4EYES-HARDGATE        |
| MSG-OP-4EYES-SELF            | SCR-APPROVALS-M2         | 自分の申請は承認できません (他の運営者の承認が必要です)                                          | 申請者 = 承認者          | E-OP-4EYES-SELF            |
| MSG-OP-4EYES-EXPIRED         | SCR-APPROVALS-M2         | 承認の有効期限が切れました。再申請してください                                                | TTL 72h 経過         | E-OP-4EYES-EXPIRED         |
| MSG-OP-4EYES-TICKET-REQUIRED | SCR-APPROVALS-M1         | 操作チケット ID を入力してください                                                    | ticket_id 必須項目欠落   | E-OP-INPUT-TICKET-REQUIRED |
| MSG-OP-4EYES-PAYLOAD-CHANGED | SCR-APPROVALS-M2         | 申請時のペイロードと異なります。再申請してください                                              | payload_hash 不一致   | E-OP-4EYES-PAYLOAD-CHANGED |
| MSG-OP-4EYES-DEADLINE-NEAR   | SCR-APPROVALS / SCR-HOME | <input checked="" type="checkbox"/> 承認期限切れ間近の申請が {N} 件あります (残 24 時間以内) | 期限 24h 以内          | -                          |

## 7.7 7. 認証・認可関連メッセージ (運営者固有)

| メッセージ ID          | 利用箇所             | 表示文言                       | 表示条件             | 関連エラー ID        |
|-------------------|------------------|----------------------------|------------------|-----------------|
| MSG-OP-IP-DENIED  | HTTP 401(画面表示なし) | -                          | IP allowlist 不一致 | E-OP-IP-DENIED  |
| MSG-OP-MFA-FAILED | SCR-AUTH         | 認証に失敗しました。MFA コードを確認してください | TOTP 失敗          | E-OP-MFA-FAILED |

| メッセージ ID                 | 利用箇所        | 表示文言                                      | 表示条件            | 関連エラー ID               |
|--------------------------|-------------|-------------------------------------------|-----------------|------------------------|
| MSG-OP-MFA-LOCKED        | SCR-AUTH    | ログイン試行回数が上限に達しました。15 分後に再試行してください         | 5 回失敗           | E-OP-AUTH-LOCKED       |
| MSG-OP-REAUTH-REQUIRED   | モーダル        | 再認証が必要です。パスワードを入力してください                   | 再認証期限切れ         | E-OP-REAUTH-REQUIRED   |
| MSG-OP-MFA-RECOVERY-USED | SCR-AUTH    | この回復コードは使用済みです                            | 回復コード再利用        | E-OP-MFA-RECOVERY-USED |
| MSG-OP-MFA-SETUP-EXPIRED | SCR-AUTH-M1 | セットアップリンクが期限切れです (72 時間)。管理者へ再発行を依頼してください | MFA セットアップ 期限切れ | E-OP-MFA-SETUP-EXPIRED |

## 7.8 8. 通知契機 (運営者向け、§9.1 から移管)

### 7.8.1 8.1 運営者宛通知 12 種

| 通知 ID                   | 契機                                | 重要度      | 配信先                | チャネル        | 関連要件             |
|-------------------------|-----------------------------------|----------|--------------------|-------------|------------------|
| NOTIF-OP-4EYES-REQUEST  | 4-eyes 申請発生                       | high     | 全運営者 (inbox + メール) | inbox/email | § 6.3.1          |
| NOTIF-OP-4EYES-APPROVED | 4-eyes 承認完了                       | normal   | 申請者 (inbox + メール)  | inbox/email | § 6.3.1          |
| NOTIF-OP-PII-REMINDER   | PII 誤検出報告 3 営業日判定リマインド            | high     | 全運営者 (inbox + メール) | inbox/email | AC-036           |
| NOTIF-OP-PAYLOAD-DIFF   | Webhook ペイロード差分検出                 | high     | 全運営者 (inbox + メール) | inbox/email | FR-302 異常系       |
| NOTIF-OP-DLQ-STUCK      | DLQ 滞留 1h 以上                      | high     | 全運営者 (inbox + メール) | inbox/email | NFR-808, NFR-809 |
| NOTIF-OP-HASH-CHAIN-NG  | ハッシュチェーン不一致                       | critical | 全運営者 (inbox + メール) | inbox/email | NFR-306          |
| NOTIF-OP-FREQ-ANOMALY   | 運営者操作頻度異常                         | high     | 全運営者 (inbox + メール) | inbox/email | FR-229(c)        |
| NOTIF-OP-ANN-TEST       | SCR-094 テスト送信                     | テスト      | 運営者本人              | inbox/email | FR-149           |
| NOTIF-OP-SIG-FAIL       | 課金 Webhook 署名検証失敗                 | critical | 全運営者 (inbox + メール) | inbox/email | NFR-310          |
| NOTIF-OP-WH-FAIL-RATE   | 課金 Webhook 受信失敗率 5% 超過            | high     | 全運営者 (inbox + メール) | inbox/email | NFR-808          |
| NOTIF-OP-CRON-FAIL      | 月次請求確定 cron 失敗 (3 回連続)            | high     | 全運営者 (inbox + メール) | inbox/email | FR-303           |
| NOTIF-OP-LOCK-CONFLICT  | 復元時 423 Locked(deletion-queue 競合) | high     | 全運営者 (inbox + メール) | inbox/email | FR-204 異常系       |
| NOTIF-OP-FRAUD-DETECTED | 不正利用検知通知 (IF #9 受信)               | critical | 全運営者 (inbox + メール) | inbox/email | FR-195           |

### 7.8.2 8.2 IF #12 経由 利用者向け運営者操作通知 (FR-211、集約窓 10 分)

| 通知 ID                      | 契機                 | 配信先                               | 重要度      | チャネル          |
|----------------------------|--------------------|-----------------------------------|----------|---------------|
| NOTIF-OP-RESTORE-DONE      | 論理削除データの復元         | 対象契約全管理者(オーナー + users:manage 保持者) | high     | inbox + email |
| NOTIF-OP-SUSPEND           | 契約無効化・復旧           | 対象契約全管理者                          | critical | inbox + email |
| NOTIF-OP-RATE-CHANGED      | 契約別レート制限・しきい値上書き変更 | 対象契約全管理者                          | high     | inbox + email |
| NOTIF-OP-AI-PARAM-CHANGED  | AI 推論パラメータ上書き変更    | 対象契約全管理者                          | normal   | inbox + email |
| NOTIF-OP-WIDGET-FORCE-STOP | ウィジェット強制停止         | 対象契約全管理者                          | critical | inbox + email |

### 7.8.3 8.3 通知テンプレート

| テンプレート ID                    | 件名                               | 本文要素                                 |
|------------------------------|----------------------------------|--------------------------------------|
| TPL-OP-4EYES-REQUEST         | [承認待ち]{action_code}の承認依頼         | 申請者、対象、payload プレビュー、承認 URL          |
| TPL-OP-PAYLOAD-DIFF          | [警告] Stripe Webhook payload 差分検出 | event_id、diff サマリ、SCR-099 URL        |
| TPL-OP-FRAUD-DETECTED        | [緊急] 不正利用検知—{owner_account_id}   | 検知パターン、推奨対応、SCR-093 URL              |
| TPL-OP-HASH-CHAIN-NG         | [重大] 監査ログハッシュチェーン検証 NG           | 検出時刻、対象範囲、SCR-096 URL、対応 Runbook URL |
| TPL-OP-IF12-RESTORE-DONE     | 論理削除データを復元しました ({日時})            | 復元対象、復元理由、運営者署名、ticket_id            |
| TPL-OP-IF12-SUSPEND          | [重要] アカウントが停止されました               | 停止理由、解除手順、課金画面誘導                     |
| TPL-OP-IF12-AI-PARAM-CHANGED | AI パラメータが変更されました                 | 変更項目、新旧値、変更理由                        |

### 7.8.4 8.4 運営者 inbox 設計

| 項目         | 仕様                                                                          |
|------------|-----------------------------------------------------------------------------|
| データ        | inbox_messages(recipient_type='service_operator', recipient_id=operator_id) |
| 保持期間       | 1 年 (NFR-705)                                                               |
| 既読管理       | 個別 + 一括既読化                                                                  |
| メール経由しない通知 | 一部の運用イベントは inbox のみ                                                         |

## 7.9 9. エラー別メッセージ対応表

(エラー設計書 06 の全エラー ID に対するメッセージ ID の対応)

| エラー ID               | メッセージ ID               | 表示文言 (再掲)                         | 補足              |
|----------------------|------------------------|-----------------------------------|-----------------|
| E-OP-IP-DENIED       | MSG-OP-IP-DENIED       | (HTTP 401、画面表示なし)                 | IP allowlist 拒否 |
| E-OP-MFA-FAILED      | MSG-OP-MFA-FAILED      | 認証に失敗しました。MFA コードを確認してください        | TOTP 失敗         |
| E-OP-AUTH-LOCKED     | MSG-OP-MFA-LOCKED      | ログイン試行回数が上限に達しました。15 分後に再試行してください | ロックアウト          |
| E-OP-REAUTH-REQUIRED | MSG-OP-REAUTH-REQUIRED | 再認証が必要です。パスワードを入力してください           | 再認証             |

| エラー ID                      | メッセージ ID                     | 表示文言 (再掲)                               | 補足           |
|-----------------------------|------------------------------|-----------------------------------------|--------------|
| E-OP-4EYES-REQUIRED         | MSG-OP-4EYES-NOT-APPROVED    | 承認が必要な操作です。SCR-APPROVALS から申請してください     | 4-eyes 未承認   |
| E-OP-4EYES-HARDGATE         | MSG-OP-4EYES-HARDGATE-OFF    | 現在この操作は無効化されています (運営側で有効化が必要)           | KV フラグ false |
| E-OP-4EYES-SELF             | MSG-OP-4EYES-SELF            | 自分の申請は承認できません (他の運営者の承認が必要です)           | 自己承認         |
| E-OP-4EYES-EXPIRED          | MSG-OP-4EYES-EXPIRED         | 承認の有効期限が切れました。再申請してください                 | TTL 切れ       |
| E-OP-4EYES-PAYLOAD-CHANGED  | MSG-OP-4EYES-PAYLOAD-CHANGED | 申請内容が変更されている可能性があります (payload_hash 不一致) | 改ざん検知        |
| E-OP-WEBHOOK-REPLAY-EXPIRED | MSG-SCR-097-ERROR-001        | 受信から 30 日を超えたためリプレイできません (R2 退避済み)      | 枠超過          |
| E-OP-RESTORE-LOCKED         | MSG-SCR-091-ERROR-001        | 他の運営者が処理中のため復元できません                     | 競合           |
| (他多数)                       |                              |                                         |              |

## 7.10 10. 未決事項

| No | 内容                                                           | 確認先               | ステータス                |
|----|--------------------------------------------------------------|-------------------|----------------------|
| 1  | announcement_drafts.severity 3 値と通知重要度 4 値 (critical 含む) の対応 | テーブル定義書 04 § 3.12 | critical 通知は別建てパスで対応 |
| 2  | エラー別メッセージ対応表 (§ 9) の全件埋め込み                                   | エラー設計書 06         | 主要項目のみ初版収載           |

## 7.11 11. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

# 8 トレーサビリティマトリクス (運営者)

## 8.1 1. 文書概要

### 8.1.1 1.1 目的

運営者側の要件 → 機能 → 画面 → API → DB → 権限 → エラー → メッセージ → テスト観点 の対応関係を一元化する。

### 8.1.2 1.2 対象範囲

- 対象: 運営者側全要件 (FR-220～232 / FR-300～310 / NFR-602 / NFR-602d / NFR-707 / NFR-808-810 等)、運営者機能 (F-OP-\*)、運営者画面 (SCR-090～099 / SCR-AUTH / SCR-AUTH-M1 / SCR-HOME / SCR-APPROVALS / M1 / M2)、運営者 API、運営者専用テーブル (19 個)
- 対象外: 利用者側要件 ([01\\_メインシステム/個別設計書群/08\\_トレーサビリティマトリクス.md](#) 参照)

### 8.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

### 8.1.4 1.4 関連ドキュメント

| ドキュメント名            | 役割                      | 参照先                                        |
|--------------------|-------------------------|--------------------------------------------|
| 索引                 | 11 ドキュメント体系の俯瞰          | 00_ 索引.md                                  |
| 要件定義書 (運営者)        | 要件 ID の正本               | ../01_ 要件定義書.md                            |
| 画面設計書              | SCR ID                  | 02_ 画面設計書.md                               |
| API 設計書            | API ID                  | 03_ API 設計書.md                             |
| テーブル定義書            | テーブル名                   | 04_ テーブル定義書.md                             |
| 権限設計書              | 4-eyes 対象 10 操作         | 05_ 権限設計書.md                               |
| エラー設計書             | E-OP-* エラー ID           | 06_ エラー設計書.md                              |
| メッセージ一覧            | メッセージ ID                | 07_ メッセージ一覧.md                             |
| 認証・認可設計書           | 6 段階認可 / 4-eyes フロー     | 09_ 認証認可設計書.md                             |
| セキュリティ設計書          | ハッシュチェーン / 3 区分保持       | 10_ セキュリティ設計書.md                           |
| 課金・請求設計書           | Stripe Webhook / 月次請求確定 | 11_ 課金請求設計書.md                             |
| 共有概念対応表            | SCR / IF 体系             | ../共有/共有概念.md                              |
| メイン側 トレーサビリティマトリクス | 利用者側要件対応                | ../01_ メインシステム/個別設計書群/08_ トレーサビリティマトリクス.md |

## 8.2 2. 要件・設計対応表 (主要 FR / NFR)

| 要件 ID      | 要件名                    | 機能 ID             | 画面 ID                   | API                                                           | テーブル                                              | 4-eyes 種別                 | エラー ID               | 連携 IF  |
|------------|------------------------|-------------------|-------------------------|---------------------------------------------------------------|---------------------------------------------------|---------------------------|----------------------|--------|
| FR-200~205 | 削除データ参照                | F-OP-DELETE-001   | SCR-090                 | GET /admin/v1/deleted-resources                               | (各種削除済みソース)                                       | -                         | -                    | -      |
| FR-206~209 | 削除データ復元                | F-OP-DELETE-002   | SCR-091                 | POST /admin/v1/restorations                                   | audit_logs                                        | 承認ログ (owner.restore_data) | E-OP-DELETE-*        | IF #4  |
| FR-211     | 運営者操作通知                | F-OP-NOTIF-001    | (全 SCR)                 | (IF #12 経由)                                                   | audit_logs                                        | -                         | -                    | IF #12 |
| FR-220     | 運営者アカウント               | F-OP-AUTH-001     | SCR-AUTH                | POST /admin/v1/auth/login                                     | service_operators                                 | -                         | E-OP-AUTH-*          | -      |
| FR-221     | MFA 必須                 | F-OP-AUTH-002     | SCR-AUTH-M1             | POST /admin/v1/auth/mfa/verify, POST /admin/v1/auth/mfa/setup | operator_mfa_secrets, operator_mfa_recovery_codes | -                         | E-OP-MFA-*           | -      |
| FR-222     | 再認証                    | F-OP-AUTH-004     | (各 SCR モーダル)            | POST /admin/v1/me/reauth                                      | operator_sessions                                 | -                         | E-OP-REAUTH-REQUIRED | -      |
| FR-223     | 削除データ参照 (復元判断用)        | F-OP-DELETE-001   | SCR-090                 | GET /admin/v1/deleted-resources                               | (各種)                                              | -                         | -                    | -      |
| FR-224     | 不正利用検知への運営者対応 (b: 上書き) | F-OP-OVERRIDE-001 | SCR-093                 | PUT /admin/v1/overrides/limit/{owner_id}                      | owner_quota_overrides                             | 承認ログ                      | -                    | IF #5  |
| FR-225     | service_operator 単一ロール | F-OP-AUTH-001     | (全運営者画面)                | (全運営者 API)                                                    | service_operators                                 | -                         | -                    | -      |
| FR-226     | 4-eyes 承認              | F-OP-4EYES-001    | SCR-APPROVALS / M1 / M2 | POST /admin/v1/approvals*                                     | operator_approvals                                | フロー中核                     | E-OP-4EYES-*         | -      |

| 要件 ID                    | 要件名                                  | 機能 ID             | 画面 ID              | API                                                         | テーブル                                              | 4-eyes 種別                     | エラー ID                                         | 連携 IF  |
|--------------------------|--------------------------------------|-------------------|--------------------|-------------------------------------------------------------|---------------------------------------------------|-------------------------------|------------------------------------------------|--------|
| FR-229                   | 運営者操作監査                              | F-OP-AUDIT-001    | SCR-096            | (全 API で自動記録)                                               | audit_logs                                        | -                             | -                                              | -      |
| FR-230                   | 全契約横断ダッシュボード                         | F-OP-HOME-001     | SCR-HOME / SCR-096 | GET /admin/v1/home, GET /admin/v1/audit-logs                | (各種集計)                                            | -                             | -                                              | -      |
| FR-231                   | 操作チケット ID(ticket_id)                 | F-OP-AUDIT-001    | (各 4-eyes 操作画面)    | (X-Op-Ticket-Id ヘッダ + Request Body)                         | audit_logs.ticket_id                              | -                             | E-OP-INPUT-TICKET-REQUIRED                     | -      |
| FR-232                   | 監査ログ閲覧・エクスポート                        | F-OP-AUDIT-001    | SCR-096            | GET /admin/v1/audit-logs, POST /admin/v1/audit-logs/exports | audit_logs                                        | -                             | -                                              | -      |
| FR-300~303               | 課金                                   | F-OP-BILL-001     | SCR-015 派生         | (月次請求確定 cron)                                               | billing_invoices, usage_metering                  | -                             | -                                              | IF #10 |
| FR-302                   | Stripe Webhook 受信                    | F-OP-WEBHOOK-001  | SCR-097 / SCR-099  | POST /webhooks/stripe, POST /admin/v1/webhooks/replay       | webhook_events, webhook_payload_diffs, replay_log | 承認ログ (webhook.replay)         | E-OP-WEBHOOK-*                                 | IF #10 |
| FR-303                   | 月次請求確定通知                             | F-OP-BILL-001     | (cron)             | (月次集計 cron)                                                 | billing_invoices                                  | -                             | -                                              | IF #10 |
| FR-304                   | SaaS 全体利用状況                          | F-OP-HOME-001     | SCR-HOME           | GET /admin/v1/home                                          | -                                                 | -                             | -                                              | IF #8  |
| FR-149 / FR-188 / FR-189 | 運営者からのお知らせ配信                         | F-OP-NOTIF-002    | SCR-094            | POST /admin/v1/announcements*                               | announcement_reports                              | 承認ログ (announcement.send 即時のみ) | E-OP-INPUT-XSS-DETECTED                        | IF #7  |
| FR-055 / FR-061-066      | AI パラメータ管理                           | F-OP-AI-001       | SCR-092            | PUT /admin/v1/ai-parameters/{scope}/{id}                    | ai_parameter_overrides                            | 承認ゲート (ai_parameter_update)   | E-OP-4EYES-UPDATE                              | IF #6  |
| FR-060 / FR-064          | PII 報告管理                             | F-OP-PII-001      | SCR-098            | POST /admin/v1/pii-rules/revisions                          | pii_false_positive_reports                        | 承認ログ (pii_rule.update)        | E-OP-PII-*                                     | -      |
| FR-121 / FR-128          | 利用量・レート制限                            | F-OP-OVERRIDE-001 | SCR-093            | PUT /admin/v1/overrides/*                                   | owner_quota_overrides                             | 承認ログ                          | -                                              | IF #5  |
| NFR-110                  | 同時アクティブ契約 200                        | -                 | -                  | -                                                           | -                                                 | -                             | E-QUOTA-CONTRACT-LIMIT                         | -      |
| NFR-114                  | 同時オンライン管理者 1,000 / ウィジェット同時接続 10,000 | -                 | -                  | -                                                           | -                                                 | -                             | E-QUOTA-ONLINE-ADMIN / E-QUOTA-WIDGET-PARALLEL | -      |



| 要件 ID   | 要件名                                | 機能 ID                           | 画面 ID                   | API                            | テーブル                                     | 4-eyes 種別     | エラー ID                      | 連携 IF  |
|---------|------------------------------------|---------------------------------|-------------------------|--------------------------------|------------------------------------------|---------------|-----------------------------|--------|
| NFR-304 | Argon2id 運営者強化プロファイル               | F-OP-AUTH-001                   | (パスワード hash)            | -                              | service_operators                        | password_hash | -                           | -      |
| NFR-306 | ハッシュチェーン改ざん検知                      | F-OP-AUDIT-001                  | SCR-096                 | (バッチ AuditChainVerifierWorker) | audit_logs                               | -             | E-OP-SYS-HASH-CHAIN-BROKEN  | -      |
| NFR-311 | 運営者認証 (MFA / IP allowlist / 5y 保持) | F-OP-AUTH-*                     | SCR-AUTH                | -                              | operator_*                               | -             | E-OP-AUTH-* / E-OP-IP-*     | -      |
| NFR-321 | ローテーション 60 日 dual-decrypt          | -                               | -                       | -                              | (Cloudflare Secrets Store)               | -             | -                           | -      |
| NFR-330 | 脆弱性対応 SLA                          | -                               | -                       | -                              | -                                        | -             | -                           | -      |
| NFR-602 | 3 区分保持 (1y / 5y / 7y)              | F-OP-AUDIT-001                  | -                       | -                              | audit_logs.retention_class               | -             | -                           | -      |
| NFR-707 | accounts_retired 永久保持              | F-OP-DELETE-002                 | SCR-091                 | POST /admin/v1/restorations    | accounts_retired                         | -             | -                           | -      |
| NFR-805 | PII 検出 3 営業日 SLA                   | F-OP-PII-001                    | SCR-098                 | -                              | pii_false_positive_reports               | -             | E-OP-PII-SLA-EXPIRED        | -      |
| NFR-808 | Webhook 受信失敗率 5% 監視                | F-OP-WEBHOOK-001                | SCR-097 / SCR-HOME      | -                              | webhook_events                           | -             | -                           | IF #10 |
| NFR-809 | DLQ 4 日 (Queues)+ 30 日 (R2)        | F-OP-WEBHOOK-001                | SCR-097                 | POST /admin/v1/webhooks/replay | webhook_events承認ログ<br>replay_log         | -             | E-OP-WEBHOOK-REPLAY-EXPIRED | -      |
| AC-036  | PII 3 営業日判定                        | F-OP-PII-001                    | SCR-098                 | -                              | pii_false_positive_reports.review_due_at | -             | -                           | -      |
| AC-037  | 運営者 MFA + 再認証                      | F-OP-AUTH-*                     | SCR-AUTH-M1 / 各操作前モジュール | -                              | -                                        | -             | -                           | -      |
| AC-038  | 運営者操作監査 + 通知                       | F-OP-AUDIT-001 / F-OP-NOTIF-001 | SCR-096                 | (全 API で自動記録)                  | audit_logs                               | -             | -                           | IF #12 |
| AC-041  | Webhook ペイロード差分検出                  | F-OP-WEBHOOK-002                | SCR-099                 | GET /admin/v1/webhook-diffs    | webhook_payload_diffs                    | -             | -                           | IF #10 |

### 8.3 3. 機能・画面・API 対応表

| 機能 ID         | 機能名             | 画面 ID       | API ID                                                        | テーブル名                                             | 4-eyes 種別 |
|---------------|-----------------|-------------|---------------------------------------------------------------|---------------------------------------------------|-----------|
| F-OP-AUTH-001 | 認証 (ログイン)       | SCR-AUTH    | POST /admin/v1/auth/login                                     | service_operators, operator_sessions              | -         |
| F-OP-AUTH-002 | MFA セットアップ / 検証 | SCR-AUTH-M1 | POST /admin/v1/auth/mfa/setup, POST /admin/v1/auth/mfa/verify | operator_mfa_secrets, operator_mfa_recovery_codes | -         |

| 機能 ID             | 機能名                               | 画面 ID                          | API ID                                                      | テーブル名                                           | 4-eyes 種別                   |
|-------------------|-----------------------------------|--------------------------------|-------------------------------------------------------------|-------------------------------------------------|-----------------------------|
| F-OP-AUTH-003     | IP allowlist                      | (運用)                           | (KV キャッシュ)                                                  | operator_ip_allowlist                           | -                           |
| F-OP-AUTH-004     | 再認証 (5 分以内)                       | (モーダル)                         | POST /admin/v1/me/reauth                                    | operator_sessions.reauthenticat                 | authenticated_at            |
| F-OP-HOME-001     | ホームダッシュボード                        | SCR-HOME                       | GET /admin/v1/home                                          | (各種集計)                                          | -                           |
| F-OP-DELETE-001   | 削除データ参照                           | SCR-090                        | GET /admin/v1/deleted-resources                             | (各種)                                            | -                           |
| F-OP-DELETE-002   | 削除データ復元                           | SCR-091                        | POST /admin/v1/restorations                                 | accounts_retired, audit_logs                    | 承認ログ                        |
| F-OP-AI-001       | AI パラメータ設定                        | SCR-092                        | PUT /admin/v1/ai-parameters/{scope}/{id}                    | ai_parameter_overrides                          | ハードゲート                      |
| F-OP-OVERRIDE-001 | 契約別レート / 予算上書き                    | SCR-093                        | PUT /admin/v1/overrides/*                                   | owner_quota_overrides                           | 承認ログ                        |
| F-OP-NOTIF-001    | お知らせ作成 / 配信                       | SCR-094                        | POST /admin/v1/announcements*                               | announcement_drafts, service_announcements      | 承認ログ (即時配信のみ)               |
| F-OP-AUDIT-001    | 監査ログ閲覧 / エクスポート                   | SCR-096                        | GET /admin/v1/audit-logs, POST /admin/v1/audit-logs/exports | audit_logs                                      | -                           |
| F-OP-WEBHOOK-001  | Stripe Webhook リプレイ               | SCR-097                        | POST /admin/v1/webhooks/replay                              | webhook_events, dlq_replay_log                  | 承認ログ                        |
| F-OP-PII-001      | PII 誤検出報告管理                       | SCR-098                        | POST /admin/v1/pii-rules/revisions                          | pii_false_positive_reports, pii_rules_revisions | 承認ログ                        |
| F-OP-WEBHOOK-002  | ペイロード差分検出                         | SCR-099                        | GET /admin/v1/webhook-diffs                                 | webhook_payload_diffs                           | -                           |
| F-OP-4EYES-001    | 4-eyes 申請 / 承認                    | SCR-APPROVALS / M1 / M2        | POST /admin/v1/approvals*                                   | operator_approvals                              | フロー中核                       |
| F-OP-BILL-001     | 月次請求確定 cron / Stripe Webhook 一次受信 | (cron / POST /webhooks/stripe) | -                                                           | billing_invoices, webhook_events                | -                           |
| F-OP-LEGAL-001    | GDPR 越境移転対応                       | (運用 + 4-eyes)                  | -                                                           | owner_registration_reviews                      | 承認ログ (owner.legal_review.*) |

## 8.4 4. 画面・メッセージ対応表 (主要)

| 画面 ID       | 画面名         | 主要メッセージ ID        | 種別                                            |
|-------------|-------------|-------------------|-----------------------------------------------|
| SCR-AUTH    | 運営者ログイン     | MSG-SCR-AUTH-*    | TITLE / LBL / BTN / ERROR                     |
| SCR-AUTH-M1 | MFA セットアップ  | MSG-SCR-AUTH-M1-* | TITLE / STEP / WARN / SUCCESS                 |
| SCR-HOME    | ホーム         | MSG-SCR-HOME-*    | TITLE / WARN(緊急アラート)                          |
| SCR-090     | 削除データ参照     | MSG-SCR-090-*     | TITLE / CHIP / MSG / TOOLTIP                  |
| SCR-091     | 削除データ復元     | MSG-SCR-091-*     | TITLE / LBL / PH / WARN / BTN / TOAST / ERROR |
| SCR-092     | AI パラメータ    | MSG-SCR-092-*     | TITLE / BANNER / MSG / TOAST / ERROR          |
| SCR-093     | 契約別レート / 予算 | MSG-SCR-093-*     | TITLE / BTN / TOOLTIP / CONFIRM_MSG / TOAST   |

| 画面 ID            | 画面名                | 主要メッセージ ID             | 種別                                             |
|------------------|--------------------|------------------------|------------------------------------------------|
| SCR-094          | お知らせ作成・配信          | MSG-SCR-094-*          | TITLE / BTN(4 ステッパー) / MSG / TOAST             |
| SCR-096          | 監査ダッシュボード          | MSG-SCR-096-*          | TITLE / BADGE / WARN / TOAST                   |
| SCR-097          | Webhook リプレイ・DLQ   | MSG-SCR-097-*          | TITLE / WARN / CONFIRM_MSG / ERROR             |
| SCR-098          | PII 誤検出報告          | MSG-SCR-098-*          | TITLE / BANNER / BADGE / WARN / TOAST          |
| SCR-099          | ペイロード差分            | MSG-SCR-099-*          | TITLE / BTN / CONFIRM_MSG                      |
| SCR-APPROVALS    | 承認待ち一覧             | MSG-SCR-APPROVALS-*    | TITLE / CHIP / MSG / EMPTY                     |
| SCR-APPROVALS-M1 | 4-eyes 申請モダール      | MSG-SCR-APPROVALS-M1-* | TITLE / DESC / LBL / MSG / BTN / TOAST / ERROR |
| SCR-APPROVALS-M2 | 4-eyes 承認 / 却下モダール | MSG-SCR-APPROVALS-M2-* | TITLE / WARN / ERROR / TOAST                   |

詳細は [07\\_メッセージ一覧.md §4](#) を正本とする。

## 8.5 5. API・エラー対応表

| API                                   | エラー ID                         | メッセージ ID                     | ステータスコード              |
|---------------------------------------|--------------------------------|------------------------------|-----------------------|
| POST /admin/v1/auth/login             | E-OP-IP-DENIED                 | (画面表示なし)                     | 401 即時                |
| POST /admin/v1/auth/login             | E-OP-AUTH-CREDENTIAL           | MSG-SCR-AUTH-ERROR-004       | 401                   |
| POST /admin/v1/auth/login             | E-OP-AUTH-LOCKED               | MSG-SCR-AUTH-ERROR-002       | 423                   |
| POST /admin/v1/auth/mfa/verify        | E-OP-MFA-FAILED                | MSG-SCR-AUTH-ERROR-003       | 401                   |
| POST /admin/v1/auth/mfa/setup         | E-OP-MFA-SETUP-EXPIRED         | MSG-SCR-AUTH-M1-ERROR-001    | 401                   |
| POST /admin/v1/approvals              | E-OP-4EYES-*                   | MSG-OP-4EYES-*               | 409 / 410 / 422       |
| POST /admin/v1/approvals/{id}/approve | E-OP-4EYES-SELF                | MSG-OP-4EYES-SELF            | 422                   |
| POST /admin/v1/approvals/{id}/approve | E-OP-4EYES-EXPIRED             | MSG-OP-4EYES-EXPIRED         | 410                   |
| POST /admin/v1/approvals/{id}/approve | E-OP-4EYES-PAYLOAD-CHANGED     | MSG-OP-4EYES-PAYLOAD-CHANGED | 409                   |
| POST /admin/v1/restorations           | E-OP-RESTORE-LOCKED            | MSG-SCR-091-ERROR-001        | 423 Locked            |
| PUT /admin/v1/ai-parameters/*         | E-OP-4EYES-REQUIRED            | MSG-OP-4EYES-NOT-APPROVED    | 403                   |
| PUT /admin/v1/ai-parameters/*         | E-OP-4EYES-HARDGATE            | MSG-OP-4EYES-HARDGATE-OFF    | 403                   |
| POST /admin/v1/webhooks/replay        | E-OP-WEBHOOK-REPLAY-EXPIRED    | MSG-SCR-097-ERROR-001        | 410                   |
| POST /webhooks/stripe                 | E-OP-WEBHOOK-SIGNATURE-INVALID | (運営者通知)                      | 401 + 監査 + high alert |
| (各 4-eyes 操作)                         | E-OP-INPUT-TICKET-REQUIRED     | MSG-OP-4EYES-TICKET-REQUIRED | 400                   |

詳細は [06\\_エラー設計書.md](#) と [07\\_メッセージ一覧.md](#) を正本とする。

## 8.6 6. 4-eyes × 画面 × API 対応表 (運営者側固有)

| 4-eyes action code            | 種別 (ハードゲート / 承認ログ) | 画面 ID      | API                                                    | retention_classification | ticket_id |
|-------------------------------|--------------------|------------|--------------------------------------------------------|--------------------------|-----------|
| owner.physical_delete         | ハードゲート             | SCR-091 派生 | DELETE /admin/v1/owners/{id}/physical                  | 7y(billing)              | ○         |
| ai_parameter.update           | ハードゲート             | SCR-092    | PUT /admin/v1/ai-parameters/{scope}/{id}               | 5y(operator_high_priv)   | ○         |
| master_key.rotate             | ハードゲート             | (CLI)      | (CLI)                                                  | 5y                       | ○         |
| owner.suspend / owner.restore | 承認ログ               | SCR-091 派生 | POST /admin/v1/owners/{id}/suspend, /restore(IF #1 経由) | 5y                       | ○         |
| rate_limit.override           | 承認ログ               | SCR-093    | PUT /admin/v1/overrides/rate-limit/{owner_id}          | 5y                       | ○         |
| budget.override               | 承認ログ               | SCR-093    | PUT /admin/v1/overrides/budget/{owner_id}              | 5y                       | ○         |
| owner.force_stop              | 承認ログ               | SCR-093 派生 | POST /admin/v1/owners/{id}/force-stop                  | 5y                       | ○         |
| owner.restore_data            | 承認ログ               | SCR-091    | POST /admin/v1/restorations                            | 5y                       | ○         |
| webhook.replay                | 承認ログ               | SCR-097    | POST /admin/v1/webhooks/replay                         | 5y                       | ○         |
| owner.legal_review            | 承認ログ               | SCR-098 派生 | POST /admin/v1/legal-review                            | 7y                       | ○         |

## 8.7 7. 連携 IF × ドキュメント対応表

(運営者側索引 [00\\_索引.md §5](#) と連動)

| IF# | 方向              | 概要         | 主管     | テーブル                  | 監査 action                     |
|-----|-----------------|------------|--------|-----------------------|-------------------------------|
| #1  | 顧管 → メ          | 契約停止イベント   | 本書(送信) | audit_logs            | owner.suspend / owner.restore |
| #2  | 顧管 → メ          | 強制ログアウト    | 本書(送信) | audit_logs            | auth.forced_logout            |
| #4  | 顧管 → メ          | 復元実行       | 本書(送信) | audit_logs            | owner.restore_data            |
| #5  | 顧管 → メ          | レート制限上書き   | 本書(送信) | owner_quota_override  | rate_limit.override           |
| #6  | 顧管 → メ          | AI しきい値上書き | 本書(送信) | ai_parameter_override | ai_parameter.update           |
| #7  | 顧管 → メ          | お知らせ生成     | 本書(送信) | announcement_draft    | announcement.send             |
| #8  | メ → 顧管          | 監視メトリクス取得  | 本書(受信) | -                     | -                             |
| #9  | メ → 顧管          | 不正利用検知通知   | 本書(受信) | -                     | abuse.detection_received      |
| #10 | Stripe → 顧管 → メ | 課金 Webhook | 本書(送信) | webhook_events        | stripe.event.processed        |
| #12 | 顧管 → メ → 利用者    | 運営者操作通知    | 本書(送信) | -                     | (各 action のサブ通知)              |

## 8.8 8. テスト観点との対応 (運営者側固有)

### 8.8.1 8.1 運営者側テスト観点 6 列の定義

| 列                  | 観点           | 説明                                      |
|--------------------|--------------|-----------------------------------------|
| 正常系                | ハッピーパス       | 標準ユースケース                                |
| 異常系                | エラーパス        | エラー設計書 06 の各エラーが発火するか                   |
| 境界値                | 上限・下限        | TTL(72h、5 分)/リトライ回数(3 回)/レート制限          |
| 権限・4-eyes          | 4-eyes 自動テスト | 自己承認禁止 / ハードゲート KV / payload_hash 改ざん検知 |
| IP allowlist / MFA | 認証・認可テスト     | 未許可 IP の 401 / MFA 失敗 5 回ロックアウト         |
| 監査ログ               | 全件記録テスト      | 全操作が audit_logs に記録され、ハッシュチェーンが正しいか     |

### 8.8.2 8.2 主要要件のテスト観点表

| 要件 ID                          | 機能 ID            | 正常系                | 異常系                        | 境界値                 | 権限・4-eyes                 | IP allowlist / MFA      | 監査ログ                                                    |
|--------------------------------|------------------|--------------------|----------------------------|---------------------|---------------------------|-------------------------|---------------------------------------------------------|
| FR-221(MFA 必須)                 | F-OP-AUTH-002    | TOTP 6 桁正常         | TOTP 失敗で 401               | 5 回失敗境界             | -                         | 5 回ロック                  | operator.mfa.verify                                     |
| FR-222(再認証 5 分)                | F-OP-AUTH-004    | 5 分以内の操作 OK        | 5 分超で 403                  | 4 / 5 / 6 分境界       | -                         | 再認証パスワード 必須             | operator.reauth                                         |
| FR-226(4-eyes 承認)              | F-OP-4EYES-001   | 別運営者承認 → 実行        | 自己承認で 422 / TTL 72h 超で 410 | TTL 72h 境界          | 自己承認 禁止 + payload_hash 検証 | -                       | operator_approval.*(5y)                                 |
| FR-302(Stripe Webhook 受信)      | F-OP-WEBHOOK-001 | 署名 OK + 内部 転送成功    | 署名 NG で 401 / ペイロード 差分検出   | DLQ 30 日境界          | -                         | -                       | webhook.signaturefailed / webhook.payload_diff_detected |
| NFR-306(ハッシュチェーン)              | F-OP-AUDIT-001   | 検証バッチ OK           | 改ざんで critical 通知           | -                   | -                         | -                       | audit.chain.verify.fail                                 |
| NFR-602(3 区分保持)                | F-OP-AUDIT-001   | 区分別に保持             | 期間超過で 物理削除 + tombstone     | 1y / 5y / 7y 境界     | -                         | -                       | 全 action                                                |
| NFR-707(accounts Deleted 永久保持) | F-OP-DELETE-002  | 物理削除時に 永久保持レコード 作成 | -                          | -                   | -                         | -                       | owner.physical_delete                                   |
| NFR-805(PII 3 営業日 SLA)         | F-OP-PII-001     | 3 営業日以内に 判定        | SLA 超過で 警告                 | 2 / 3 / 4 営業日 境界    | -                         | -                       | pii_report.review                                       |
| NFR-808(Webhook 失敗率)           | F-OP-WEBHOOK-001 | 通常 < 5%            | 5% 超過で high 通知             | 4.9 / 5.0 / 5.1% 境界 | -                         | -                       | -                                                       |
| NFR-809(DLQ 30 日リプレイ)          | F-OP-WEBHOOK-001 | 30 日以内のリプレイ可       | 30 日超で 410                 | 29 / 30 / 31 日境界    | 承認ログ                      | -                       | webhook.replay                                          |
| (4-eyes ハードゲート KV)             | F-OP-AI-001      | KV true で実行        | KV false で 403             | -                   | KV ハードゲート                 | -                       | feature.hard_gate.toggle                                |
| (オーナー境界)                       | (運営者は適用外、全契約横断)  | 全契約横断アクセス可         | -                          | -                   | 6 段認可                     | IP / MFA / 再認証 / 4-eyes | 全 action                                                |

## 8.9 9. 不足・不整合一覧

| No | 種別     | 対象 ID                                                                      | 内容                    | 影響     | 推奨対応                 |
|----|--------|----------------------------------------------------------------------------|-----------------------|--------|----------------------|
| 1  | DB 未定義 | owner_registration_reviews / webhook_replay_requests / pii_rules_revisions | 基本設計のみ言及、詳細設計に DDL なし | 正式定義待ち | 04_テーブル定義書.md §12 参照 |

## 8.10 10. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

## 8.11 11. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

## 9 認証・認可設計書 (運営者)

### 9.1 1. 文書概要

#### 9.1.1 1.1 目的

運営者システムの認証(ログイン/MFA/セッション/パスワードリセット)、認可(6 段判定 / 4-eyes 承認フロー)、IP allowlist、再認証(5 分以内)、運営者アカウント・ライフサイクルを一元化する。

#### 9.1.2 1.2 対象範囲

- 対象: 運営者の認証・認可全般
- 対象外: 利用者の認証・認可(01\_メインシステム/個別設計書群/09\_認証認可設計書.md 参照)

#### 9.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

#### 9.1.4 1.4 関連ドキュメント

| ドキュメント名       | 役割                                | 参照先                                |
|---------------|-----------------------------------|------------------------------------|
| 索引            | 11 ドキュメント体系の俯瞰                    | 00_索引.md                           |
| 権限設計書         | 4-eyes 対象 10 操作                   | 05_権限設計書.md                        |
| セキュリティ設計書     | 監査・ログ / 管理(参照)                    | 10_セキュリティ設計書.md                    |
| API 設計書       | 認証 API / 4-eyes API               | 03_API 設計書.md                      |
| エラー設計書        | 認証・認可エラー                          | 06_エラー設計書.md                       |
| テーブル定義書       | operator_* / operator_approvals   | 04_テーブル定義書.md                      |
| メイン側 認証・認可設計書 | 利用者認証(IP allowlist 契約単位オプトインの参照元) | ../01_メインシステム/個別設計書群/09_認証認可設計書.md |

### 9.2 2. 認証方式

| 認証方式               | 利用有無  | 概要                                                | 備考           |
|--------------------|-------|---------------------------------------------------|--------------|
| メールアドレス / パスワード    | ○     | Argon2id 運営者強化プロファイル(m=128MB, t=4, p=4, salt=16B) | パスワード要件は § 5 |
| MFA(TOTP RFC 6238) | ○(必須) | HMAC-SHA1, 6 桁, 30 秒                              | § 4          |
| 回復コード              | ○     | 10 個、Argon2id ハッシュ、1 回限り                          | § 4          |
| IP allowlist       | ○     | ホワइटリスト方式(共有概念正本)                                 | § 3          |
| パスワードリセット          | ○     | 60 分有効、自己リセット禁止 → 別運営者承認経由                        | § 6          |
| SSO / SAML         | ×     | MVP 範囲外                                           | Future       |

### 9.3 3. IP allowlist(共有概念正本)

(§ 10.2 から移管)

| 項目        | 仕様                                                                        |
|-----------|---------------------------------------------------------------------------|
| 適用箇所      | 運営者 Worker(admin.open-faq.example.com) の入口                                |
| データ       | operator_ip_allowlist(operator_id, cidr, description, granted_at)         |
| 評価方式      | リクエスト元 IP が許可 CIDR にマッチするかを KV で即時参照(TTL 60s)                             |
| 未許可時の応答   | 403 Forbidden(ログイン画面さえ表示しない)                                              |
| ホワइटリスト推奨 | 本社 IP・VPN IP・運営者自宅 IP                                                     |
| 一時例外      | メイン要件 § 6.2.1 緊急区分(特に区分 2 全員ロックアウト)+ § 6.2.2 発動条件成立時に限り、別運営者の追加で許可 + 監査記録 |

| 項目    | 仕様                                                                 |
|-------|--------------------------------------------------------------------|
| KV キー | ip-allowlist:<operator_id>                                         |
| 変更操作  | 4-eyes 承認ログ (audit_logs.action = ip_allowlist.update、retention=5y) |

メイン側 認証・認可設計書では「**契約単位 IP allowlist オプトイン**」として本書を参照する (契約別に有効化できる Future 機能の正本)。

## 9.4 4. MFA(TOTP)

(§10.3 から移管)

| 項目       | 仕様                                                    |
|----------|-------------------------------------------------------|
| 方式       | TOTP RFC 6238, HMAC-SHA1, 6 桁, 30 秒                   |
| 初回トークン   | SCR-AUTH-M1 で QR コード / シークレット表示、有効期限 72 時間            |
| 回復コード    | 10 個、Argon2id ハッシュ、1 回限り使用                            |
| シークレット保管 | operator_mfa_secrets(AES-256-GCM 暗号化、オーナー派生 で暗号化)     |
| MFA リセット | 自己リセット禁止、別運営者 + 組織内承認 (4-eyes 承認ログ)                   |
| ロックアウト   | TOTP 失敗 5 回で (IP × operator_id) を 15 分ロック             |
| 失敗時      | audit_logs.action = operator.mfa.failed(retention=5y) |

## 9.5 5. セッション・トークン設計

(§10.0 / §10.1 から移管)

| 項目           | 内容                                                                        |
|--------------|---------------------------------------------------------------------------|
| セッション方式      | Cookie + DB セッション (operator_sessions テーブル) + KV キャッシュ (TTL 60s)           |
| セッション TTL    | 8 時間 (MVP、D-18)                                                           |
| 再認証 (FR-005) | 5 分以内、操作 1 回限り (SCR-091 / 092 / 093 / 094 / 097 / 098 / 099 の高権限操作の前)     |
| Cookie 属性    | Secure; HttpOnly; SameSite=Lax; Path=/; Domain=admin.open-faq.example.com |
| パスワードハッシュ    | Argon2id 運営者強化プロファイル (m=128MB, t=4, p=4, salt=16B)                        |
| パスワード要件      | 12 文字以上、大文字 + 小文字 + 数字 + 記号各 1 文字以上                                       |
| ログイン失敗ロックアウト | 5 回失敗 → (IP × operator_id) を 15 分ロック (FR-007)                             |
| パスワードリセット    | 60 分有効、自己リセット禁止 → 別運営者承認経由 (NFR-311)                                      |
| 同時ログイン       | 複数デバイス可、SCR-090 でアクティブセッション一覧確認可                                          |
| 強制ログアウト      | 別運営者の操作で全セッション無効化 (KV キャッシュ 60s)                                          |
| CSRF         | Double Submit Cookie + X-CSRF-Token ヘッダ突合                                 |

### 9.5.1 5.1 重要操作の再認証 (FR-222) 対象

| 重要操作          | 関連画面    | API                                         |
|---------------|---------|---------------------------------------------|
| 削除データ復元       | SCR-091 | POST /admin/v1/restorations                 |
| AI パラメータ変更    | SCR-092 | PUT /admin/v1/ai-parameters/{scope}/{id}    |
| レート / 予算上書き   | SCR-093 | PUT /admin/v1/overrides/*                   |
| お知らせ予約 / 即時配信 | SCR-094 | POST /admin/v1/announcements/*              |
| Webhook リプレイ  | SCR-097 | POST /admin/v1/webhooks/replay              |
| PII ルール更新     | SCR-098 | POST /admin/v1/pii-rules/revisions          |
| ペイロード差分手動再処理  | SCR-099 | POST /admin/v1/webhook-diffs/{id}/reprocess |

## 9.6 6. 運営者アカウント・ライフサイクル (§3.5 から移管)

| イベント                  | 実行可能者                        | 監査記録                                                    |
|-----------------------|------------------------------|---------------------------------------------------------|
| 発行 (account.invite)   | 既存運営者 (MVP は全員)/ ブートストラップ管理者 | audit_logs(retention_class='5y')、action=operator.invite |
| MFA 初回設定              | 本人 (初回 72h セットアップトークン経由)     | 同上、action=operator.mfa.setup                            |
| MFA リセット              | 別運営者 + 組織内承認 (自己リセット禁止)      | 同上、action=operator.mfa.reset                            |
| パスワード再設定              | 別運営者 + 組織内承認 (自己リセット禁止)      | 同上、action=operator.password.reset                       |
| 無効化 (account.disable) | 既存運営者                        | 同上、action=operator.disable                              |
| 再有効化 (account.enable) | 既存運営者                        | 同上、action=operator.enable                               |

## 9.7 6.1 操作チケット ID 入力規約 (§3.6 から移管)

要件 FR-224 / FR-231 に従い、運営者の高権限操作には対応チケット ID の入力を必須化する。

| 項目      | 仕様                                                                      |
|---------|-------------------------------------------------------------------------|
| 形式      | 任意の文字列。推奨形式 INC-XXXXX(運営者側で規約定義)                                        |
| 入力場所    | SCR-091~094 / SCR-097(リプレイ操作)/ SCR-098(ルール更新)/ SCR-099(差分再処理) の各操作前モーダル |
| 監査記録    | audit_logs.ticket_id 列に保存、SCR-096 から逆引き検索可                              |
| バリデーション | 必須・空白除外・最大 64 文字                                                        |
| ヘッダ     | X-Op-Ticket-Id(各 API リクエストの Request Body にも ticket_id を必須フィールドとして含める)   |

## 9.8 7. 認可モデル

### 9.8.1 7.1 認可方式

単一ロール **service\_operator** + 4-eyes 多段ガード (本書 § 8)+ 全操作監査ログ (セキュリティ設計書 10 § 7)

### 9.8.2 7.2 オーナー境界

運営者はオーナー境界を適用しない (全契約横断アクセス)。代わりに以下のガード:

1. IP allowlist (§ 3)
2. MFA (§ 4)
3. 再認証 (5 分以内、§ 5)
4. ロール検証 (**service\_operator**)
5. 4-eyes 承認 (§ 8)
6. 監査ログ全件 (セキュリティ設計書 10 § 7)

### 9.8.3 7.3 6 段認可判定順序 (共有概念正本、§3.4 から移管)

flowchart TD

```

A[リクエスト到着] --> B{1. IP 許可リスト?}
B -->|NG| X1[401 Unauthorized 即時]
B -->|OK| C{2. セッション有効?}
C -->|NG| X2[401 / ログイン誘導]
C -->|OK| D{3. MFA 検証済?}
D -->|NG| X3[403 / MFA 強制セットアップ]
D -->|OK| E{4. user_type = service_operator?}
E -->|NG| X4[403 Forbidden]
E -->|OK| F{5. 操作が再認証対象?<br/>SCR-091/092/093/094/097/098/099}
F -->|Yes| G{再認証セッション有効?<br/>5 分以内}
F -->|No| H{6. 操作が 4-eyes 対象?}
G -->|NG| X5[403 / 再認証要求]
G -->|OK| H
H -->|Hard Gate 3 操作 | I{承認済み operator_approval が存在?}
H -->|Log Only 7 操作区分 | J[実行 + audit_logs 記録]
H -->|通常実行 | J

```



```

I -->|NG| X6[403 / 4-eyes 申請誘導]
I -->|OK| K{KV ハードゲートフラグ true?}
K -->|NG| X7[403 / ハードゲート無効]
K -->|OK| J
J --> L[200 OK + 監査記録]

```

各段階のエラー応答とメッセージは [06\\_エラー設計書.md §5](#) を参照。

## 9.9 8. 4-eyes 承認フロー (本書の中核、共有概念正本)

### 9.9.1 8.1 4-eyes 対象操作 (§3.3 から移管)

#### 9.9.1.1 MVP ハードゲート (3 操作・フルワークフロー必須)

| 対象操作                                   | 実装                                                                                         |
|----------------------------------------|--------------------------------------------------------------------------------------------|
| (1) 契約物理削除 (deleted_pending → deleted) | operator_approvals テーブルでの申請 → 別運営者承認 → 実行のフルワークフローを必須。承認なしの実行は API 層で拒否 (403)。承認待ち TTL 72h |
| (2) AI 推論パラメータ変更 (信頼度 / 関連度しきい値・モデル切替) | 同上                                                                                         |
| (3) マスター ローテーション                       | 同上                                                                                         |

#### 9.9.1.2 MVP 承認ログのみ (7 操作・単独実行許可)

| 対象操作                           | action code                           |
|--------------------------------|---------------------------------------|
| (4) 契約無効化 (active → suspended) | owner.suspend                         |
| (5) 契約復元 (削除猶予中 → active)      | owner.restore                         |
| (6) 従量単価表・無料枠の改定               | pricing.update                        |
| (7) 契約別レート制限・予算上限の上書き          | rate_limit.override / budget.override |
| (8) 緊急ウィジェット強制停止               | owner.force_stop                      |
| (9) 削除データの復元 (FR-204)          | owner.restore_data                    |
| (10) ハードゲート KV フラグ切替           | feature.hard_gate.toggle              |

### 9.9.2 8.2 ハードゲート KV フラグの管理

KV `feature:hard-gate:<action_code>` は **緊急一時無効化 (true → false 一時切替) のみ** (メイン要件 §6.2.1 区分3 セキュリティインシデント + §6.2.2 発動条件成立時に限る)。

フラグ変更操作は 4-eyes 承認ログ対象 (`feature.hard_gate.toggle`、`retention_class='5y'`)。

### 9.9.3 8.3 operator\_approvals データモデル (論理設計、§6.5 から移管)

物理スキーマは [04\\_テーブル定義書.md §3.6](#) を正本とする。論理設計:

| 要素            | 設計                                                                                                                                                    |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| データモデル        | operator_approvals(id, action_code, requested_by, approved_by, payload_hash, payload_json, state, requested_at, approved_at, executed_at, expires_at) |
| 承認待ち TTL      | 72 時間 (expires_at = requested_at + 72h)、超過は自動 expired                                                                                                 |
| 自己承認禁止        | DB CHECK 制約: requested_by IS NULL OR approved_by IS NULL OR requested_by != approved_by + アプリ層チェック                                                    |
| 自己却下禁止        | DB CHECK 制約: requested_by != rejected_by + アプリ層チェック                                                                                                   |
| payload 改ざん防止 | 承認時に payload_hash(SHA-256) を確定、実行時に再計算して照合。不一致は実行不可                                                                                                   |
| ハードゲート対象      | KV <code>feature:hard-gate:&lt;action_code&gt;</code> で動的制御 (MVP は 3 操作のみ true)                                                                       |
| 承認後 TTL       | 承認後 72h 以内未実行で expired、再申請が必要                                                                                                                         |
| 緊急例外手続き       | MVP では紙ベース回復コード手続き (§12.3 RB-014)                                                                                                                     |

#### 9.9.4 8.4 4-eyes 申請・承認状態遷移 (§4.5 から移管)

stateDiagram-v2

```

[*] --> requested: 運営者が申請 <br/>(action_code, payload_hash, ticket_id)
requested --> reviewing: 別運営者が確認開始
requested --> expired: 72h 経過 (自動)
requested --> withdrawn: 申請者本人が自己取下げ
reviewing --> approved: 別運営者が承認 <br/>(自己承認禁止)
reviewing --> rejected: 別運営者が却下 <br/>(自己却下禁止)
reviewing --> withdrawn: 申請者本人が自己取下げ
reviewing --> expired: 72h 経過 (自動)
approved --> executed: 申請者が実行操作 <br/>(payload_hash 再検証)
approved --> expired: 承認後 72h 未実行 <br/>(自動)
executed --> [*]
rejected --> [*]
withdrawn --> [*]
expired --> [*]

```

#### 9.9.5 8.5 申請 → 承認 → 実行フロー

1. 申請 (SCR-APPROVALS-M1): 申請者が action / payload / ticket\_id を入力。payload\_hash = SHA-256(payload\_json) を計算して保存
2. 通知: 全運営者へ inbox + email 通知 (high)
3. 承認 (SCR-APPROVALS-M2): 別運営者が再認証 → ペイロード確認 → 承認。payload\_hash 再計算で改ざん検証
4. 実行: 承認後 72h 以内に申請者が実行 (approval\_ttl\_expires\_at 検証)。X-Approval-Id: <approval\_id> ヘッダ必須
5. 監査: 申請・承認・実行を全て audit\_logs に記録 (retention\_class = 5y or 7y)

#### 9.9.6 8.6 自己承認禁止 / 自己却下禁止 / 取下げ規約

- ・ 承認: requested\_by != approved\_by (DB CHECK + アプリ層チェック)
- ・ 却下: requested\_by != rejected\_by (DB CHECK + アプリ層チェック)
- ・ 取下げ: 申請者本人 (requested\_by) のみ可。withdrawn 状態へ

### 9.10 9. セキュリティ二段ガード (運営者専用、§10.0.3)

運営者向けには以下の追加二段ガードを敷く (本書側で正本管理):

| ガード               | 内容                                         | 参照                  |
|-------------------|--------------------------------------------|---------------------|
| (a) IP 許可リスト      | § 3、未許可は 403 即時、ログイン画面さえ表示しない              | § 3                 |
| (b) MFA 必須        | § 4、未設定アカウントはログイン不可                        | § 4                 |
| (c) 重要操作の再認証      | § 5、5 分以内 + 操作 1 回限り                       | § 5                 |
| (d) 4-eyes 承認     | § 8、要件 § 6.2.3、MVP ハードゲート 3 操作 + 承認ログ 7 操作 | § 8                 |
| (e) ハードゲート KV フラグ | § 8.2、実装定数 + 緊急一時無効化のみ KV                  | § 8.2               |
| (f) 監査ログ 5 年保持    | NFR-602d、運営者高権限操作                          | 10_セキュリティ設計書.md § 7 |

#### 9.11 10. アカウント状態

| 状態          | 説明                | ログイン可否 | 操作制限           |
|-------------|-------------------|--------|----------------|
| 有効          | アクティブな運営者         | ○      | なし             |
| MFA 未セットアップ | 初回ログイン後           | △      | SCR-AUTH-M1 のみ |
| ロック中        | ログイン失敗 5 回        | ×      | 15 分後解除        |
| MFA リセット中   | リセット申請中           | ×      | 別運営者承認後解除      |
| 退職済み        | 退職処理完了 (disabled) | ×      | -              |

## 9.12 11. 認証・認可エラー

詳細は 06\_エラー設計書.md を正本とする。本書では主要エラーのみ。

| エラー ID                     | 発生条件             | メッセージ ID                     | ステータスコード | システム動作              |
|----------------------------|------------------|------------------------------|----------|---------------------|
| E-OP-IP-DENIED             | IP allowlist 不一致 | (画面表示なし)                     | 401 即時   | ログイン画面さえ表示しない       |
| E-OP-AUTH-CREDENTIAL       | パスワード不一致         | MSG-SCR-AUTH-ERROR-004       | 401      | 失敗カウント +1           |
| E-OP-AUTH-LOCKED           | 5 回失敗            | MSG-SCR-AUTH-ERROR-002       | 423      | 15 分ロック             |
| E-OP-MFA-FAILED            | TOTP 失敗          | MSG-SCR-AUTH-ERROR-003       | 401      | 失敗カウント +1           |
| E-OP-MFA-LOCKED            | TOTP 5 回失敗       | MSG-OP-MFA-LOCKED            | 423      | 15 分ロック             |
| E-OP-MFA-SETUP-EXPIRED     | セットアップトークン期限切れ   | MSG-SCR-AUTH-M1-ERROR-001    | 401      | 管理者へ再発行依頼           |
| E-OP-MFA-RECOVERY-USED     | 回復コード再利用         | MSG-SCR-AUTH-M1-ERROR-002    | 401      | -                   |
| E-OP-REAUTH-REQUIRED       | 再認証期限切れ          | MSG-OP-REAUTH-REQUIRED       | 403      | 再認証モーダル表示           |
| E-OP-4EYES-REQUIRED        | 4-eyes 未承認       | MSG-OP-4EYES-NOT-APPROVED    | 403      | SCR-APPROVALS へ申請誘導 |
| E-OP-4EYES-HARDGATE        | KV ハードゲート false  | MSG-OP-4EYES-HARDGATE-OFF    | 403      | 即時拒否                |
| E-OP-4EYES-SELF            | 自己承認試行           | MSG-OP-4EYES-SELF            | 422      | -                   |
| E-OP-4EYES-EXPIRED         | TTL 72h 経過       | MSG-OP-4EYES-EXPIRED         | 410      | 再申請が必要              |
| E-OP-4EYES-PAYLOAD-CHANGED | payload_hash 不一致 | MSG-OP-4EYES-PAYLOAD-CHANGED | 409      | 最新の内容を確認してから承認      |
| E-OP-INPUT-TICKET-REQUIRED | ticket_id 必須項目欠落 | MSG-OP-4EYES-TICKET-REQUIRED | 400      | 入力欄エラー表示            |

## 9.13 12. 未決事項

| No | 内容 | 確認先 | 期限 | ステータス |
|----|----|-----|----|-------|
|----|----|-----|----|-------|

## 9.14 13. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\newpage

# 10 セキュリティ設計書 (運営者)

## 10.1 1. 文書概要

### 10.1.1 1.1 目的

運営者システムのセキュリティ対策を一元化する。監査ログのハッシュチェーン構造と 3 区分保持 (1y / 5y / 7y) が本書の正本 (共有概念)。accounts\_retired 永久保持、GDPR 越境移転対応、運営者側固有の不正利用検知 / アクセス制御 / Webhook 一次受信のセキュリティ要件を扱う。

### 10.1.2 1.2 対象範囲

- 対象: 運営者側セキュリティ全般、メイン側からも参照される **監査ログハッシュチェーン構造・3 区分保持 (共有概念正本)**
- 対象外: PII 暗号化 / オーナー派生 / 暗号 管理 (マスター)(メイン側 [10\\_セキュリティ設計書.md §3 / §8](#) を参照)

### 10.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

### 10.1.4 1.4 関連ドキュメント

| ドキュメント名        | 役割                                             | 参照先                                  |
|----------------|------------------------------------------------|--------------------------------------|
| 索引             | 11 ドキュメント体系の俯瞰                                 | 00_索引.md                             |
| 共有概念対応表        | 監査ログ / / PII の正本所在                             | ../共有/共有概念.md                        |
| 認証・認可設計書       | 6 段認可 / 4-eyes / MFA / IP allowlist            | 09_認証認可設計書.md                        |
| 権限設計書          | 4-eyes 対象 10 操作                                | 05_権限設計書.md                          |
| テーブル定義書        | audit_logs / webhook_events / accounts_retired | 04_テーブル定義書.md                        |
| 課金・請求設計書       | 請求書 7 年保持 / 電子帳簿保存法                            | 11_課金請求設計書.md                        |
| メイン側 セキュリティ設計書 | PII 暗号化 / 管理 (正本)                              | ../01_メインシステム/個別設計書群/10_セキュリティ設計書.md |

## 10.2 2. セキュリティ基本方針

### 10.2.1 2.1 保護対象 (運営者側固有)

- 運営者の認証情報 (パスワード / MFA シークレット / 回復コード)
- 監査ログ (改ざん検知必須、ハッシュチェーン)
- 削除済み契約のスラグ (**accounts\_retired**、永久保持)
- 4-eyes 申請のペイロード (改ざん検知必須)
- Webhook ペイロード (差分検出による改ざん検知)

### 10.2.2 2.2 想定脅威 (運営者側固有)

- 運営者の内部不正 (高権限の濫用)
- 監査ログの改ざん・削除
- 4-eyes 承認の迂回 (申請ペイロードの差し替え / 自己承認)
- Webhook ペイロードの差し替え (Stripe 連携)
- 法令違反 (GDPR 越境移転、電子帳簿保存法、APPI 等)

### 10.2.3 2.3 基本対策方針

- 多段ガード** (IP allowlist + MFA + 再認証 + 4-eyes + 監査ログ + ハードゲート KV)
- 改ざん検知** (ハッシュチェーン監査 + payload\_hash)
- 永久保持** (**accounts\_retired** / **billing\_invoices** 7 年)
- 法令対応** (APPI / GDPR / 国税通則法 / 電子帳簿保存法 / 改正電気通信事業法 / 特定電子メール法)

## 10.3 3. データ保護 (運営者側固有)

メイン側 [10\\_セキュリティ設計書.md §3](#) を正本とする。本書では運営者側固有のみ:

| 対象データ                | 保護レベル | 保存時の対策                                            | 通信時の対策                 | ログ出力可否               |
|----------------------|-------|---------------------------------------------------|------------------------|----------------------|
| 運営者パスワード             | 最高    | Argon2id(運営者強化プロファイル m=128MB, t=4, p=4, salt=16B) | TLS 1.2+               | 不可                   |
| MFA シークレット           | 最高    | AES-256-GCM(オーナー派生 相当)                            | TLS 1.2+               | 不可                   |
| MFA 回復コード            | 最高    | Argon2id ハッシュ                                     | TLS 1.2+               | 不可                   |
| 4-eyes 申請ペイロード       | 高     | payload_hash(SHA-256) による改ざん検知                    | TLS 1.2+               | 監査ログには含む(秘匿情報はマスキング) |
| Stripe Webhook ペイロード | 高     | webhook_events に原文保存 + SHA-256 差分検出               | TLS 1.2+ + Stripe 署名検証 | 監査ログ用に保存             |

## 10.4 4. 入力値検証

| 対象               | 検証内容                          | 対策する脅威         |
|------------------|-------------------------------|----------------|
| API リクエスト        | Zod スキーマ + ticket_id 形式検証     | 入力エラー / 型混乱    |
| 4-eyes 申請ペイロード   | JSON Schema + サイズ上限           | DoS / インジェクション |
| Stripe Webhook   | 署名検証 (Stripe-Signature ヘッダ)   | 改ざん / リプレイ     |
| お知らせ本文 (SCR-094) | 入稿時 + 表示時の 2 重サニタイズ (NFR-309) | XSS            |

## 10.5 5. Web 脆弱性対策

メイン側 10\_セキュリティ設計書.md §5 を踏襲。運営者側固有:

### 10.5.1 5.1 CSP / Web セキュリティヘッダ (運営者側)

Content-Security-Policy:

```
default-src 'self';
script-src 'self' 'wasm-unsafe-eval';
style-src 'self' 'unsafe-inline';
img-src 'self' data:;
connect-src 'self' https://app.open-faq.example.com;
frame-ancestors 'none';
form-action 'self';
base-uri 'self';
upgrade-insecure-requests
```

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

X-Content-Type-Options: nosniff

X-Frame-Options: DENY

Referrer-Policy: strict-origin-when-cross-origin

Permissions-Policy: camera=(), microphone=(), geolocation=()

利用者側 Cookie とは Domain スコープを分離、CORS も完全閉 (Access-Control-Allow-Origin: https://admin.open-faq.example.com 固定)。

### 10.5.2 5.2 4-eyes 承認画面の CSRF

- Double Submit Cookie + payload\_hash 二重検証
- ログイン失敗ロックアウト: 5 回失敗で 15 分

## 10.6 6. アクセス制御

| 対象            | 制御方法                         | 関連設計書            |
|---------------|------------------------------|------------------|
| 運営者画面         | IP allowlist + MFA + 6 段認可判定 | 09_認証認可設計書.md    |
| 4-eyes 対象 API | 6 段認可 + KV ハードゲート            | 09_認証認可設計書.md §7 |

| 対象      | 制御方法                   | 関連設計書              |
|---------|------------------------|--------------------|
| 監査ログ参照  | 全運営者参照可                | 本書 §7              |
| Webhook | mTLS + JWT + Stripe 署名 | 03_API 設計書.md §3.5 |

## 10.7 7. 監査・ログ (本書の中核、共有概念正本)

### 10.7.1 7.1 ハッシュチェーン構造 (§7.3 から移管)

#### 10.7.1.1 テーブルスキーマ (audit\_logs)

| 列名               | 型          | 説明                                                  |
|------------------|------------|-----------------------------------------------------|
| id               | TEXT(UUID) | レコード ID                                             |
| prev_hash        | TEXT(hex)  | 前レコードの record_hash(初行は固定値 0x00...)                  |
| record_hash      | TEXT(hex)  | 'SHA-256(prev_hash                                  |
| actor_id         | TEXT       | 操作者 ID(service_operators.id / accounts.id / system) |
| actor_type       | TEXT       | service_operator / admin / end_user / system        |
| action           | TEXT       | <resource>.<verb> 形式                                |
| target_id        | TEXT       | 操作対象 ID                                             |
| target_type      | TEXT       | 操作対象種別                                              |
| owner_account_id | TEXT       | 影響契約 (運営者横断操作は NULL 可)                              |
| before_value     | JSON       | 操作前の値 (差分のみ)                                        |
| after_value      | JSON       | 操作後の値 (差分のみ)                                        |
| ip_masked        | TEXT       | IPv4 末オクテット 0、IPv6 末 80 ビット 0                       |
| ticket_id        | TEXT       | 対応チケット ID(FR-231)                                   |
| occurred_at      | TIMESTAMP  | 発生時刻                                                |
| retention_class  | TEXT       | 1y / 5y / 7y(NFR-602 と整合)                           |

#### 10.7.1.2 ハッシュチェーン計算式

`record_hash = SHA-256(prev_hash || canonical_json(他全フィールド))`

- `canonical_json` 仕様: JCS(JSON Canonicalization Scheme, RFC 8785) 準拠、キーをコードポイント昇順ソート、Unicode NFC 正規化、数値 ES6 ToString 規則、null/true/false リテラル維持、文字列内 Unicode はサロゲートペア保持し空白除去
- Webhook ペイロード差分用は本仕様 + EXCLUDE\_FIELDS (§9 付録 H) 引数差のみ

#### 10.7.1.3 鍵管理

- 単一 (Cloudflare Secret Store、年次ローテーション、60 日 dual-decrypt)
- HKDF info 値: `info=audit-export / info=mfa-setup / info=re-auth / info=internal-api`

#### 10.7.1.4 検証バッチ

- 日次バッチ `AuditChainVerifierWorker`(02:00 JST 起動)
- 全件再計算 (直近 90 日窓ではなく全件)
- 不一致検出時: 運営者 `inbox(system/high)+ メール + 検証実行ログ` を `audit_logs(action='audit.chain.verify.fail', retention_class='5y')` に記録

#### 10.7.1.5 IP マスク (NFR-306)

| 種類   | 元 IP                                   | マスク後                       |
|------|----------------------------------------|----------------------------|
| IPv4 | 203.0.113.42                           | 203.0.113.0                |
| IPv6 | 2001:db8:1234:5678:9abc:def0:1234:5678 | 2001:db8:1234:5678:0:0:0:0 |

### 10.7.2 7.2 3 区分保持の物理実装 (§7.4 / D-08、共有概念正本)

| 区分         | retention | 期間                           | 対象 action コード                                                                                                                                                                                                                                            |
|------------|-----------|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 業務監査 (a)   | 1y        | 1 年 (NFR-602a)               | faq.create、faq.update、chat.reply、account.login、inbox.read 等利用者側操作                                                                                                                                                                                        |
| 運営者高権限 (b) | 5y        | 5 年 (NFR-602d)               | owner.suspend、owner.restore、owner.physical_delete、ai_parameter.update、rate_limit.override、budget_limit.override、announcement.send、operator.invite、operator.disable、webhook.replay、prod.direct_change、audit.export、pii_rule.update、webhook.payload_diff.* |
| 課金・取引 (c)  | 7y        | 7 年 (NFR-602b、電子帳簿保存法・国税通則法) | billing.invoice.issued、billing.credit_note.issued、billing.cron.run、stripe.event.processed                                                                                                                                                                |

値の正本表記: `audit_logs.retention_class` の値は **クラス名表記** (`general / billing / operator_high_priv`) を正本とする。期間表記 (`1y / 5y / 7y`) はクラス名から導出できる人間可読補助。詳細は [04\\_テーブル定義書.md § 2.1](#) を参照。

### 10.7.3 7.3 物理削除バッチ

- ・ 日次 03:00 JST 起動 (Cron Triggers)
- ・ `DELETE FROM audit_logs WHERE retention_class='1y' AND occurred_at < now() - 365d`
- ・ 5y / 7y も同様
- ・ 削除前に R2 へ圧縮アーカイブ (法令対応エビデンス保管、年次)

### 10.7.4 7.4 tombstone 方式

- ・ 保持期間経過後の削除および退会確定時: 本文 (actor / target / IP / payload) を物理削除しつつ、`id / prev_hash / current_hash / deleted_at` を保持
- ・ tombstone 自体は監査ログの保持期間を超えても削除しない (チェーン破断防止)
- ・ NFR-306 / NFR-602c / NFR-604 の日次再計算でハッシュチェーン連続性を維持

### 10.7.5 7.5 監査対象操作の網羅範囲

詳細はメイン側 [10\\_セキュリティ設計書.md § 7.2](#) と運営者側 [権限設計書 § 7](#) を参照。

### 10.7.6 7.6 監査ログエクスポート (§10.5)

| 用途              | キー (HKDF info)               | 有効期限    |
|-----------------|------------------------------|---------|
| 監査ログエクスポート署名    | info=audit-export(グローバル派生 )  | ファイル単位  |
| 監査ログ R2 アーカイブ署名 | info=audit-archive(グローバル派生 ) | アーカイブ単位 |

R2 アーカイブ後の再検証: `R2AuditArchiveWorker` が書き出す JSONL の末尾に `chain_summary` 行 (最終 `record_hash` + HMAC-SHA256 署名) を付与。RB-017 で復元時検証手順規定。

## 10.8 8. 秘密情報管理 (運営者側固有)

メイン側 [10\\_セキュリティ設計書.md § 8](#) を正本とする。運営者側固有:

| 鍵種別               | 保管                                         | 用途               | ローテーション          |
|-------------------|--------------------------------------------|------------------|------------------|
| MFA シークレット        | operator_mfa_secrets(AES-256-GCM、オーナー派生 )  | TOTP 検証          | アカウント更新時         |
| MFA 回復コード         | operator_mfa_recovery_codes(Argon2id ハッシュ) | MFA 復旧           | 1 回限り使用          |
| 4-eyes ペイロード hash | operator_approvals.payload_hash(SHA-256)   | 改ざん検知            | -                |
| 内部 API JWT 署名     | info=internal-api(グローバル派生 )                | 連携 IF mTLS + JWT | リクエスト毎 (exp 5 分) |
| MFA セットアップトークン    | info=mfa-setup(グローバル派生 )                   | MFA 初回設定         | 72 時間            |
| 再認証セッショントークン      | info=re-auth(グローバル派生 )                     | 重要操作前再認証         | 5 分 (1 回限り)      |

## 10.9 9. SaaS 特有のセキュリティ観点 (運営者側固有)

| 観点           | 対策                                                             | 関連設計書                    |
|--------------|----------------------------------------------------------------|--------------------------|
| 管理者権限の濫用防止   | 4-eyes 多段承認 + 監査ログ全件 + ハードゲート KV                               | 09_ 認証認可設計書.md §7/ 本書 §7 |
| 監査ログ改ざん防止    | ハッシュチェーン + 完全性検証バッチ + tombstone                                | 本書 §7                    |
| GDPR 越境移転対応  | owner_registration_reviews で EU/EEA/UK 契約を審査 (4-eyes 承認 + 同意書) | §10                      |
| 削除済み契約の証跡    | accounts_retired 永久保持 (スラグのみ)                                  | 04_ テーブル定義書.md §3.13     |
| MFA 自己リセット禁止 | 別運営者承認必須                                                       | 09_ 認証認可設計書.md §4        |

## 10.10 10. 法令対応 (§1.5 から移管)

| 法令                  | 影響箇所          | 物理化方針                                                                 |
|---------------------|---------------|-----------------------------------------------------------------------|
| APPI 30 条 (不適正利用禁止) | 監査ログ閲覧自体の記録   | audit.search action コード (retention_class='1y') で検索操作を記録               |
| APPI 33 条 (開示請求)    | 運営者手動対応       | inbox_messages で運営者へ通知し手動対応                                           |
| GDPR 越境移転規制 (46 条)  | データリージョン管理    | MVP は Cloudflare APAC リージョン固定。EU 顧客の契約登録時は §10.1 参照                   |
| 国税通則法・法人税法施行規則      | 課金エビデンス 7 年保持 | audit_logs.retention_class='7y' で識別、billing_invoices は 7 年保持          |
| 電子帳簿保存法 (真実性)       | 取引データ改ざん防止    | 監査ログハッシュチェーン (prev_hash                                               |
| 電子帳簿保存法 (可視性)       | 3 検索要件        | SCR-096 で billing_invoices の検索 UI 提供 (取引日範囲・金額範囲・owner_account_id 指定) |
| 電子帳簿保存法 (関連書類保存)    | 取引情報 5 年保持    | audit_logs.retention_class='5y'                                       |
| 改正電気通信事業法           | 外部送信規律        | SCR-094 で外部送信先一覧を運営者通知                                                |
| 特定電子メール法            | 運営者発通知        | メール本文末尾に法人名・住所・問合せ先・配信停止 URL 自動付与                                     |

### 10.10.1 10.1 GDPR 越境移転規制への運用ガード (§1.5.1)

EU/EEA/UK 検知時のワークフロー:

- ・ **検知点**: 契約登録フォーム (SCR-002) で「事業所所在地」「主要顧客所在地」必須入力
- ・ **判定基準**: 国コード ISO 3166-1 alpha-2 ホワイトリスト (EU 27 + EEA 3 + UK)
- ・ **動作**:
  - owner\_registration\_reviews.status='pending\_legal\_review' に申込情報を保存
  - 運営者 inbox(legal/high) 通知 + メール送信
  - メイン側 SCR-002 完了画面に「審査中」表示
- ・ **4-eyes 承認**: 法務確認画面の事後添付と監査ログ記録を必須
- ・ **同意取得書面**: 「日本データセンター処理同意書」を別途締結、書面 ID のみ audit\_logs(owner.legal\_review.approve, retention\_class='5y') に記録
- ・ **監査ログ**: owner.legal\_review.{detect, approve, reject} の 3 action コード (retention\_class='5y')
- ・ **Runbook**: RB-023(EU 顧客検知時の対応)

## 10.11 11. 不正利用検知 (運営者側固有)

メイン側 10\_セキュリティ設計書.md §10 を参照。運営者側固有:

- ・ 短時間で複数契約に対する高権限操作 → 運営者通知 (**critical**)
- ・ 4-eyes 申請の異常パターン (同一申請者から連続) → 運営者通知

## 10.12 12. 監視 (運用統合)

(運用詳細は 03\_運用/運用手順書.md を参照、本書では監視対象のみ)



| 監視対象                 | 閾値        | アクション                    |
|----------------------|-----------|--------------------------|
| 監査ログ完全性              | 差異検出      | 運営者通知 (critical)+ DB ロック |
| Webhook DLQ          | 件数 > 10   | 運営者通知 (high)             |
| MFA 失敗率              | 5% / 5 分  | 運営者通知 (high)             |
| Stripe Webhook 受信失敗率 | > 5% / 1h | 運営者通知 (high、NFR-808)     |
| 月次請求確定 cron 失敗       | 3 回連続     | 運営者通知 (high、FR-303)      |

## 10.13 13. 脆弱性対応 SLA・SCA・ペネトレーション (§10.10)

| 項目                    | 仕様                                                                                          |
|-----------------------|---------------------------------------------------------------------------------------------|
| 脆弱性対応 SLA(NFR-330)    | Critical(CVSS 9.0+ / 悪用観測あり)= 24h、High(7.0~8.9)= 7d、Medium(4.0~6.9)= 30d、Low(<4.0)= 次定例リリース |
| SLA 超過対応              | 運営者ダッシュボード (SCR-090 系) で可視化                                                                 |
| SCA(NFR-331)          | npm audit / Dependabot / Trivy 等を CI に必須組込、週次フルスキャン                                         |
| Critical 検出時          | NFR-330 の SLA に従い対応開始、未対応 Critical でのリリースをブロック                                              |
| ペネトレーションテスト (NFR-332) | 年 1 回以上 + 重大機能変更時 (認証・認可・課金・運営者操作・AI 推論基盤の変更)                                               |
| 実施記録                  | 範囲・実施日・発見項目・対応状況を 5 年間保持 (audit_logs(retention_class='5y'))                                 |

## 10.14 14. ウィジェット保護 / PII マスキング / プロンプト注入対策

メイン側 [10\\_セキュリティ設計書.md §12~13](#) を正本とし、運営者側からは参照のみ。

PII 3 層検出の運用詳細 (運営者側固有):

- 第 1 層 (正規表現): <5ms、既知パターン再現率 100%(国内携帯 / 固定電話・主要メール形式・JCB / VISA / Master / AMEX(Luhn 検証)・マイナンバー (チェックデジット)・7 桁郵便番号・IPv4/IPv6)
- 第 3 層 (FAQ 整合性検査): <50ms、参照 FAQ 外固有名詞・数値・手順の検出再現率 ☑ 95% / 適合率 ☑ 90%
- マスキング形式: 【情報型】(例: 【電話番号】)
- 誤検出救済フロー: 報告 → 運営者 3 営業日判定 → KV ルール更新 (KV キー: pii-rules:regex / pii-rules:classifier、TTL 60s)
- 過去データは修正しない (今後の検出のみ適用、FR-064(d))

プロンプト注入対策の運用詳細 (運営者側固有):

- 回帰テストセット保守: FR-063、20 ケース以上、四半期更新
- 攻撃パターン: 役割再定義 / タグ脱出 / コード注入 / 言語切替誘導 / 指示上書き / ロール変更要求 / システムプロンプト開示要求 / 参照 FAQ 外の実事回答誘導 / 機密情報抽出誘導
- 実行タイミング: AI モデル変更時 / プロンプトテンプレート変更時 / 四半期定期
- データセット管理者: 運営者 (SCR-092 系で管理 UI 提供)

## 10.15 15. Webhook 比較除外フィールド (付録 H、D-06)

Stripe Webhook ペイロード正規化 JSON ハッシュ計算で **除外する** 非決定的フィールド:

| フィールドパス                                   | 理由                                    |
|-------------------------------------------|---------------------------------------|
| \$.created                                | イベント生成タイムスタンプ (再送で変動)                 |
| \$.request.id                             | Stripe 内部リクエスト ID (再送で変動)             |
| \$.request.idempotency_key                | Stripe 側の冪等性キー再発行ありえる                 |
| \$.livemode                               | テストモード / 本番モードでの値差分                   |
| \$.data.object.created                    | リソース作成時刻 (API 仕様変更耐性のため除外)            |
| \$.data.object.metadata.stripe_request_id | Stripe 内部メタデータ                        |
| \$.data.object.latest_charge.id (該当時)     | 同一イベント内派生リソース ID                      |
| \$.api_version                            | Stripe API バージョン (再送時に最新バージョンへ昇格の可能性) |

正規化方式:

- 上記フィールドを削除

2. JSON のキーを再帰的にアルファベット昇順ソート
3. 空白文字をすべて除去 (\\s+ 完全削除、文字列値内は保持)
4. UTF-8 バイト列に対し SHA-256 を計算

詳細実装は [04\\_テーブル定義書.md §3.9 webhook\\_payload\\_diffs](#) 参照。

## 10.16 16. バックアップ・復旧

メイン側 [10\\_セキュリティ設計書.md §14](#) を参照。

## 10.17 17. 未決事項

(該当なし)

## 10.18 18. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |

\\newpage

# 11 課金・請求設計書 (運営者)

## 11.1 1. 文書概要

### 11.1.1 1.1 目的

運営者側の課金・請求機能 (**Stripe Webhook 一次受信** / DLQ 30 日リプレイ / 月次請求確定 cron / 請求書 7 年保持 / Webhook ペイロード差分検出) を一元化する。

### 11.1.2 1.2 対象範囲

- 対象: Stripe Webhook 一次受信処理、DLQ 管理、月次請求確定、請求書 7 年保持、Webhook ペイロード差分検出、契約別上書き (運営者操作)
- 対象外: 利用者向け課金 UI (SCR-015 / SCR-016 / SCR-024) — [01\\_メインシステム/個別設計書群/11\\_課金請求設計書.md](#) 参照、契約モデル (単一プラン定義はメイン側正本)

### 11.1.3 1.3 版数

| 項目  | 値          |
|-----|------------|
| 版数  | 1.0        |
| 更新日 | 2026-05-17 |

### 11.1.4 1.4 関連ドキュメント

| ドキュメント名   | 役割                                                      | 参照先             |
|-----------|---------------------------------------------------------|-----------------|
| 索引        | 11 ドキュメント体系の俯瞰                                          | 00_索引.md        |
| 共有概念対応表   | contract_status / Stripe Webhook / 契約上書きテーブル            | ../共有/共有概念.md   |
| API 設計書   | Stripe Webhook 一次受信 API / IF #10 / IF #1 送信             | 03_API 設計書.md   |
| テーブル定義書   | webhook_events / webhook_payload_diffs / dlq_replay_log | 04_テーブル定義書.md   |
| 認証・認可設計書  | 4-eyes 対象 10 操作中の webhook.replay                        | 09_認証認可設計書.md   |
| 権限設計書     | 4-eyes 対象 10 操作                                         | 05_権限設計書.md     |
| セキュリティ設計書 | 監査ログ / 7 年保持 / 電子帳簿保存法                                  | 10_セキュリティ設計書.md |

| ドキュメント名       | 役割                | 参照先                                |
|---------------|-------------------|------------------------------------|
| メイン側 課金・請求設計書 | 契約モデル / 契約状態 (正本) | ../01_メインシステム/個別設計書群/11_課金請求設計書.md |

## 11.2 2. 契約モデル (メイン側参照)

MVP は単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル)。詳細は [メイン側 課金・請求設計書 §2](#) を正本とする。

## 11.3 3. 契約別利用上書き (運営者操作)

運営者が SCR-093 から契約単位で `owner_quota_overrides` テーブルを操作する。`resource_kind` で統一実装 (`rate_limit_overrides` / `budget_limit_overrides` の別テーブルではない)。**4-eyes 承認ログ対象** (action: `rate_limit.override`, `budget.override`)。

| resource_kind          | 用途               | 主管 SCR  | 4-eyes 種別 | KV ミラー       |
|------------------------|------------------|---------|-----------|--------------|
| widget_ask_per_min     | ウィジェット質問レート      | SCR-093 | 承認ログ      | あり (60s TTL) |
| widget_inquiry_per_min | ウィジェット未解決質問送信レート | SCR-093 | 承認ログ      | あり           |
| widget_chat_per_min    | ウィジェットチャット投稿レート  | SCR-093 | 承認ログ      | あり           |
| email_per_hour         | メール送信レート         | SCR-093 | 承認ログ      | あり           |
| admin_api_per_min      | 管理 API レート       | SCR-093 | 承認ログ      | あり           |

詳細は [04\\_テーブル定義書.md §3.26](#) 参照。

## 11.4 4. 契約状態 (メイン側参照)

`accounts.contract_status` 4 値はメイン側を正本とする ([01\\_メインシステム/個別設計書群/11\\_課金請求設計書.md §4](#))。運営者側は連携 IF #1 経由で遷移をトリガーする。

| 遷移                                         | トリガー                       | 連携 IF    | 運営者画面      |
|--------------------------------------------|----------------------------|----------|------------|
| active → suspended(支払い失敗確定)                | Stripe Smart Retries 3 回失敗 | IF #1 送信 | -          |
| active → suspended(トライアル終了)                | 月次 cron                    | IF #1 送信 | -          |
| suspended → active(再決済成功)                  | Stripe Webhook 受信          | IF #1 送信 | -          |
| suspended → active(運営者復帰)                  | 4-eyes 承認                  | IF #1 送信 | SCR-091 派生 |
| active / suspended → deleted_pending(退会申請) | 利用者操作                      | -        | -          |
| deleted_pending → deleted(30 日経過)          | 月次 cron                    | IF #4 送信 | -          |
| deleted_pending → active(退会キャンセル)          | 利用者操作                      | -        | -          |

## 11.5 5. 契約ライフサイクル (運営者側責務)

| イベント                  | 運営者責務                  | 関連 SCR     | 関連 API                                |
|-----------------------|------------------------|------------|---------------------------------------|
| サスペンション解除 (運営者)       | 4-eyes 承認 + IF #1 送信   | SCR-091 派生 | POST /admin/v1/owners/{id}/restore    |
| 強制停止                  | 4-eyes 承認 + IF #1 送信   | SCR-093 派生 | POST /admin/v1/owners/{id}/force-stop |
| 物理削除                  | 4-eyes ハードゲート + KV フラグ | SCR-091 派生 | DELETE /admin/v1/owners/{id}/physical |
| accounts_retired 永久保持 | 物理削除時に自動               | -          | -                                     |

## 11.6 6. 契約とオーナーの関係

メイン側 [§6](#) を参照。運営者側固有:

- ・法令対応: EU / EEA / UK 契約は `owner_registration_reviews` で登録審査 (GDPR 越境移転対応)
- ・4-eyes 承認 + 同意書必須 (セキュリティ設計書 10 §10.1 / RB-023 参照)

## 11.7 7. プラン変更時の仕様

MVP は単一プランのため、契約別上書きのみ(本書 §3)。階層プラン導入は Future。

## 11.8 8. 課金方式

メイン側 §8 を参照。運営者側固有:

- ・ 月次集計の確定 → 請求書発行は本書 §11(月次請求確定 cron) を正本とする
- ・ 訂正請求: Stripe Credit Note API、**運営者の手動操作のみ**(自動禁止)

## 11.9 9. 請求対象 / 請求状態

メイン側 §9 / §10 を参照。

## 11.10 10. 決済フロー

メイン側 §11 を参照。運営者側固有:

- ・ Stripe Smart Retries 委譲(独自リトライ実装禁止)
- ・ 最大3回失敗後にメイン側へ「決済失敗確定」イベント送信(連携 IF #1)
- ・ 猶予期間7日間(顧客管理側からのイベント受信時刻起点)

## 11.11 11. 月次請求確定 cron(本書の中核)

(§6.3.7 から移管)

| 項目    | 内容                                                                                                    |
|-------|-------------------------------------------------------------------------------------------------------|
| 実行頻度  | 月初1日 02:00 JST                                                                                        |
| 対象期間  | 前月の利用量                                                                                                |
| 処理内容  | 1. usage_metering から月次集計、2. 契約上書き適用、3. billing_invoices 作成、4. Stripe 請求作成 (IF #10 経由)、5. 通知メール (high) |
| 冪等性   | 同一月の二重実行はスキップ (billing_invoices.unique(owner, period))                                                |
| エラー処理 | 個別契約失敗時は他契約継続、DLQ 投入                                                                                  |
| 監査    | audit_logs.action='billing.cron.run'(retention_class=7y)                                              |

## 11.12 12. 外部決済サービス連携 (Stripe)

| 連携先    | 連携内容                                                      | 連携方式               | Webhook                 |
|--------|-----------------------------------------------------------|--------------------|-------------------------|
| Stripe | Subscription / Setup Intent / Smart Retries / Credit Note | REST API + Webhook | あり (IF #10 = 運営者側で一次受信) |

## 11.13 13. Webhook 処理 (本書の中核、共有概念正本)

### 11.13.1 13.1 Stripe Webhook 一次受信 (運営者側 → メイン転送)

(§6.3.3 / §8.5 から移管)

| 項目      | 内容                                                                                                           |
|---------|--------------------------------------------------------------------------------------------------------------|
| エンドポイント | POST https://admin.open-faq.example.com/webhooks/stripe(運営者側 API)                                            |
| ヘッダ     | Stripe-Signature: t=<unix_ts>,v1=<hmac_sha256>,v1=<hmac_sha256_alternative> / Content-Type: application/json |
| 署名検証    | Stripe-Signature ヘッダで HMAC-SHA256 検証(トレランス 300s)                                                             |
| 冪等性     | Stripe イベント ID(evt_*) で重複排除、webhook_events.event_id PK                                                       |
| 保存      | webhook_events テーブルに原文 + state(received)                                                                     |
| 状態遷移    | received → verifying_signature → checking_idempotency → processing → succeeded / failed → dlq_*(リトライ失敗時)     |
| メイン転送   | IF #10 経由でメイン側へ転送                                                                                            |

| 項目     | 内容                                       |
|--------|------------------------------------------|
| 保持期間   | 7 年 (電子帳簿保存法対応)                          |
| タイムアウト | 30 秒 (超過で 5xx 返却 → Stripe Smart Retries) |

#### 11.13.1.1 署名検証アルゴリズム

```

verifyStripeSignature(payload, header, secret, tolerance=300s):
    parts = parseHeader(header)
    timestamp = parts.t
    if |now - timestamp| > tolerance:
        return false // Replay 攻撃防止
    signedPayload = timestamp + "." + payload
    expectedSig = HMAC-SHA256(secret, signedPayload)
    for sig in parts.v1[]:
        if constantTimeEqual(sig, expectedSig):
            return true
    return false

```

失敗時: HTTP 401 即返却 + 運営者 `inbox(system/high)+ audit.webhook.signature_invalid(5y)`

#### 11.13.1.2 冪等性・差分検出

| 項目                   | 仕様                                                                            |
|----------------------|-------------------------------------------------------------------------------|
| 同 event_id + ハッシュ一致  | 200 OK 「duplicate, skipped, hash_match」 + ログ                                  |
| 同 event_id + ハッシュ不一致 | 200 OK + webhook_payload_diffs INSERT + SCR-099 記録 + 運営者 high alert + 自動上書き禁止 |

#### 11.13.1.3 内部転送対象イベント (メイン側へ mTLS + JWT 同期)

| event_type                           | 処理                 | 冪等性キー           |
|--------------------------------------|--------------------|-----------------|
| invoice.paid                         | 支払成功確定 → サスペンション解除 | Stripe event_id |
| invoice.payment_failed               | 支払失敗 → grace 突入    | Stripe event_id |
| invoice.finalized                    | 請求書確定              | Stripe event_id |
| customer.subscription.updated        | プラン変更反映            | Stripe event_id |
| customer.subscription.deleted        | 解約 → suspended 遷移  | Stripe event_id |
| customer.subscription.trial_will_end | トライアル終了予告          | Stripe event_id |
| charge.refunded                      | 返金 → 請求書更新         | Stripe event_id |

#### 11.13.2 13.2 Webhook ペイロード差分検出 (§6.7 から移管)

| 項目                  | 内容                                                                                                                                                                    |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 目的                  | Stripe API 仕様変更 / 改ざんの早期検出                                                                                                                                            |
| 検出方式                | 過去ペイロードと正規化後 SHA-256 比較、差分があれば webhook_payload_diffs に記録                                                                                                              |
| 正規化方式               | JCS(JSON Canonicalization Scheme、RFC 8785) 準拠 + 除外フィールド削除 + UTF-8 SHA-256(セキュリティ設計書 10 §15 参照)                                                                        |
| 除外フィールド (付録 H、8 項目) | created / request.id / request.idempotency_key / livemode / data.object.created / data.object.metadata.stripe_request_id / data.object.latest_charge.id / api_version |
| 通知                  | SCR-099 で運営者に表示 + 通知 (normal)                                                                                                                                         |
| 監査                  | audit_logs.action='webhook.payload_diff_detected'                                                                                                                     |

#### 11.13.3 13.3 DLQ 30 日リプレイ

| 項目                   | 仕様                                                        |
|----------------------|-----------------------------------------------------------|
| Cloudflare Queues 保持 | 4 日                                                       |
| R2 退避パス              | dlq-stripe-events/<event_id>.json                         |
| R2 保持期間              | 30 日 (dlq_archived で以降リプレイ不可)                             |
| 自動 BO                | 1m → 4m → 16m(3 回、超過で永久失敗)                                |
| 手動リプレイ               | SCR-097 から運営者の明示操作のみ (4-eyes 承認ログ、action: webhook.replay) |
| リプレイ履歴               | dlq_replay_log に保存                                        |
| エラー処理                | リプレイ失敗時は再度 DLQ、最大 3 回でアラート (high)                         |

#### 11.13.4 13.4 監視・通知

| KPI      | 閾値        | 通知                 |
|----------|-----------|--------------------|
| 1h 受信失敗率 | > 5%      | 運営者 high(NFR-808)  |
| DLQ 滞留   | 30 分以上未処理 | 運営者 high           |
| 差分検出     | 検出時       | 運営者 high + SCR-099 |
| 署名検証失敗   | 検出時       | 運営者 high           |

#### 11.14 14. 請求書・領収書 (7 年保持)

| 帳票  | 発行タイミング     | 記載項目                                   | ダウンロード可否                              | 保持期間         |
|-----|-------------|----------------------------------------|---------------------------------------|--------------|
| 請求書 | 月次請求確定 cron | 利用量 / 請求金額 / 税 / 期間 / 適格請求書(インボイス制度対応) | 利用者: SCR-015 から PDF / 運営者: SCR-096 派生 | 7 年(電子帳簿保存法) |
| 領収書 | 支払い成功時      | 支払金額 / 支払日                             | 利用者: SCR-015 から PDF                   | 7 年          |

帳票仕様 (PDF 出力 / インボイス制度対応の項目) は未決 —— メイン側未決事項 No.1 と連動。

#### 11.15 15. 課金・契約エラー時の動作 (運営者側責務)

| ケース                     | 運営者の対応                                  | 関連 SCR     | メッセージ ID                    |
|-------------------------|-----------------------------------------|------------|-----------------------------|
| Stripe Webhook 失敗 (3 回) | DLQ 確認 + 手動リプレイ                         | SCR-097    | MSG-OP-NOTIF-WEBHOOK-DLQ    |
| 月次請求確定 cron 失敗          | DLQ 確認 + 個別契約再実行                        | (運用 CLI)   | -                           |
| サスペンション解除 (運営者起動)       | 4-eyes 承認 + IF #1 送信                    | SCR-091 派生 | MSG-OP-NOTIF-SUSPEND        |
| 不正利用検知通知受信 (IF #9)      | SCR-093 から強制停止 / 契約上書き                  | SCR-093 派生 | MSG-OP-NOTIF-FRAUD-DETECTED |
| Stripe 署名検証失敗           | 監査ログ確認 + 必要なら Stripe Webhook Secret 再発行 | (運用)       | NOTIF-OP-SIG-FAIL           |

#### 11.16 16. 未決事項

| No | 内容                              | 確認先                 | ステータス               |
|----|---------------------------------|---------------------|---------------------|
| 1  | 請求書帳票仕様 (PDF 出力 / インボイス制度対応の項目) | 既存ドキュメントに帳票フォーマットなし | 要確認 (メイン側 No.1 と連動) |

#### 11.17 17. 変更履歴

| 日付         | 版数  | 変更内容 | 変更者    |
|------------|-----|------|--------|
| 2026-05-17 | 1.0 | 初版作成 | claude |